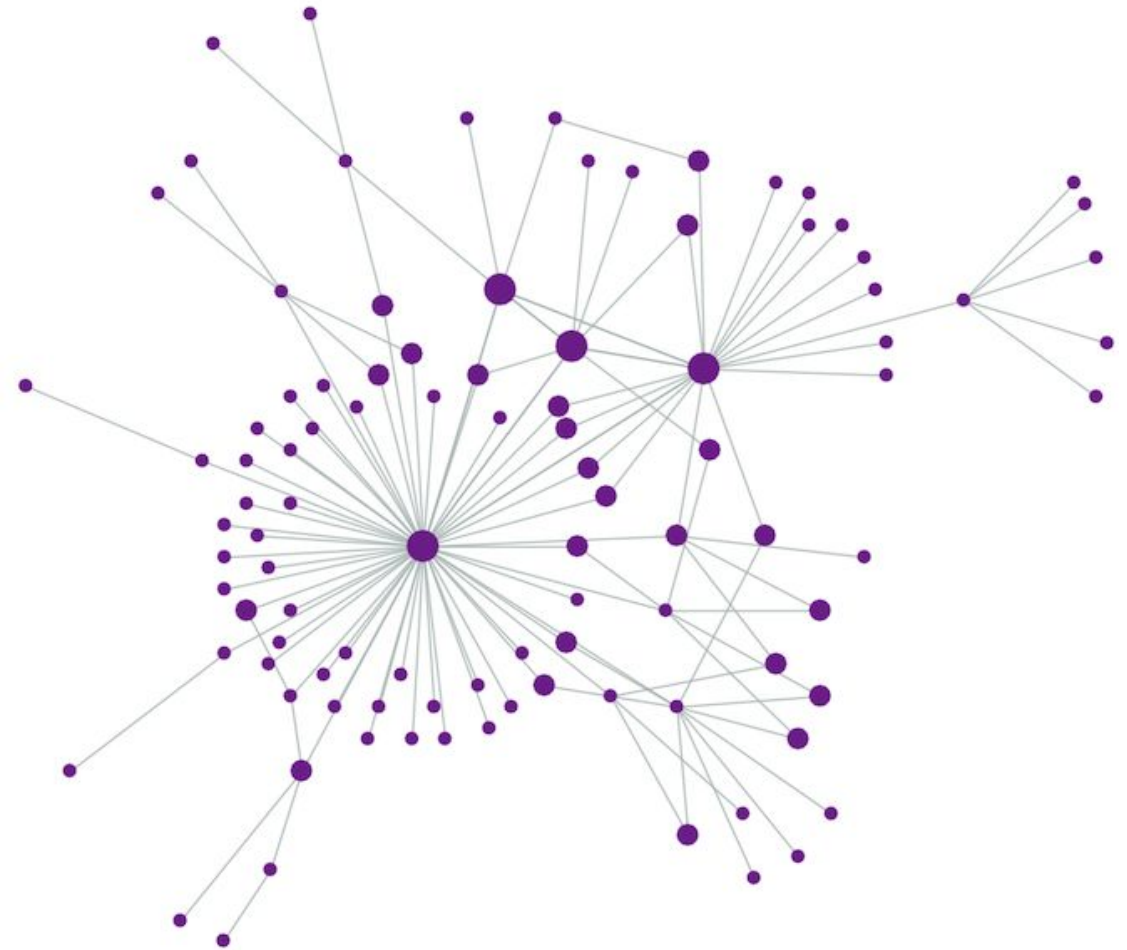


Networking and Security in Transition

**Wie moderne Netzwerke
funktionieren und wieso sie
gebraucht werden**

WAN-Edge, SSE & SASE



Linus Espach

- Ex. Seefahrer
- Gründer der Rheintec
- Studium IT-Security
- Fokus Netzwerksicherheit
- Security-Architekt



Wer hat schon Berufserfahrung?

<https://www.menti.com/>

Code:

5511 1335



Zielsetzung

Netzwerke entwickeln sich – genau wie die Applikationen, Systeme und Nutzer, die sie verbinden – **kontinuierlich** weiter. Technologische Fortschritte und veränderte Anforderungen führen dazu, dass sich Konzepte, Architekturen und Betriebsmodelle ständig wandeln.

Diese Vorlesung vermittelt einen **Überblick über klassische Netzwerkansätze**, beleuchtet deren Grenzen im Kontext moderner IT-Landschaften und führt anschliessend in zeitgemässe Architekturen und Lösungsansätze wie **SD-WAN, SSE und SASE** ein.



Was sich die letzten 10 Jahre verändert hat

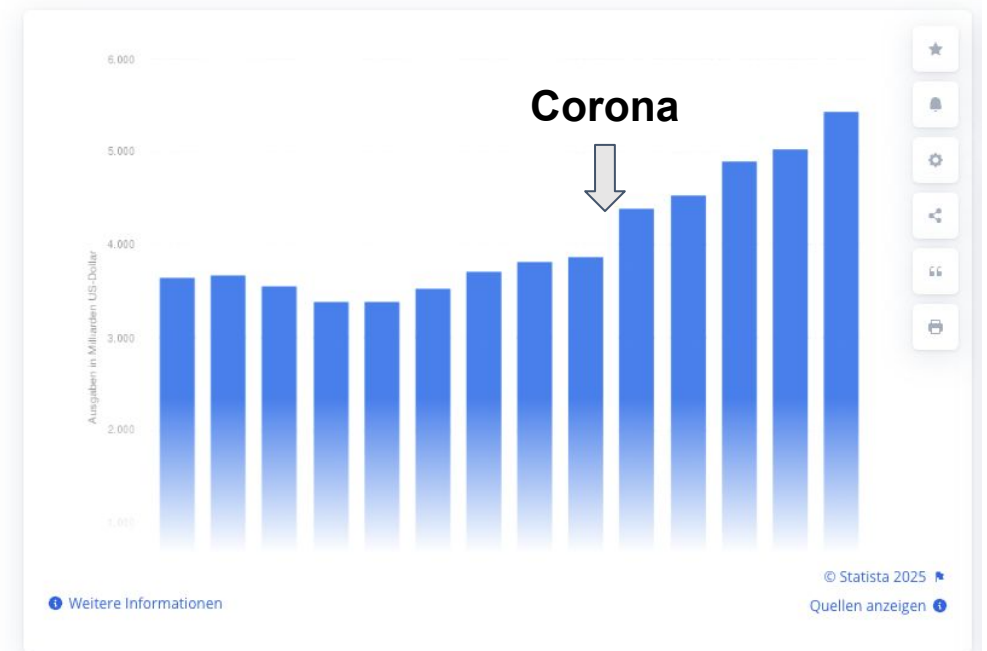
Corona hat die verbreitung des Home Offices stark getrieben. Mitarbeiter arbeiten heute nicht mehr primär an einem Standort, sondern hybrid von zu hause und dem Unternehmensstandort.

Die **Cloudifizierung** schreitet schnell voran. Unternehmen hosten nicht mehr jede Applikation selbst, sondern beziehen sie als [I,P,S]aaS aus der Cloud.

Komplexität und Heterogenität: Netze und IT-Infrastrukturen sind aufgrund des explosiven Wachstums der Wichtigkeit von IT stark mit gewachsen. Dies oft auf Basis veralteter Architekturen. Es braucht einfache, sichere und Effektive Ansätze zur Bereitstellung von Infrastruktur Services.

Telekommunikation, IT & Consumer Electronics > IT-Services

Prognose zu den weltweiten IT-Ausgaben von 2012 bis 2025
(in Milliarden US-Dollar)

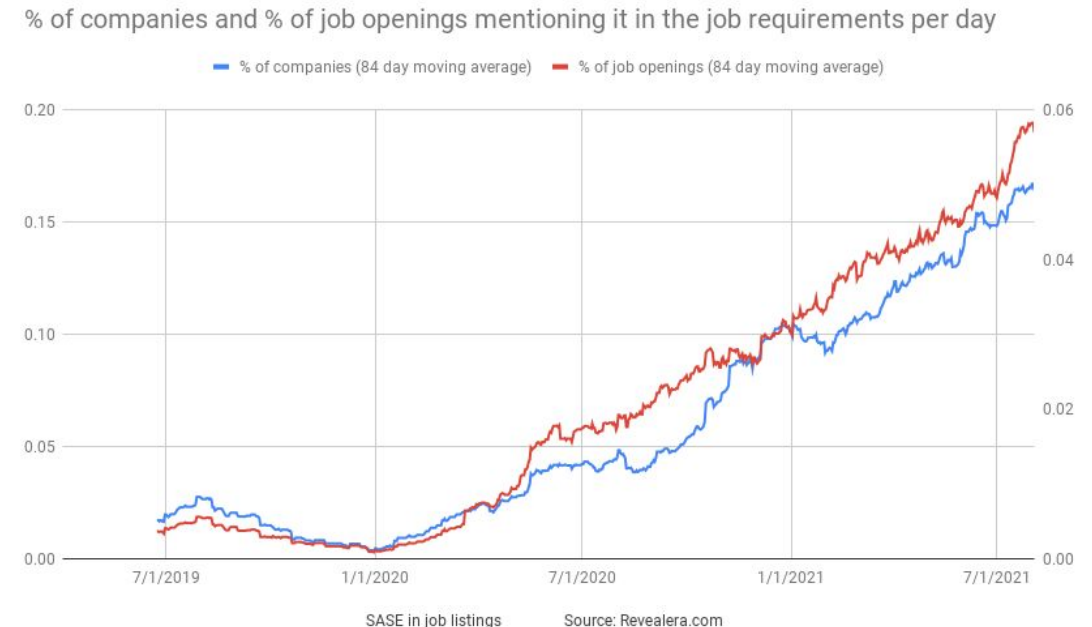


Nachfrage nach modernen Technologien wie SASE

Die **Nachfrage nach Experten** für moderne Netzwerk-Technologie **steigt**.

Anbei ein Bild, welches die Entwicklung der Nachfrage von Firmen nach Fachkräften mit dem Schlagwort “SASE” zeigt.

Es ist ersichtlich, dass diese Nachfrage sich innerhalb der Jahre zwischen 2019 und 2021 **vervielfacht** hat.



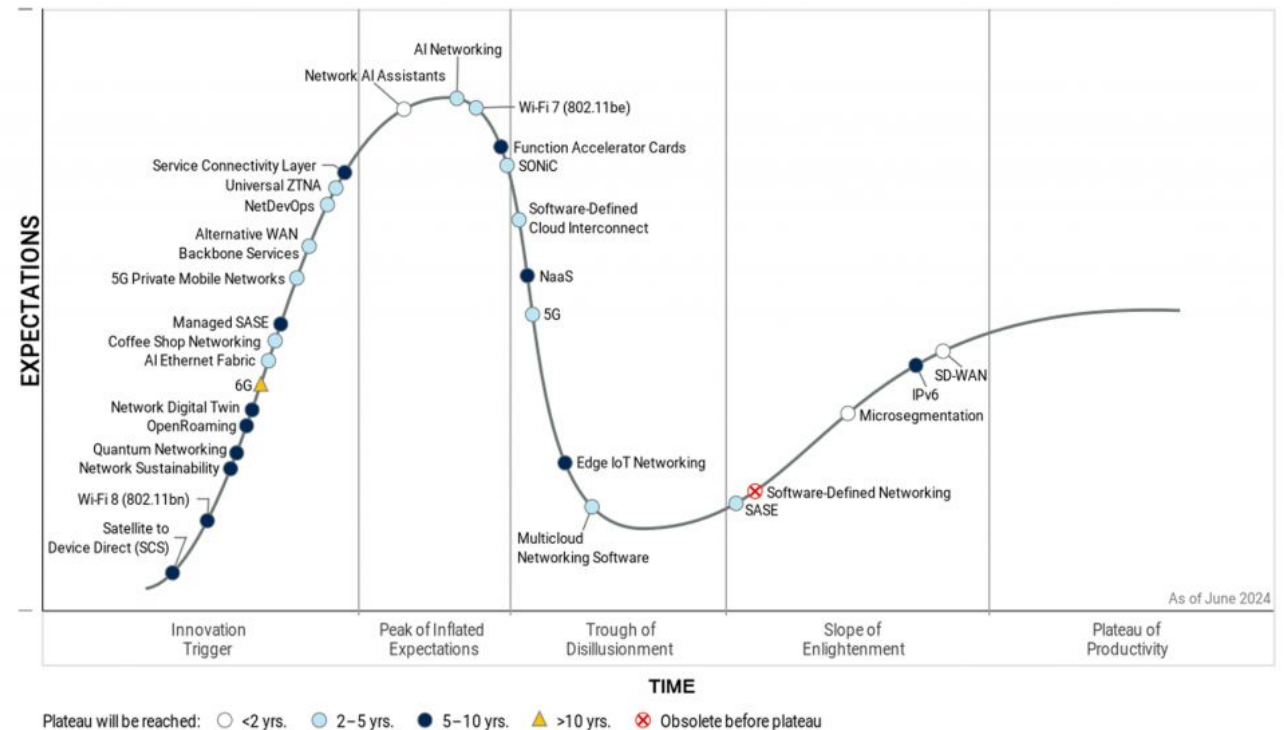
Hype und Adaption

Der IT Markt ist innovativ. Es entstehen ständig neue Produkte, Ansätze und Technologien. Während sich manche durchsetzen können, gehen andere vergessen.

Gartner dokumentiert diese Technologien in "Hype Cycles".

Figure 1: Hype Cycle for Enterprise Networking, 2024

Hype Cycle for Enterprise Networking, 2024



Hype und Adaption - Wie man die Grafik liest

X-Achse: Zeit / Reifegrad

1. **Innovation Trigger**
Eine neue Technologie taucht auf. Es gibt erste Prototypen, Medienberichte und viel Neugier, aber wenig reale Implementierung.
2. **Peak of Inflated Expectations**
Hype-Phase. Es wird stark über die Technologie berichtet, Erwartungen sind überhöht, erste erfolgreiche (und viele gescheiterte) Tests erscheinen.
3. **Trough of Disillusionment**
Die Realität holt den Hype ein. Viele Projekte scheitern oder liefern nicht wie versprochen. Interesse sinkt.
4. **Slope of Enlightenment**
Verständnis wächst. Die Technologie wird realistischer betrachtet, bewährte Einsatzszenarien entstehen.
5. **Plateau of Productivity**
Die Technologie ist etabliert und bringt echten geschäftlichen Nutzen. Sie wird breiter eingesetzt.

Y-Achse: Erwartungen

Zeigt, wie hoch die kollektive Erwartungshaltung (Medien, Anbieter, Anwender) an die jeweilige Technologie ist.

Marktlage am Beispiel SASE

SASE ist eine neue Architektur, die den Hype überstanden hat und mittlerweile mit als höchstes **strategisches Ziel** in [82%](#) der Unternehmen in europa gesetzt ist.

Es ist **neben AI** einer der stärkst **wachsenden** Märkte.

Dies liegt auch daran, dass aktuell **nicht einmal 10%** der Unternehmen SASE (gesamthaft) **einsetzen**, während SD-WAN von bereits [63%](#) der Unternehmen wenigsten an einem Standort eingesetzt wird.

Info: SD-WAN wurde **2014** populär, SASE ca. **2019** (beide Male durch Gartner)

82%

<15%

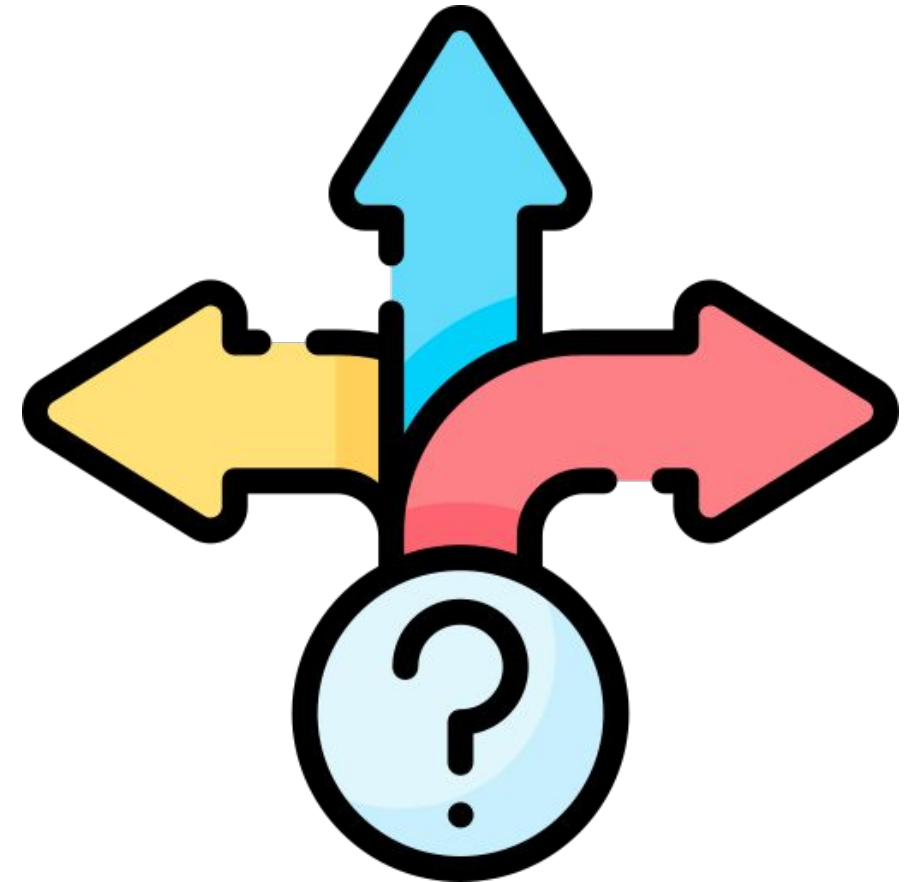
63%

Schlussfolgerung

Die IT befindet sich in einem ständigen Wandel. Moderne Technologien sind der Schlüssel zum Erfolg von morgen.

Um fundierte Entscheidungen zu treffen, ist es entscheidend, den Markt und neue Technologien zu verstehen – und zu wissen, wann welche Lösung für welchen Zweck und welches Unternehmen die richtige ist.

Wer beides verbindet – technisches Können und strategisches Verständnis – wird deutlich erfolgreicher sein als seine Konkurrenz.



WAN Edge

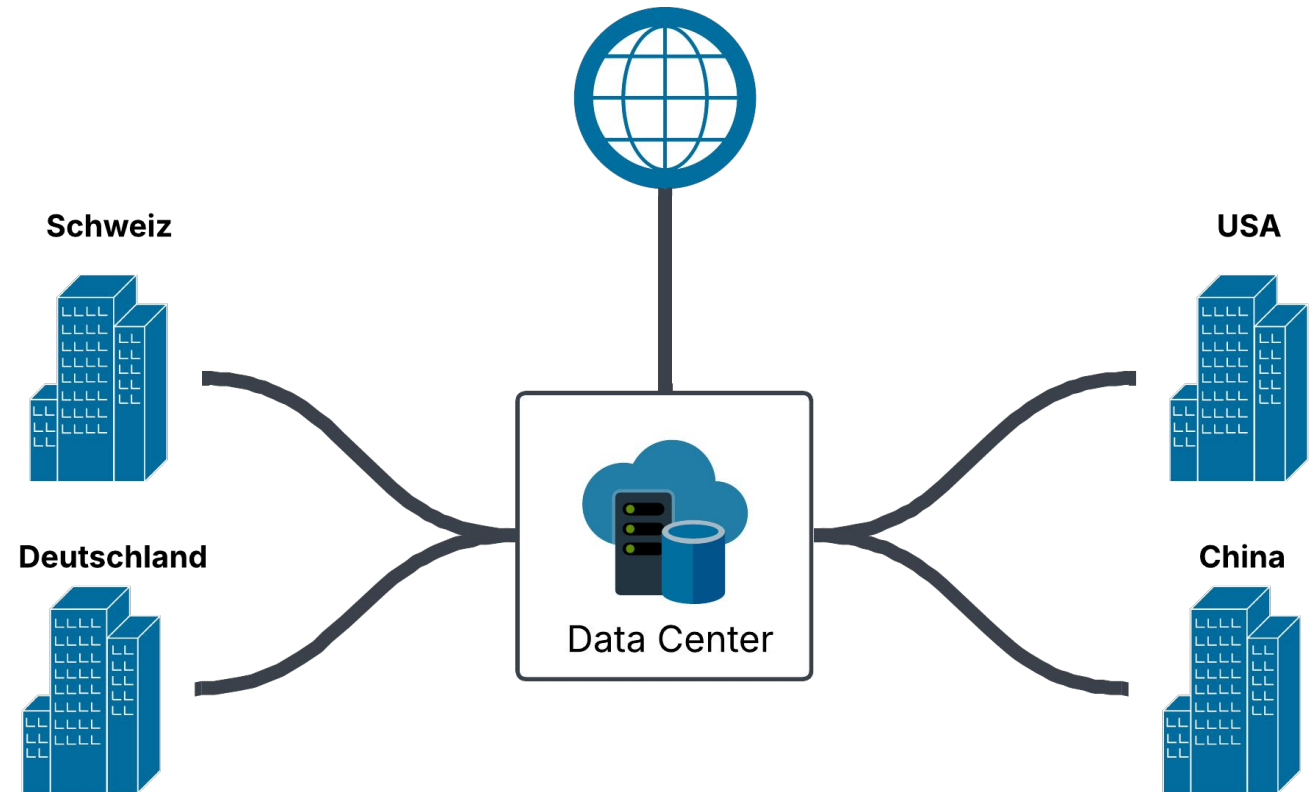
1. Einführung & Grundlagen
2. Traditionelle WAN Architekturen
3. SD-WAN

1. Einführung & Grundlagen

Was ist ein WAN?

Ein Wide Area Network (**WAN**) ist ein Telekommunikationsnetzwerk, das sich über grosse geografische Distanzen erstreckt – von Städten über Regionen bis hin zu **Ländern** oder sogar Kontinenten.

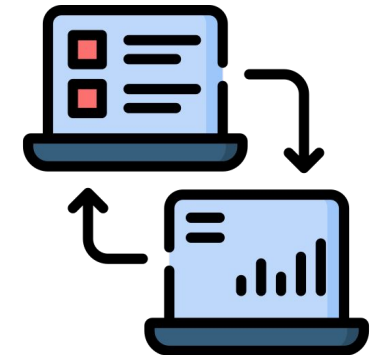
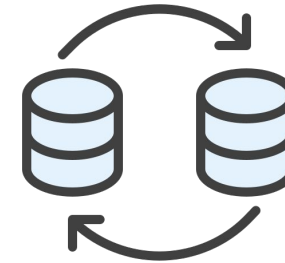
Ein WAN **verbindet** mehrere Local Area Networks (**LANs**) miteinander und ermöglicht es Organisationen, **Daten, Anwendungen und Ressourcen standortübergreifend zu nutzen** und auszutauschen.



Warum Unternehmen WANs benötigen

Moderne Unternehmen arbeiten über mehrere Standorte hinweg. Ein WAN ermöglicht:

- **Zweigstellen**, zentralisierte Daten und Anwendungen zu nutzen
- **Remote**-Mitarbeitern, sicher auf Unternehmensressourcen zuzugreifen
- **Disaster**-Recovery-Standorten, synchron zu bleiben
- **Partnern** und Lieferanten, sich effizient zu vernetzen (B2B-Kommunikation)
- **Globale** Zusammenarbeit und einheitliche Kommunikation über Standorte hinweg



Zentrale Merkmale eines WANs

- **Geografische Abdeckung:**

Deckt grosse Distanzen ab, weit über ein einzelnes Gebäude oder einen Campus hinaus (von wenigen bis zu mehreren tausend Kilometern).

- **Geschwindigkeit & Bandbreite:**

In der Regel langsamer als LANs, bedingt durch Entfernung und Kosten (Bandbreiten im Bereich von Mbit/s bis Gbit/s).

- **Kostenstruktur:**

Höhere Betriebskosten – abhängig von Bandbreite, Entfernung und vereinbarten Service Levels (SLAs).

- **Verbindungstypen:**

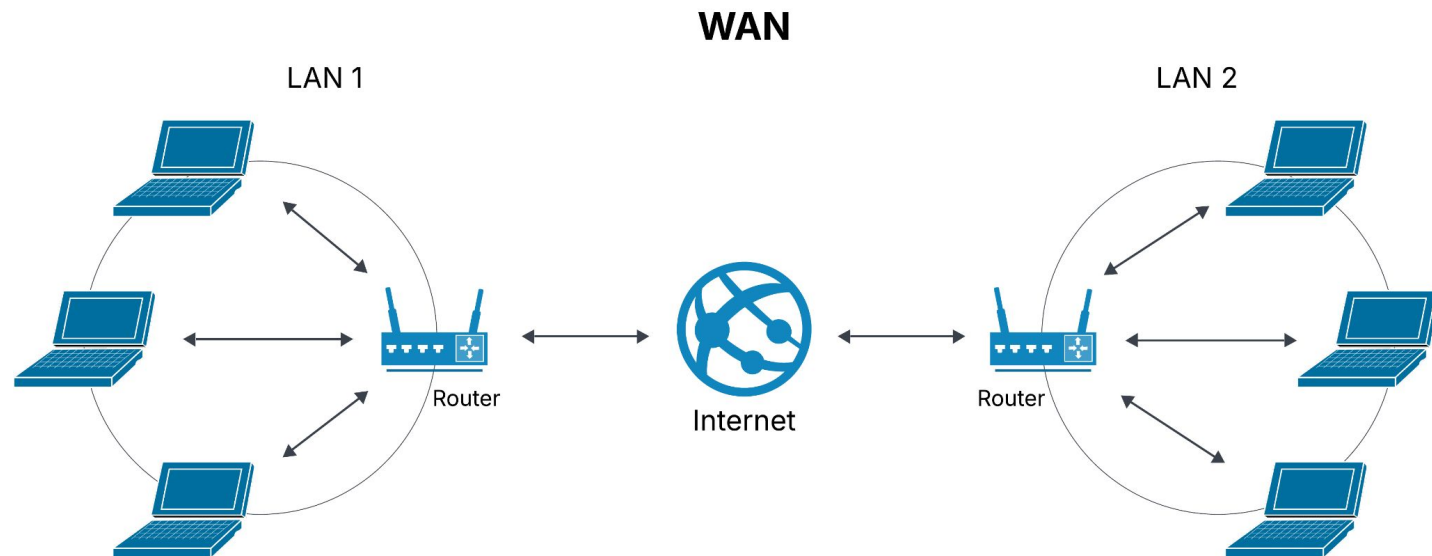
Mietleitungen, MPLS, Internet, Satellit oder drahtlose Verbindungen (4G/5G).

- **Latenz:**

Höhere Verzögerung im Vergleich zu LANs (typischerweise 10–100 ms, kann aber auch höher sein).

WAN vs LAN

Aspect	LAN	WAN
Abdeckung	Gebäude oder Campus	Städte, Länder oder Kontinente
Geschwindigkeit	1-100 Gbps	1 Mbps - 10 Gbps (typical)
Kosten	Niedrig	Hoch
Latenz	<1 ms	10-100+ ms
Technologie	Ethernet, Wi-Fi	MPLS, Leased Lines, Internet

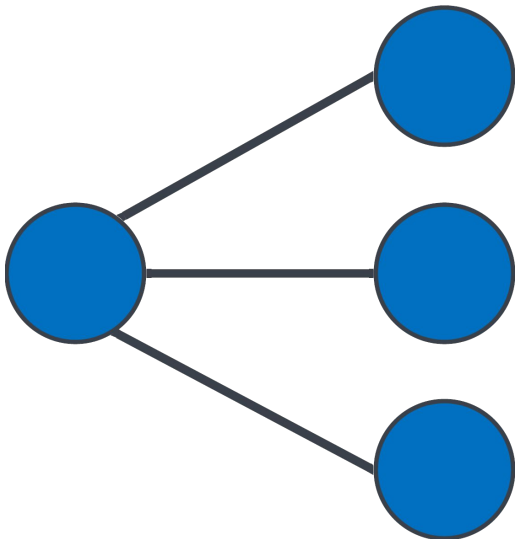


Netzwerk Topologien

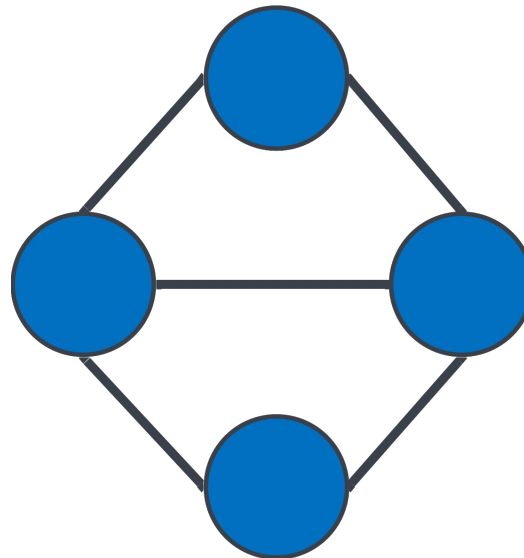
Die physische oder logische Netzwerktopologie bestimmt, wie Geräte oder Standorte miteinander verbunden sind.

In Unternehmensnetzwerken dominieren Stern-, Baum- und vermaschte Strukturen, je nach Skalierung und Redundanzbedarf.

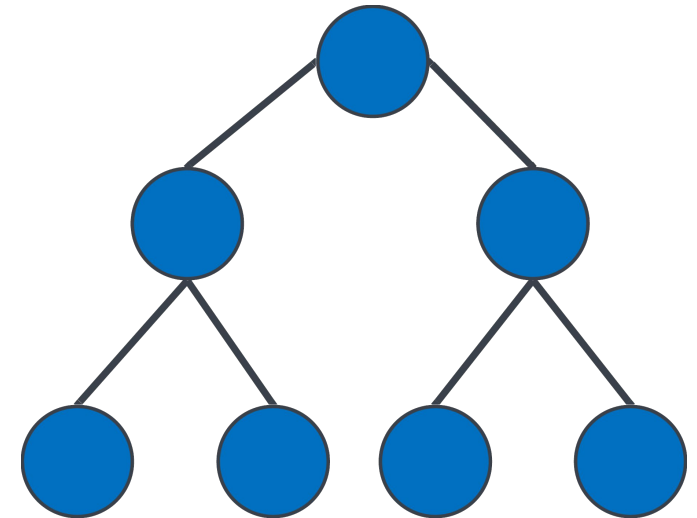
Stern Topologie



Meshed Topologie



Baum Topologie





Vergleich von Netzwerk Topologien

Topologie	Beschreibung	Vorteile	Nachteile	Typische Anwendung
Stern	Alle Geräte oder Standorte sind mit einem zentralen Knoten verbunden.	Einfache Verwaltung, klare Struktur, Ausfall eines Endgeräts hat keine Auswirkungen.	Zentrale Komponente = Single Point of Failure.	Standard in modernen LANs und kleineren WANs.
Baum	Hierarchische Erweiterung der Stern-Topologie: mehrere Sterne sind über Backbone-Switches oder Router verbunden.	Gute Skalierbarkeit, logische Segmentierung, klare Hierarchie.	Ausfall des Backbones oder zentraler Knoten beeinträchtigt viele Segmente.	Unternehmensnetzwerke, Campus-, Provider- oder Carrier-Infrastrukturen.
Mesh	Jeder Standort oder Knoten ist direkt mit jedem anderen verbunden.	Maximale Redundanz und Ausfallsicherheit, beste Performance.	Hohe Kosten und Komplexität bei vielen Knoten.	Hochverfügbare WANs, SD-WAN-Overlays, Rechenzentren.

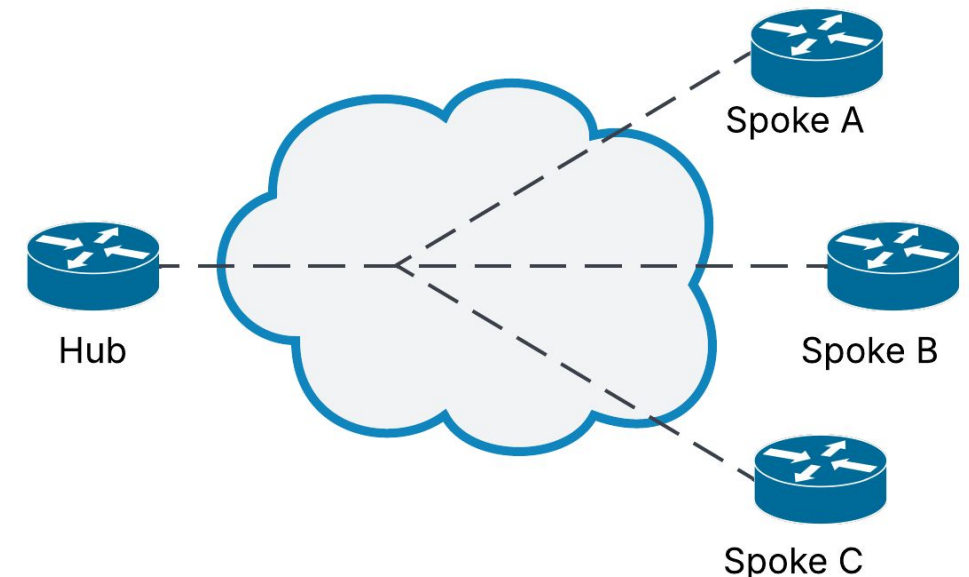
Das Hub-and-Spoke Modell

Das Hub-and-Spoke-Modell ist eine typische WAN-Topologie, bei der mehrere Außenstellen (Spokes) über eine zentrale Site (Hub) miteinander verbunden sind. Der gesamte Datenverkehr zwischen den Spokes läuft über den Hub. Der Begriff hat sich am Markt als Standard für die Standortvernetzung (Stern-Topologie) aber auch die Vernetzung in Datacentern und Clouds durchgesetzt.

Komponenten:

- **Hub (Zentrale):** Hauptstandort, oft DC oder Hauptsitz bzw. zentrale Datacenter oder Cloud Firewall.
- **Spokes (Aussenstellen):** Filialen oder Produktionsstandorte bzw. Einzelne Netze hinter DC oder Cloud-Firewalls, die nur über den Hub kommunizieren.

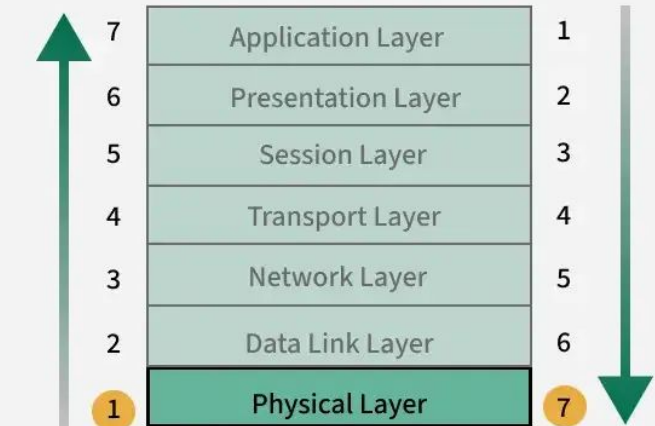
Das Modell wird gebraucht um eine einheitliche Standortvernetzung zu ermöglichen, bzw Netzsegmentierung in Datacentern und Clouds vorzunehmen.



WAN im OSI Model - Layer 1 - Physical Layer

Übliche Layer-1 Technologien für WANs:

- **Kupfer:** T1/E1 Leitungen, DSL (Digital Subscriber Line)
- **Glasfaser:** Single-/Multi-Mode, DWDM, CWDM, Metro Ethernet, Dark Fiber
- **Funk:** Richtfunk, Satelliten, 4G LTE, 5G

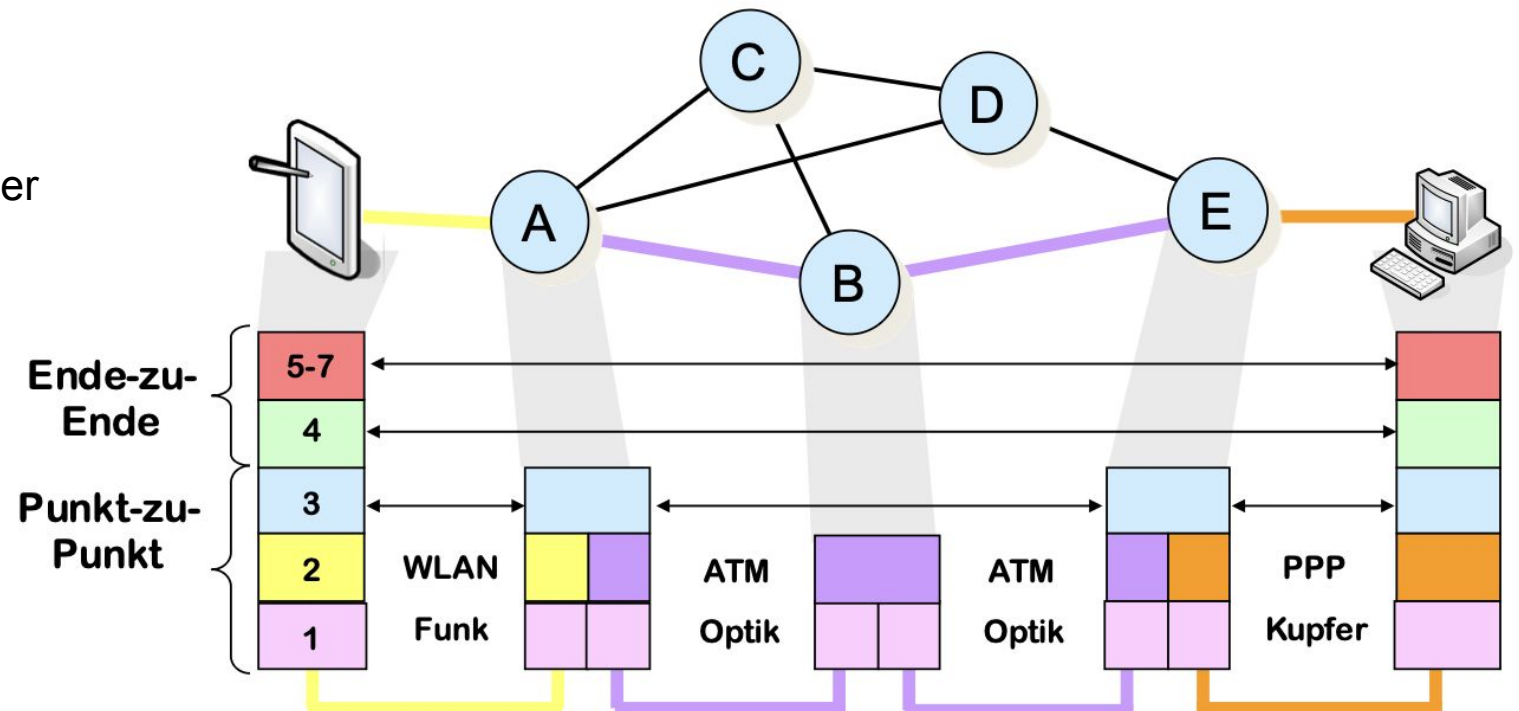


WAN in the OSI Model - Layer 2 - Data Link Layer

WAN Verbindungen von Standort zu Standorte gehen potentiell über **mehrere verschiedene physische Layer**.

Das heisst eine WAN-Architektur muss über **heterogene Technologien** hinweg funktionieren können.

Dies ist bei der **Planung** eines WANs zu berücksichtigen.





Layer-2 Encapsulation Protokolle

Wenn Daten über eine WAN-Verbindung übertragen werden, müssen sie in ein Protokollformat gekapselt werden, das zur jeweiligen WAN-Technologie passt.

Protokoll	Layer	Verwendung	Authentifizierung	Kompression	Status
HDLC	2	Serielle P2P-Verbindungen, Cisco-Standard	Nein	Nein	veraltet
PPP	2	Serielle Leitungen, Wählverbindungen (ISDN, 56K)	Ja (CHAP/PAP)	Ja	veraltet
PPPoE	2	DSL, Breitband-Zugänge	Ja	Ja	Weit verbreitet
Frame Relay	2	Paketvermitteltes WAN	Nein	Nein	Obsolet
Metro / Carrier Ethernet	2	Aktueller WAN Standard	Ja	Nein	Standard
ATM	2	Früher DSL- und MPLS-Unterbau	Nein	Nein	Obsolete
GPON / XGS-PON	2	FTTH / Glasfaser-Access	Teilweise (über PPPoE, DHCP oder VLAN-Auth)	Nein	Standard für FTTH



Carrier Ethernet

Carrier Ethernet ist eine Erweiterung des Ethernet Protokolls, um Ethernet auch für weitere Strecken und damit die Standortvernetzung von Unternehmen einsetzen zu können. Vorgänger war Metro Ethernet (CE1.0), das allerdings noch keine Service-Erweiterungen wie QoS, Monitoring, Bandbreiten, etc. angeboten hat.

3 spezifizierte Topologien:

Merkmal	E-Line	E-Tree	E-LAN
Topologie	Punkt-zu-Punkt	Sternförmig (Hub-Spoke)	Vollvermascht
Kommunikation	A ↔ B	Root ↔ Leaf	Alle ↔ Alle
Beispiel	HQ ↔ DC	HQ ↔ Filialen	4 Standorte, alle verbunden
Broadcast-Unterstützung	Ja	Eingeschränkt	Ja
Komplexität	Gering	Mittel	Hoch
Kosten	Niedrig	Mittel	Hoch

Carrier Ethernet

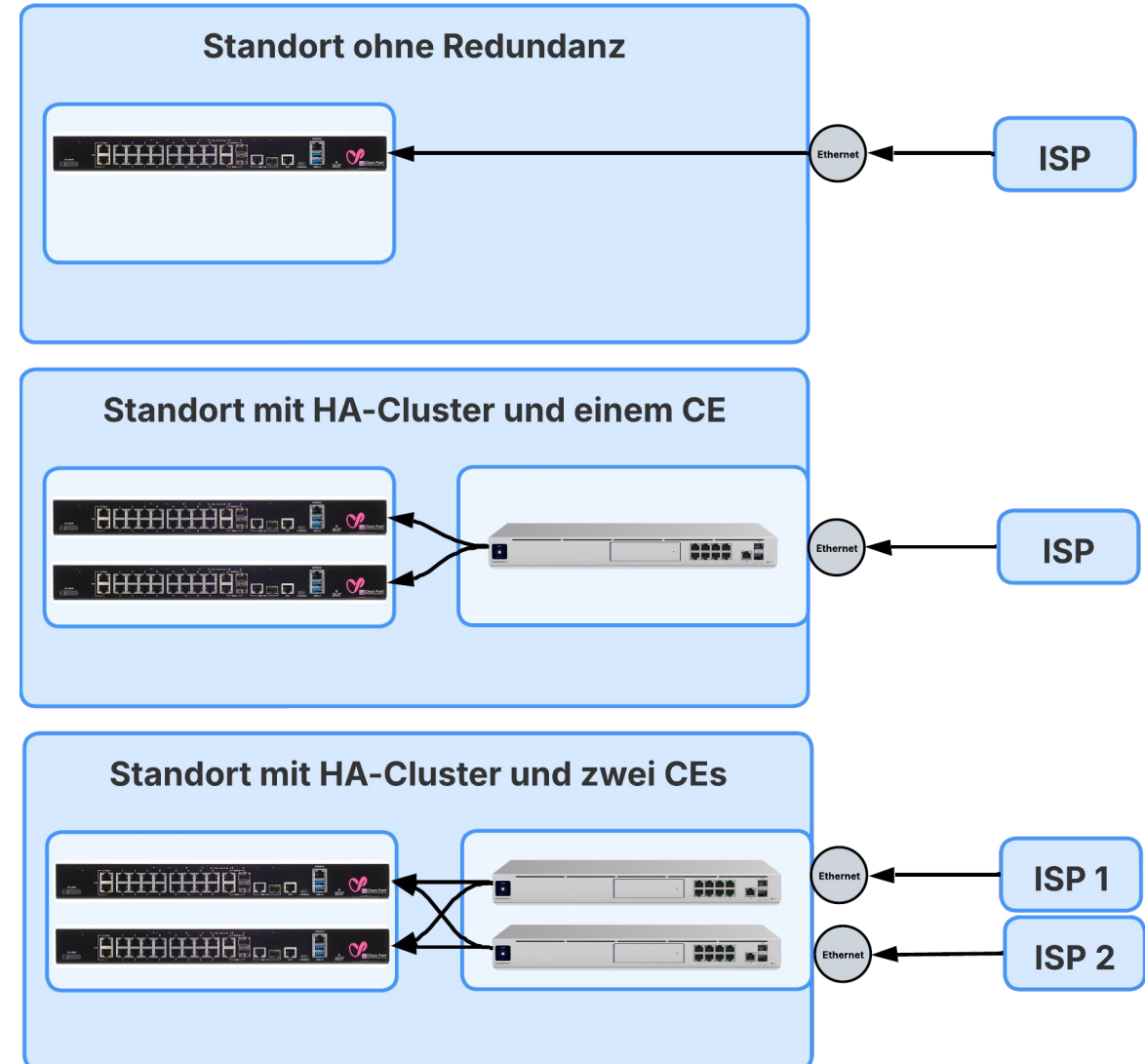
Carrier Ethernet wird als Produkt von ISPs angeboten, damit Unternehmen ihre Standorte anbinden können. Die Konfiguration erfolgt auf ISP-Seite. Es ist keine dedizierte Leitung, sondern wird im Backbone des ISPs verarbeitet (EoMPLS, Ethernet Switching) auf Layer 2.5 (mittels Labels). Der Kunde bekommt vom ISP aber einen Anschluss auf Ethernet-Basis geliefert.

- Mittlerweile De Facto Standard für klassische Standortvernetzung
- Kosten pro Anschluss je nach SLA und Bandbreite zwischen 600 - 6.000 CHF pro Standort pro Monat (1 Gbit/s ~ 1.500 CHF)
- Wird meistens via MPLS auf Provider Seite umgesetzt
- Wichtige Unterscheidung: Keine Leased-Line. Eine Leased-Line ist eine tatsächliche physische Vernetzung von 2 Standorten (Beispiel Dark Fiber) (Deutlich teurer, Preis hängt von Länge ab, üblicherweise innerhalb CH 4.000 bis 8.000 CHF pro Link).

Anbindung von Carrier Ethernet

Je nach Anforderungen an die Resilienz gibt es verschiedene Möglichkeiten den Standort mit CE anzubinden. Hier zu sehen drei Beispiele mit Perimeter, WAN-Switch und verschiedenen ISPs.

- Option 1 ist **kosteneffizient** bietet aber keine Sicherheit gegen Ausfälle von CE oder dem Perimeter
- Option 2 **erlaubt den Ausfall eines Perimeters**, aber nicht des WAN-Switches oder des ISPs
- Option 3 **erlaubt den Ausfall jeder einzelnen Komponente** (Perimeter, WAN-Switch & ISP). Sinnvollerweise würde man hier 2 CE's von verschiedenen ISPs nehmen, da die Redundanz ansonsten bei einem Backbone-Fehler des ISPs Wirkungslos ist.



Einschub: VRRP - Virtual Router Redundancy Protocol

Ziel:

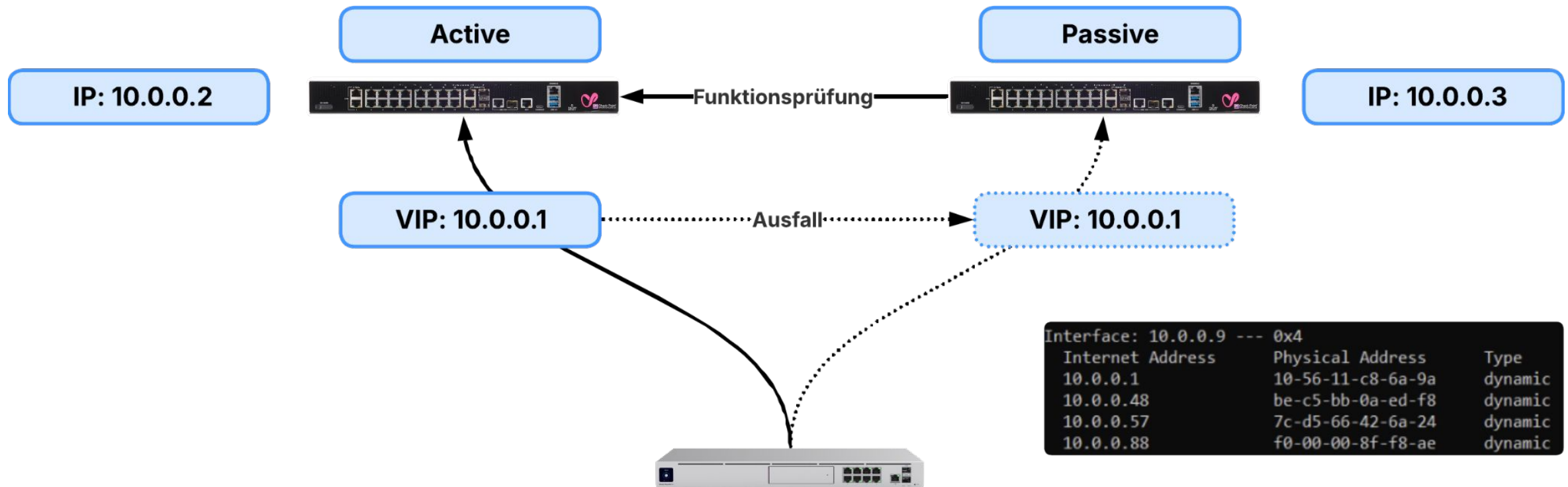
Sicherstellen, dass ein Netzwerk auch bei einem Routerausfall weiter funktioniert – ohne manuelle Eingriffe oder IP-Adressänderungen.

Funktionsweise:

- **Mehrere Gateways** bilden eine VRRP-Gruppe
- Einer davon wird als **Master** gewählt, die anderen sind **Backups**.
- Der Master ist für den Datenverkehr zuständig und besitzt die virtuelle IP-Adresse (**VIP**), die Clients als Gateway verwenden.
- Fällt der Master aus, übernimmt **automatisch** ein Backup-Router.
- Die Umschaltung erfolgt automatisch und transparent für die Endgeräte (via Gratuitous ARP).

Wie genau funktioniert VRRP?

- Nach feststellen des Ausfalls von GW1 sendet GW2 einen **Gratuitous ARP**.
- Die ARP-Table des Switches updated sich entsprechend und **routed die VIP zu GW2**.



WAN im OSI Model - Layer 3 - Network Layer

Stellt **primären** Layer der WAN Intelligenz dar (Perimeter, WAN-Edge). Layer 3 **Gateway** trifft Routing-Entscheidungen und terminiert öffentliche IP-Adressen des Standorts.

Layer 3 WAN Funktionen:

- **Terminierung von Public IP Adressen:** Für die Kommunikation ins Internet
- **Terminierung von Private IP Adressen:** Für die Kommunikation innerhalb des Standortes, zu anderen Standorten oder Partnern
- **NAT/PAT:** Network Address Translation ins Internet, zu Standorten oder Partnern
- **Default Gateway:** Meist das DG für alle Netze am Standort

Verwendete Routing-Protokolle am WAN Edge:

- **Static Routing:** Manuelle Konfiguration, statisch
- **Dynamic Routing:**
 - **OSPF:** Interior Gateway Protocol
 - **EIGRP:** Cisco Proprietär
 - **BGP:** Border Gateway Protocol

Layer 3 Geräte:

- **Router:** Primary WAN edge device, makes forwarding decisions
- **Firewalls:** Zur Segmentierung von Netzen und Schutz von aussen
- **Switches:** Zur terminierung von ISPs oder anderen Switchen

Für was braucht man überhaupt public IPs?



Routing Protokolle im WAN

Routing-Protokolle ermöglichen es Routern, automatisch verschiedene Netzwerkpfade zu erkennen und anhand definierter Metriken den optimalen Weg für den Datenverkehr zu wählen. Dadurch erhöhen sie die Effizienz, Ausfallsicherheit und Skalierbarkeit eines WANs.

Protokoll	Typ	Metrik	Konvergenz	Skalierbarkeit	Typischer Einsatz
Statisch	Manuell (kein dynamisches Routing)	Keine	Keine	Schwach	Kleine oder lokale Netze, Backup-Routen
OSPF	Link-State (IGP)	Kosten (Bandbreite)	Schnell (Sekunden)	Gut	Internes Routing an Campus-Netzen
EIGRP	Hybrid (IGP, Cisco-proprietär)	Bandbreite + Verzögerung + Last + Zuverlässigkeit	Sehr schnell (< 1 s)	Gut	Cisco-basierte WAN-Umgebungen
BGP	Path-Vector (EGP)	Richtlinienbasiert (mehrere Attribute: AS-Path, etc.)	Langsam (Sekunden – Minuten)	Sehr gut	Internet-Edge, Multi-ISP-Routing, Cloud- und SD-WAN-Peering

Verstehen des Perimeter Ansatzes

Der **Perimeter** ist die Grenze zwischen internen und externen Netzwerken. Historisch stellt er oft den Übergang von “Trusted” zu “Untrusted” dar. **Standorte von Perimetern:**

1. Unternehmensstandorte und Datacenter:

- Ist das Default Gateway für alle Netze am Standort
- Fast immer mit Firewall-Funktionen, um Filterung von Netzwerken zu ermöglichen
- Terminiert ggf. einen Internet-Anschluss (ISP)

2. Cloud:

- Verbindungspunkt zu Public Clouds (AWS, Azure, Google Cloud)
- Kann virtuell (VM) oder physisch umgesetzt sein (Direct Connect, ExpressRoute)

3. Enduser Geräte:

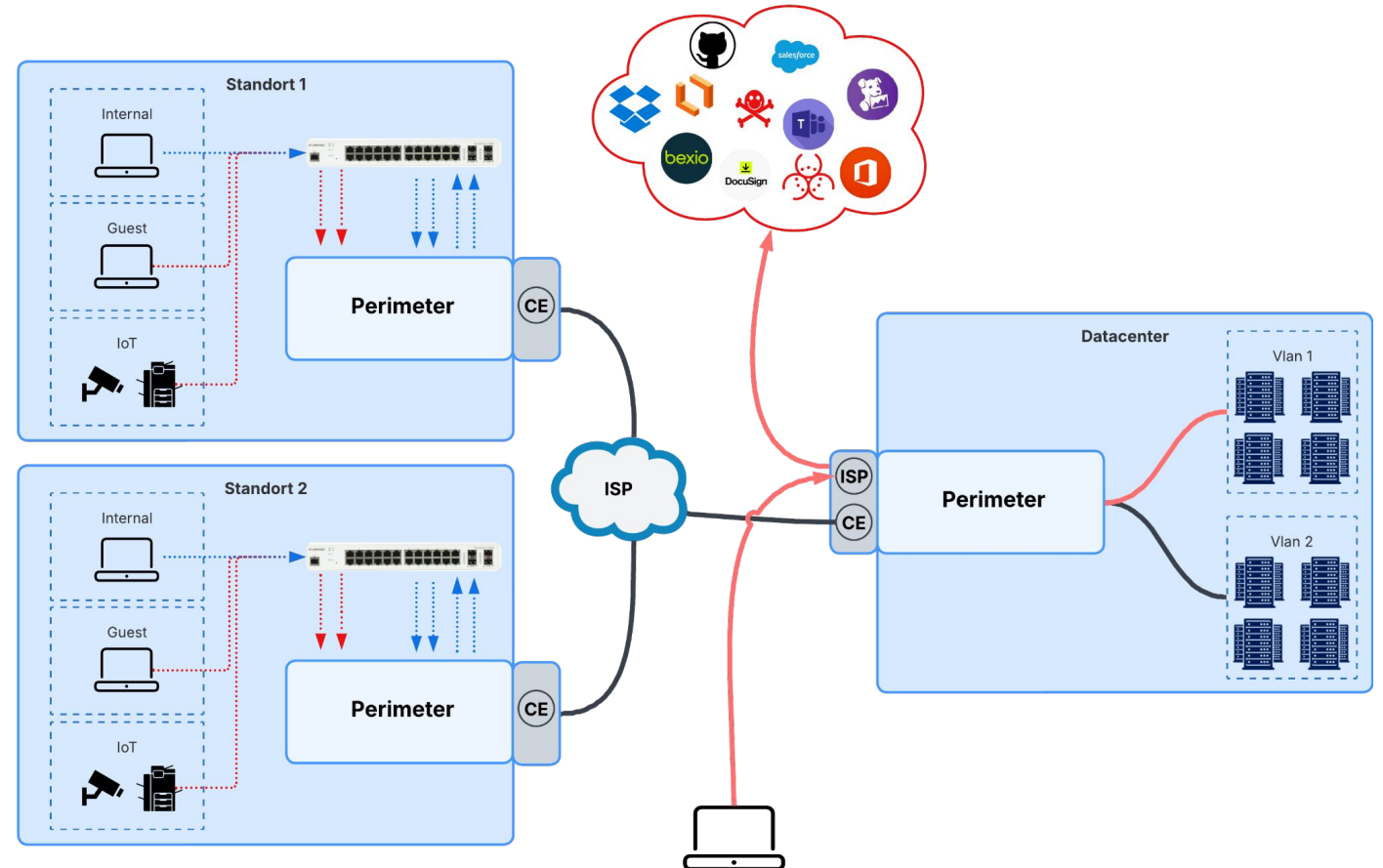
- Logisch, fast immer per Software (VPN, ZTNA)
- Software Komponente die Benutzern das Arbeiten ausserhalb des Netzwerks erlaubt

4. OT Umgebungen:

- Speziell für produzierende Industrie.
- Verbindet OT-Netze mit IT-Netzen

Beispiel für einen Perimeter

- Hier zu sehen ein klassisches Unternehmensnetzwerk mit verschiedenen Standorten die über Carrier Ethernet (E-LAN) miteinander vernetzt wurden.
- Alle Standorte können direkt miteinander kommunizieren.
- Remote User verbinden sich via VPN ins Datacenter und gelangen so zu internen Ressourcen.
- Internet-Traffic wird zentral über das DC geroutet und bricht dort lokal über einen zweiten ISP aus.



Weitere Funktionen im Perimeter-Umfeld

Der Perimeter hat in Netzwerken oft eine zentrale Rolle. Ausserhalb der Standortvernetzung übernimmt er üblicherweise noch andere Funktionen, bzw. hat direkt an ihn angebundene Systeme die diese Aufgaben übernehmen.

- Firewalling
- Routing
- Zonierung
- Traffic Shaping
- QOS
- NAT
- VPN-Terminierung
- Reverse Proxy
- Load Balancing
- IDS/IPS
- Proxy
- DDI (DNS, DHCP, IPAM)
- Mail-Gateway
- NAC

Perimeter - Firewalling

Üblicherweise haben Standorte hinter Perimetern ein LAN in dem Hosts sitzen. Clients, Server, IoT & OT. Da der Perimeter eigentlich immer das Default Gateway ist, werden hier auch zentral die verschiedenen Netze terminiert und auf Layer-4 gefiltert.

So darf das Gäste-WiFi nicht zu den internen Servern, die IoT nicht zu den Clients aber die Clients zur IoT und so weiter.

Source	Destination						
	All Policies (61)	Internal	External	Gateway	VPN	Hotspot	DMZ
	Internal	Allow All	Allow All (2)	Allow All (2)	Allow All	Allow All	Allow All
	External	Allow Return (3)	Allow Return (3)	Allow Return (6)	Allow Return (3)	Allow Return (3)	Allow Return (3)
	Gateway	Allow All	Allow All	-	Allow All	Allow All	Allow All
	VPN	Allow All	Allow All (2)	Allow All	Allow All	Allow All	Allow All
	Hotspot	Allow Return	Allow All (2)	Allow Return	Allow Return	Block All	Block All
	DMZ	Allow Return	Allow All (2)	Allow Return	Allow Return	Block All	Block All

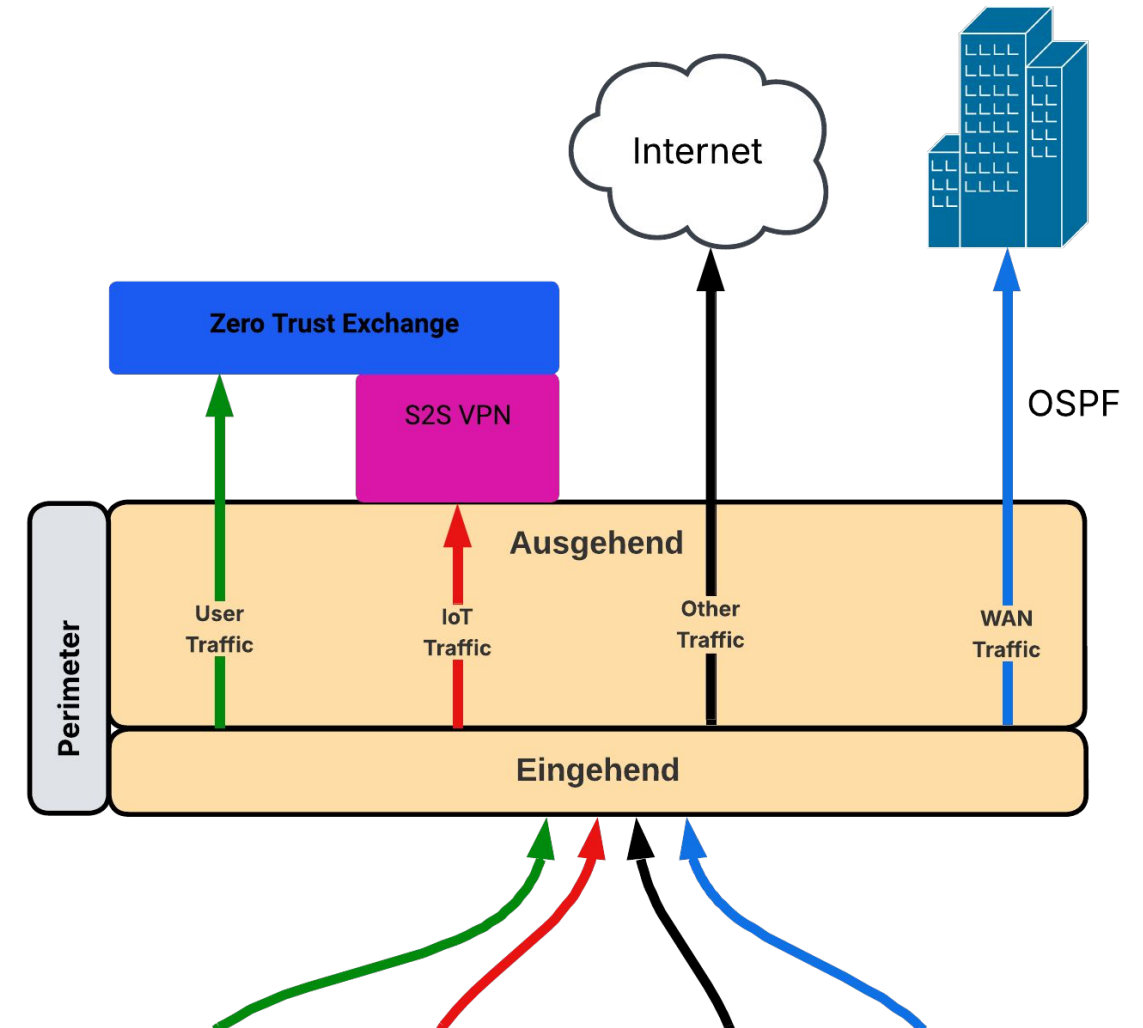
Perimeter - Routing

Der Perimeter übernimmt weiterhin zentrale Routing Aufgaben.

Sowohl innerhalb des Standortes (von einem Netz in das andere) als auch zwischen Standorten (via WAN) oder zu Partnern (Site 2 Site VPNs) und ins Internet.

Im Standard geschieht dies statisch. Für höhere Ansprüche an Resilienz und effizienz aber auch dynamisch.

Dabei kommen Protokolle wie BGP, OSPF oder auch policy based routing Funktionen zum Einsatz.



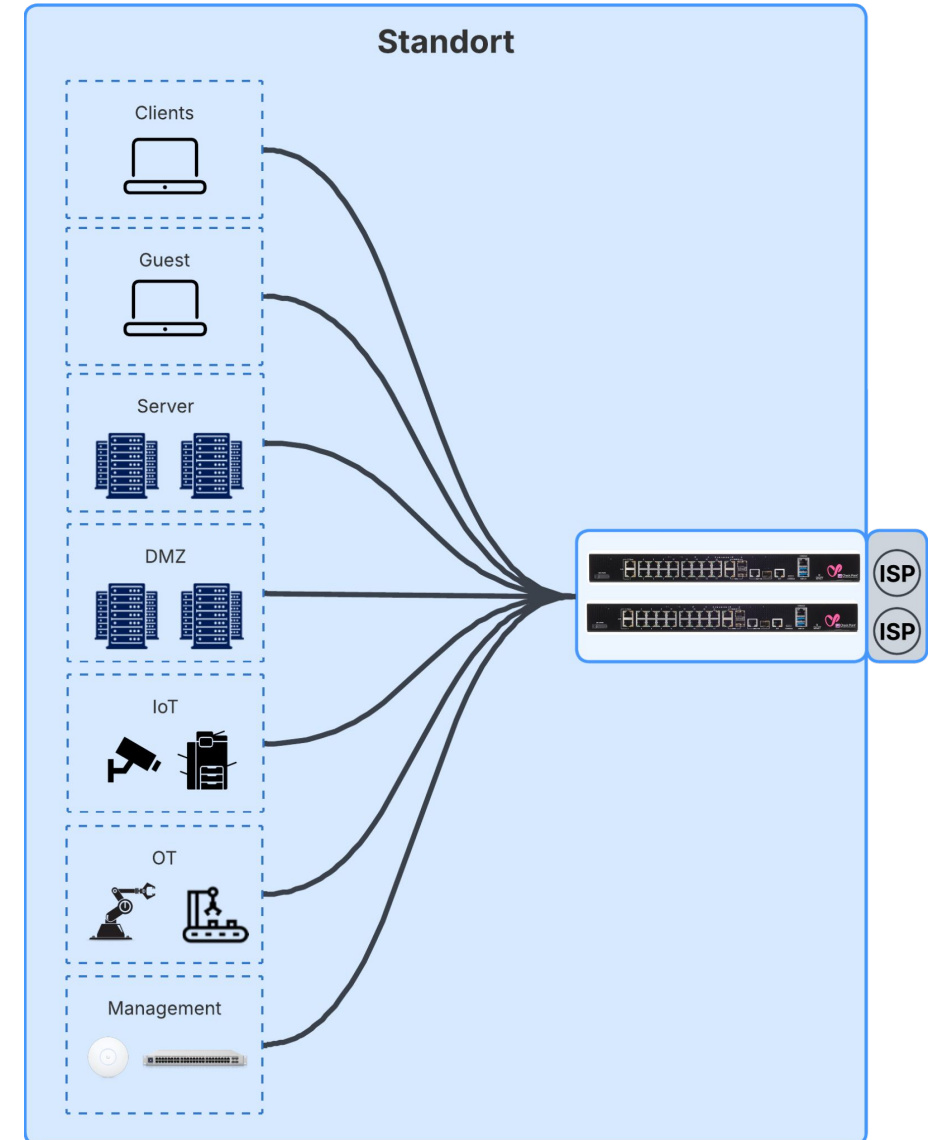
Perimeter - Zonierung

Da der Perimeter alle Netzübergreifenden Anfragen aufnimmt, ist er auch der Beste Ort um mit Hilfe der Firewall für Zonierung der Netze zu sorgen.

Netze können dabei auch über mehrere Standorte hinweg “gestretched” werden. Je nach Implementierung auf Layer-2 oder Layer-3.

Insgesamt lassen sich folgende Netze häufig als Zonen auf Perimetern finden:

- Clients
- Guests
- Server
- DMZ
- IoT
- OT
- Management



Welche Infrastruktur Komponenten im Netzwerk kennt ihr?

<https://www.menti.com/>

Code:

5747 0628



Zeichnung einer Beispiel Infrastruktur für ein Unternehmen

Eckdaten:

- 300 Benutzer auf 3 Standorte verteilt
- 30 Maschinen und DC mit 30 VMs an einem Standort
- Die anderen Standorte haben nur User & IoT
- Public Cloud (AWS) im Einsatz für 10 VMs
- Wollen Web-Zugriffe filtern
- Brauchen Remote-Access für Benutzer

2. Traditionelle WAN Architekturen

Herausforderungen traditioneller WAN-Architekturen

1. Cloud-Einbindung

- Anwendungen wandern aus dem Rechenzentrum in die Cloud (SaaS)
- Nutzung von [I,P]aaS-Plattformen (AWS, Azure, Google Cloud)
- Klassische WAN-Architekturen sind nicht für Cloud-Zugriffe optimiert und erhöhen die Latenz

2. Mobile Belegschaft

- Zunahme von Remote Work und Homeoffice
- BYOD („Bring Your Own Device“) erhöht Komplexität und Sicherheitsrisiken
- Erwartung von nahtlosem Zugriff auf Unternehmensressourcen von überall

Herausforderungen traditioneller WAN-Architekturen

3. Steigender Bandbreitenbedarf

- Videokonferenzen als primäre Kommunikationsform
- 4K-Streaming und grosse Datenströme belasten Leitungen
- Zentrale Internet-Breakouts führen zu Engpässen

4. Komplexität & Skalierbarkeit

- Microservices-Architekturen und containerisierte Workloads
- Loadbalancing von Grossen Anwendungsumgebungen
- Hybride Umgebungen mit vielen Datacentern und Clouds schwer umsetzbar

Herausforderungen traditioneller WAN-Architekturen

5. Sicherheitsbedrohungen

- Zunehmend gezielte Angriffe (Ransomware, APTs)
- Erweiterte Angriffsflächen durch Cloud, mobile Endgeräte und IoT
- Strengere Compliance-Vorgaben (z. B. DSGVO, HIPAA, SOX)

6. Kosten

- Dedizierte WAN Anbindungen sind mit hohen Kosten verbunden
- Unternehmen sind einem kontinuierlichen Kostendruck ausgesetzt

Herausforderungen traditioneller WAN-Architekturen



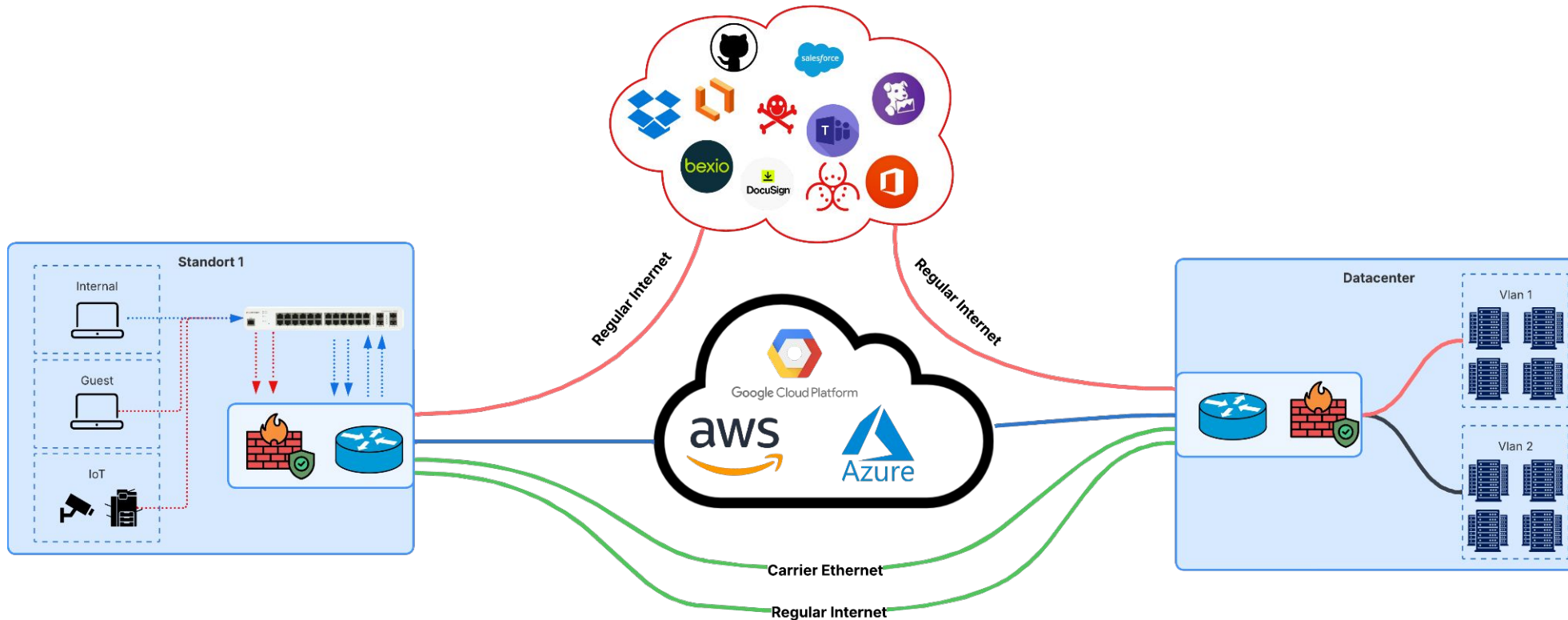
Schlussfolgerung

- Es braucht neue Ansätze die sich der veränderten Applikations und Nutzer Landschaft anpassen
- Das Netzwerk existiert nicht mehr Parallel zur Sicherheit sondern verschmilzt mit dieser.

3. SD-WAN

Was ist SD-WAN?

SD-WAN (Software-Defined Wide Area Network) ist eine softwaregesteuerte Netzwerktechnologie, die es Unternehmen ermöglicht Unternehmen, mehrere Verbindungen (MPLS, Breitband, LTE/5G) parallel zu nutzen und den Datenverkehr gemäss Richtlinien und Anwendungsanforderungen intelligent zu steuern.

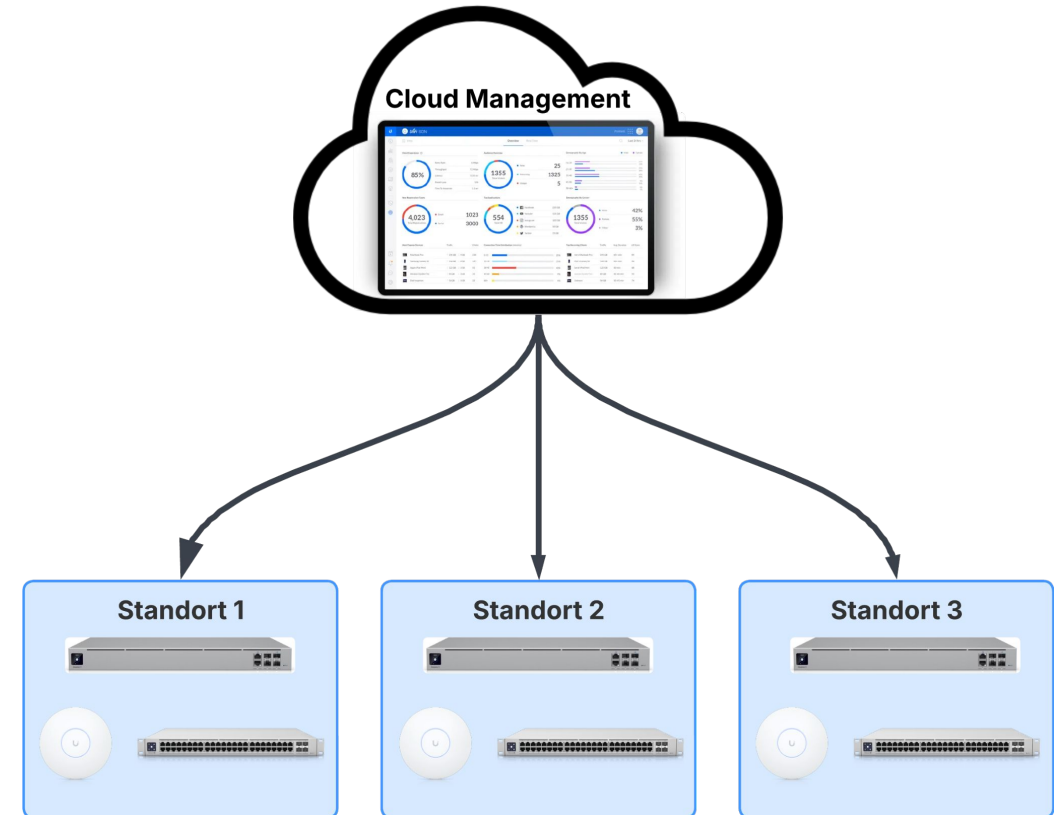


Kernfunktionen von SD-WAN

- **Zentrale Orchestrierung und Verwaltung:** Verwaltung aller Standorte, Richtlinien und Verbindungen über eine zentrale Management-Plattform. Änderungen werden automatisch ausgerollt.
- **Dynamische Pfadwahl:** Permanente Analyse aller Leitungen (Latenz, Jitter, Paketverlust) und automatische Nutzung des besten Pfads pro Anwendung.
- **Policy-Based Routing:** Datenverkehr wird anhand von Anwendungsregeln gesteuert – z. B. Priorisierung von VoIP oder kritischen Cloud-Diensten.
- **Traffic Priorisierung (QoS & Policies):** Qualitätssicherung durch Priorisierung geschäftskritischer Anwendungen und Bandbreitensteuerung.
- **Sicherheitsintegration:** Terminierung User-VPNs, lokales Firewalling, Web-Proxy, Web Application Firewall, etc.
- **Multi-Link-Unterstützung:** Gleichzeitige Nutzung verschiedener Transportmedien (Internet, MPLS, LTE/5G) für Redundanz und Kostenoptimierung.
- **Cloud-Optimierung:** Direkte, performante Anbindung an SaaS- und IaaS-Plattformen ohne Backhauling über das Rechenzentrum.
- **Visibility & Analytics:** Zentrales Echtzeit-Monitoring von Anwendungen, Verbindungen und Standorten mit Analyse- und Reportingfunktionen.

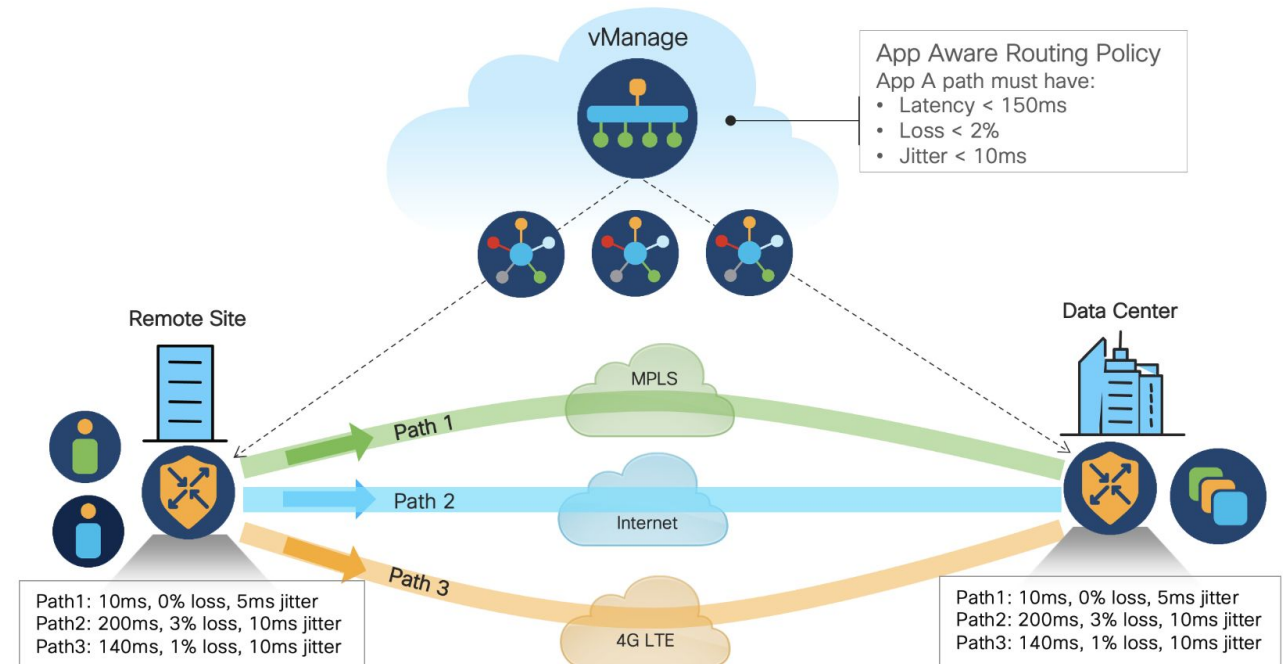
Zentrale Orchestrierung und Verwaltung

- Zentrale Stelle für **Policies** (Routing, QoS, Security)
- Zero Touch **Provisioning**: Einfache Aufnahme und Konfiguration weiterer Gateways ohne manuelle Konfiguration
- **Intent- und Template-basiert** statt einzelner CLI-Konfigurationen für konsistente Standorte
- **Zentrale Routing- und Netz-Definition**
- **Echtzeit-Monitoring**, Dashboards für Verfügbarkeit, ISP-Monitoring, Threat-Detection
- **Zentrale Updates** für konsistente Patch-Stände
- Zentralisierte **Authentifizierung** via RBAC und iDP
- **API- und Automation-Integration** für IaC und ITSM



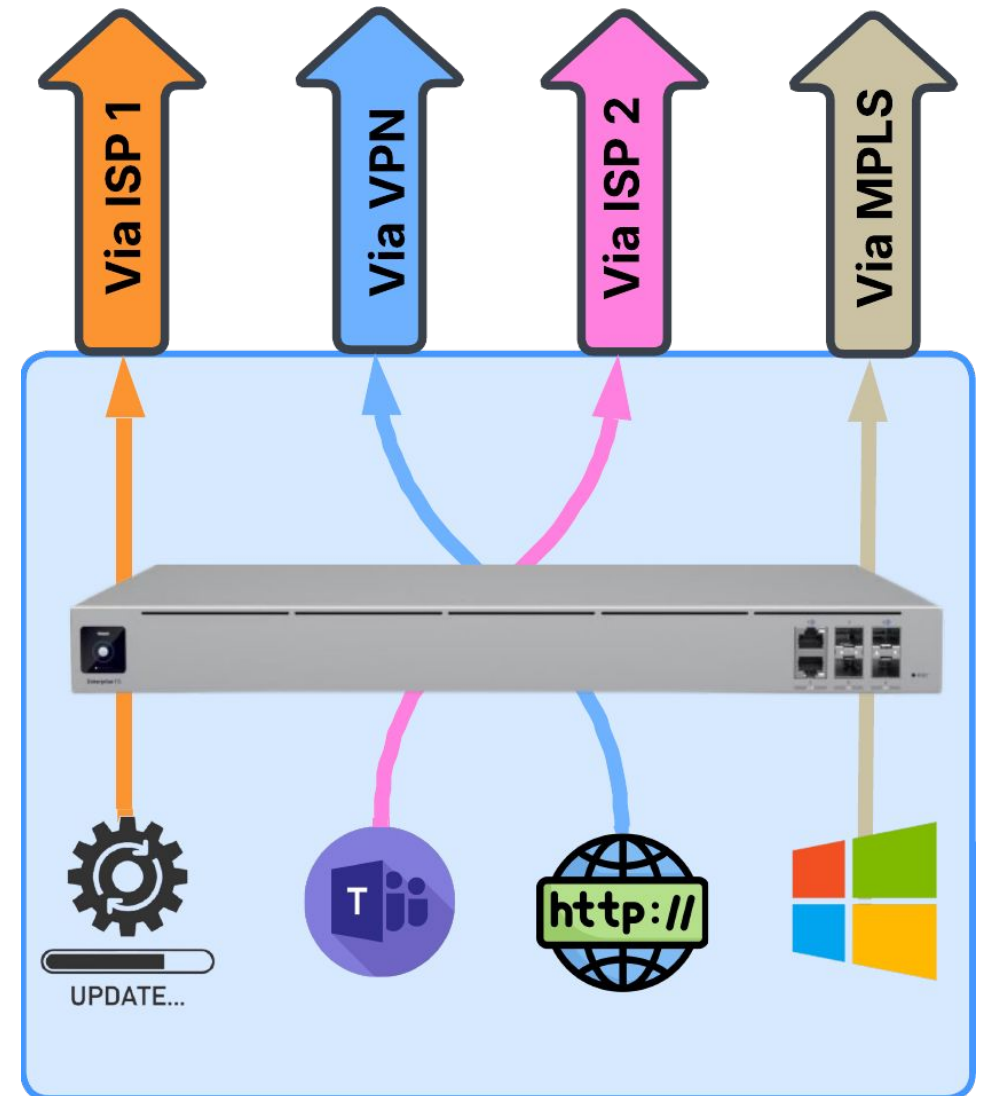
Dynamische Pfadwahl

- SD-WAN **analysiert** permanent alle verfügbaren Leitungen (Latenz, Jitter, Paketverlust, Auslastung).
- Der Datenverkehr wird in Echtzeit über den Pfad mit der besten **Performance** pro Anwendung geleitet.
- App-Aware Routing: Jede Anwendung hat eigene **SLA-Vorgaben** (z. B. VoIP < 150 ms Latenz, < 2 % Loss).
- Bei Qualitätsverlust erfolgt **automatischer Wechsel** auf den nächstbesten Link – ohne Unterbruch.
- Mehrere Leitungen (MPLS, Internet, LTE/5G) können **parallel genutzt** und intelligent kombiniert werden.
- **Ziel: Optimale Performance, Ausfallsicherheit und effiziente Bandbreitennutzung**



Policy Based Routing

- **Routing nach Regeln** statt nach Ziel-IP: Entscheidungen basieren auf Anwendung, Benutzer, Quelle, Zeit oder Dienst.
- **Flexible Steuerung** des Traffics: Unterschiedliche Pfade (z. B. ISP1, ISP2, MPLS, VPN) je nach Policy mit overlays und Priorisierungen.
- **Application-Identification** anhand IPs, Domains und Protokollen
- Beispiel:
 - Microsoft Teams: Über ISP2 (niedriger Latenz)
 - Software-Updates: Über ISP1 (kostengünstig)
 - Web-Traffic: Über VPN (Zu transparentem Cloud Proxy)
- **Messung der Leitungsqualität** (Latenz, Jitter, Loss) in Echtzeit und dynamisches re-routing.
- **Ziel: Richtiger Pfad für die richtige Anwendung** – Performance, Sicherheit und Kostenoptimierung.



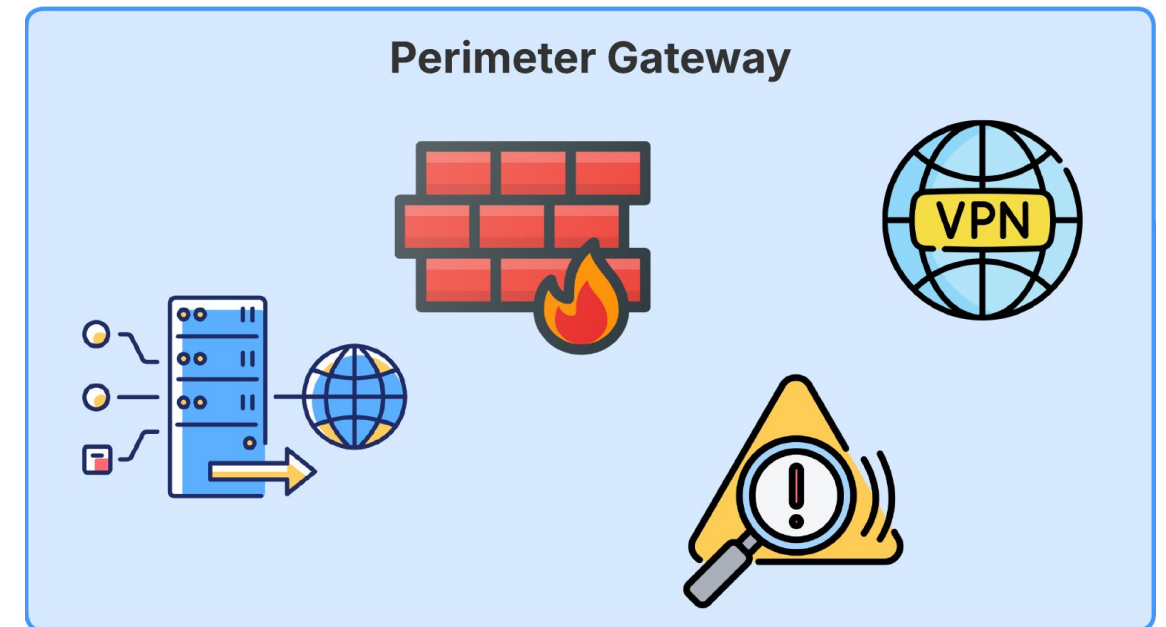
Traffic Priorisierung

- Ziel: **Sicherstellung der Performance** geschäftskritischer Anwendungen bei begrenzter Bandbreite.
- Prinzip: Datenverkehr wird **in Klassen unterteilt** (z. B. kritisch, VoIP, Best Effort) und nach Priorität behandelt.
- Mechanismus:
 - QoS-Policies definieren Mindest- und Maximalbandbreiten pro Klasse.
 - Wichtige Anwendungen (z. B. ERP, Teams, VoIP) erhalten bevorzugte Behandlung bei Engpässen.
 - Nicht-kritische Anwendungen (z. B. Updates, Downloads) werden nachrangig bedient.
- Automatisierung: SD-WAN **analysiert Traffic in Echtzeit** und passt Priorisierung dynamisch an.
- Ergebnis: Stabile Sprach- und Videoqualität, gleichbleibende Performance kritischer Business-Apps.



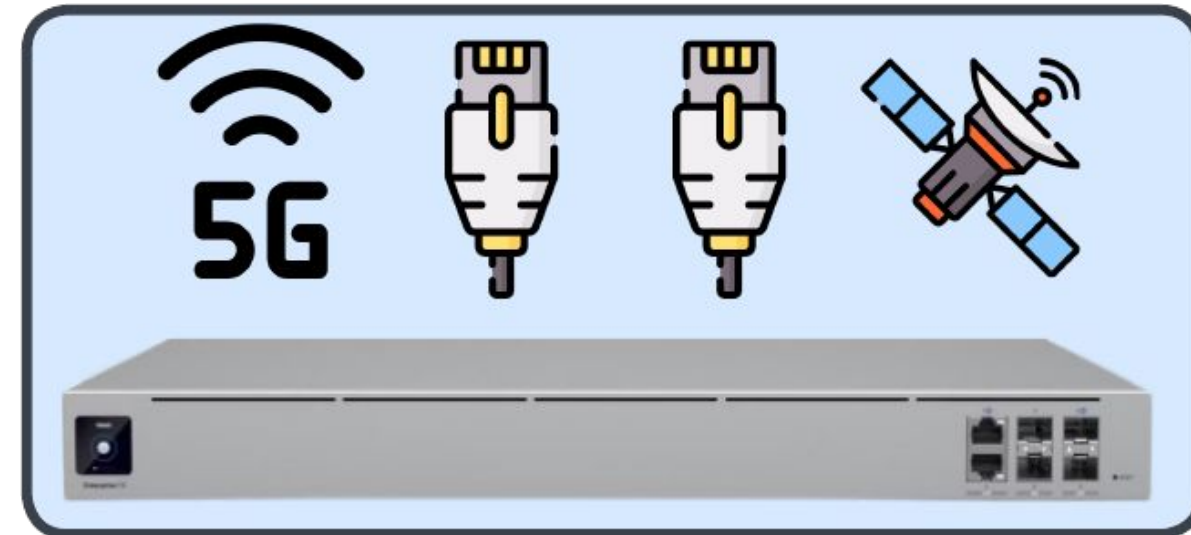
Sicherheitsintegration

- **Security-Edge am Standort:** Das SD-WAN-Gateway ist zugleich Netzwerkknoten und Sicherheitskomponente.
- **User- und Site-VPN-Terminierung:** Aufbau und Verwaltung sicherer Tunnel zwischen Standorten oder zu Remote-Usern.
- **Firewall:** Stateful Inspection, Application Control, Intrusion Detection/Prevention (IDS/IPS) und Web-Filtering integriert.
- Lokale Dienste: DHCP, **DNS (Security)** und NTP müssen im Netz angeboten werden.
- **Segmentierung:** Trennung von internen, IoT- und Gast-Netzen direkt am Standort-Edge.



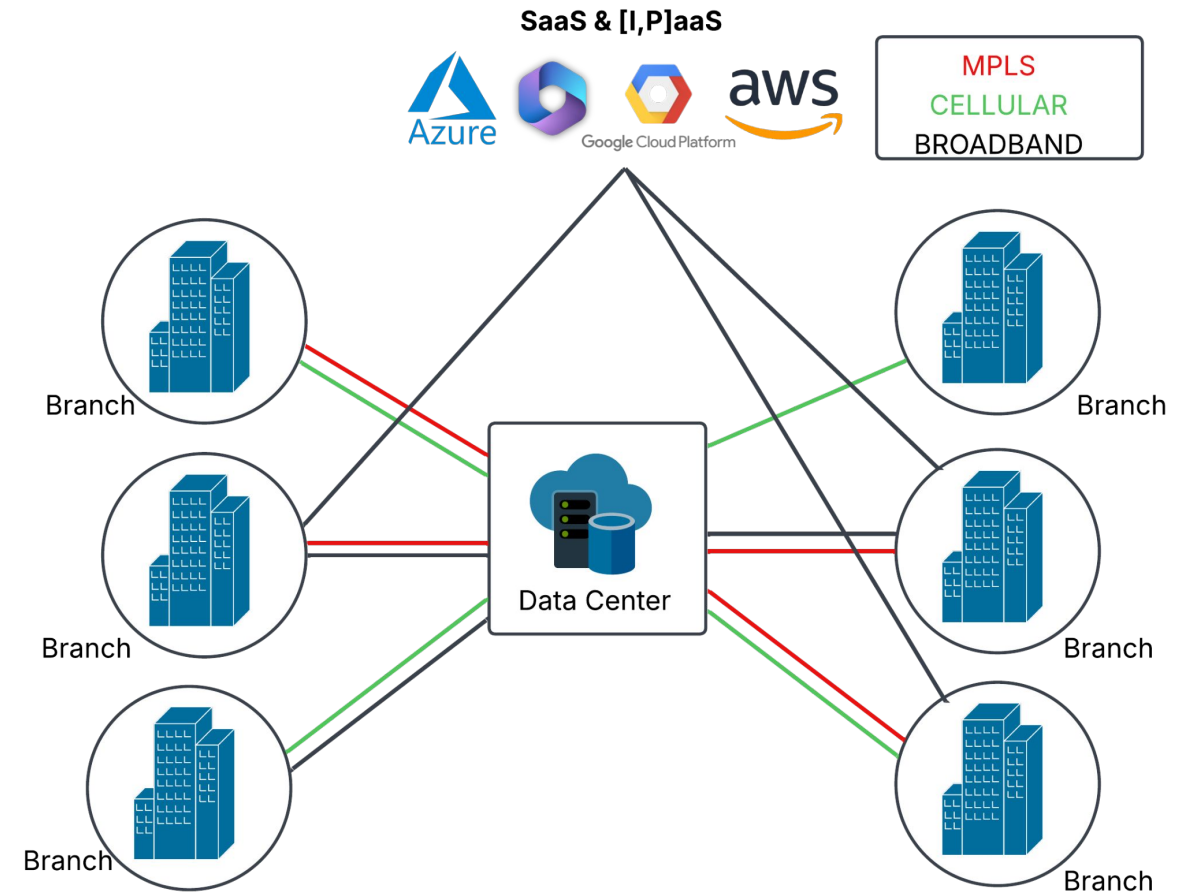
Multi-Link-Unterstützung

- **Ziel: Hohe Verfügbarkeit, Performance und Kostenoptimierung** durch gleichzeitige Nutzung mehrerer Verbindungen.
- Verschiedene Medien: **Kombination** aus Internet, 5G und Satellit für parallelen Betrieb.
- **Automatische Pfadwahl:** SD-WAN misst kontinuierlich Latenz, Jitter und Paketverlust und wählt pro Anwendung den besten Pfad.
- **Lastverteilung & Redundanz:** Traffic kann aktiv über mehrere Leitungen verteilt oder bei Ausfall sofort umgeleitet werden (Failover <1 s).
- **Kostenoptimierung:** Günstige Internet-Links kompensieren teure MPLS-Strecken, ohne Einbussen bei Verfügbarkeit.
- Nutzungsszenarien:
 - Primär: MPLS + Internet für kosteneffiziente Redundanz
 - Backup: 5G als Fallback für kleine Standorte



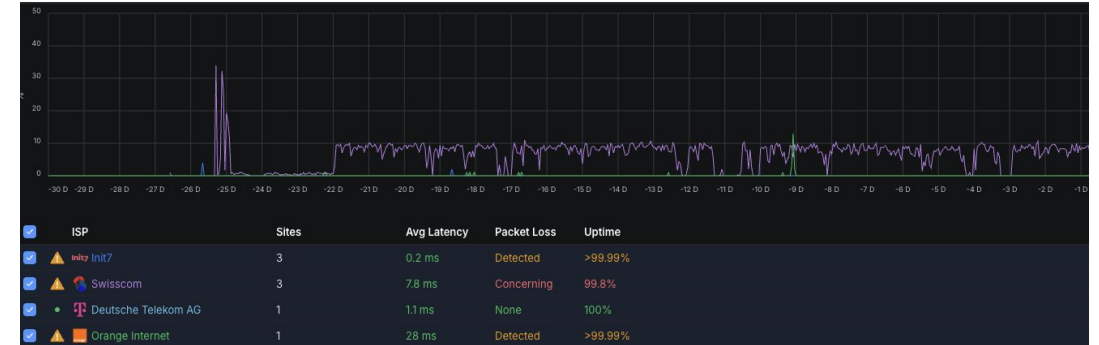
Cloud Optimierung

- **Ziel:** Hohe Performance und niedrige Latenz für Cloud-Anwendungen durch direkte Verbindung zu SaaS- und IaaS-Services.
- **Traditionell:** Traffic floss über das Unternehmensrechenzentrum („Backhauling“) → erhöhte Latenz, Engpässe und Kosten.
- **Mit SD-WAN:** Direkter Local Breakout zu Cloud-Diensten (z. B. Microsoft 365, Salesforce, AWS, Azure, Google Cloud).
- **Intelligente Pfadwahl:** SD-WAN erkennt Cloud-Anwendungen automatisch und wählt den optimalen Zugangspunkt (PoP, Region, Peering).
- **Cloud-Integration:** Native Anbindung an Cloud-Gateways oder virtuelle SD-WAN-Edges in IaaS-Umgebungen.
- **Ergebnis:** Schnellerer Zugriff, stabilere Cloud-Performance und geringere Rechenzentrumsbelastung.



Visibilität und Analytics

- **Ziel:** Vollständige Transparenz über alle Standorte, Verbindungen und Anwendungen – in Echtzeit.
- **Zentrale Übersicht:** Alle SD-WAN-Gateways melden kontinuierlich Status-, Update-Stand, Traffic- und Performance-Daten an den Controller.
- **Echtzeit-Monitoring:** Visualisierung von Latenz, Jitter, Paketverlust, Bandbreitenauslastung und SLA-Compliance.
- **Application Visibility:** Identifikation von Top-Anwendungen, Nutzungsprofilen und potenziellen Engpässen.
- **Analytics & Reporting:** Automatische Trendanalysen, Anomalieerkennung und SLA-Reports für Betrieb und Management.
- **Proaktive Optimierung:** Daten dienen als Grundlage für Policy-Anpassungen, Kapazitätsplanung und Troubleshooting.



Wie SD-WAN funktioniert

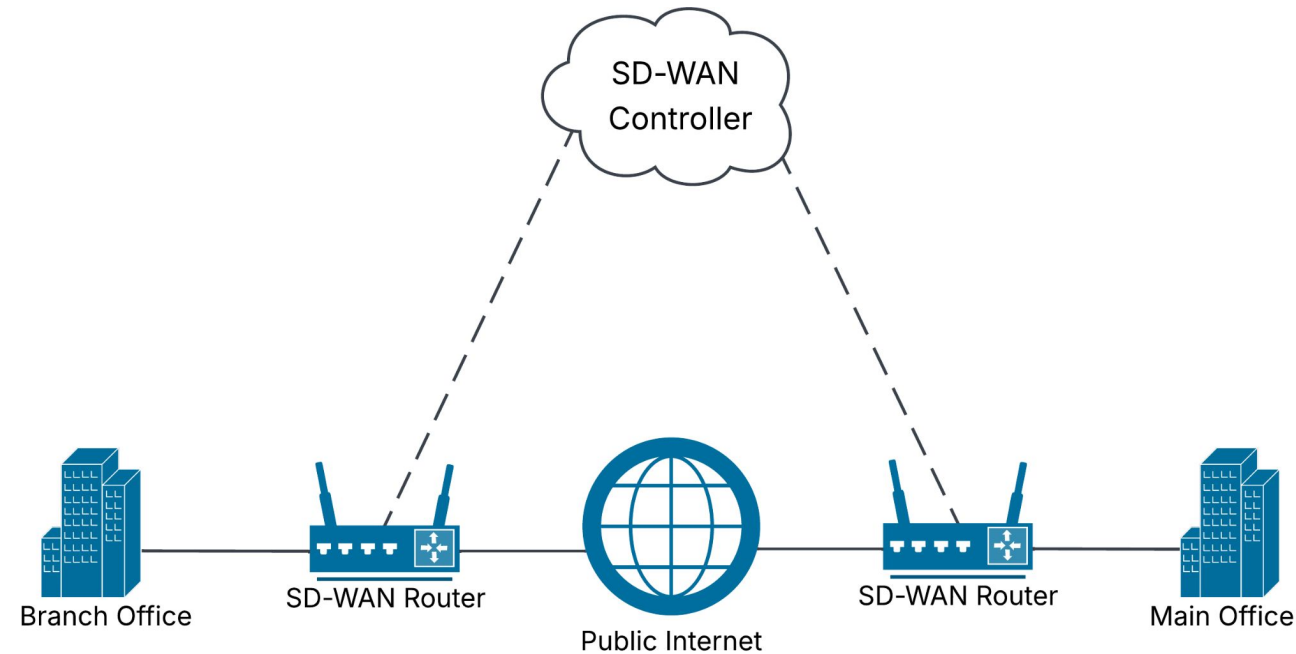
SD-WAN abstrahiert physische WAN-Verbindungen zu einer **virtualisierten Overlay-Struktur**.

Dadurch kann die IT zentral steuern, welche Richtlinien gelten und wie der Datenverkehr über die verschiedenen Verbindungen fließt.

Eine zentrale Komponente ist der **SD-WAN-Controller**:

- verteilt Richtlinien an alle Standorte
- steuert Datenflüsse dynamisch je nach Zustand und Anwendung
- bietet ein zentrales Monitoring Dashboard

Die Overlay-Architektur ermöglicht es, mehrere Verbindungstypen – MPLS, Breitband, LTE/5G zu kombinieren und den Datenverkehr entsprechend geschäftlicher Prioritäten zu lenken.



SD-WAN Architecture

SD-WAN Architecture

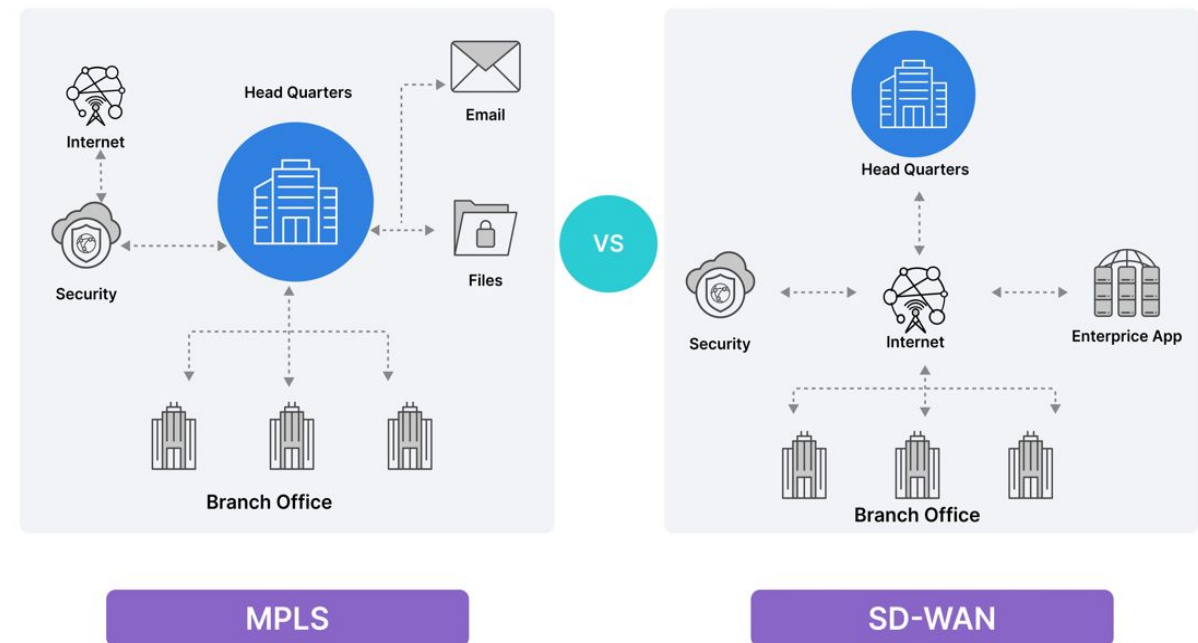
- Uses multiple links (e.g., broadband, MPLS) for intelligent, application-aware routing
- Enhances performance for critical apps and ensures consistent user experience
- Integrates security functions like firewalls and secure web gateways
- Simplifies centralized management and scales easily across locations
- Delivers efficiency, flexibility, and cost savings for modern enterprises

SD-WAN vs. Traditionelle WANs

Aspect	Traditional	SD-WAN
Steuerung	Manuell, pro Gerät	Zentralisiert, automatisiert
Transport	MPLS-zentriert, ein Anbieter	Multi-Transport (MPLS + Internet + LTE/5G)
Konfiguration	Manuell, CLI auf jedem Gerät	Zentral, GUI-basiert
Routing	Statisch, IP-basiert	Dynamisch, anwendungsbasiert
Bereitstellung	Wochen/Monate	Tage
Management	Komplex, pro Gerät	Einheitliche Oberfläche („Single Pane of Glass“)
Kosten	Hoch (MPLS)	Geringer (Internet + Fallback)
Sicherheit	Separate Geräte	Integrierte Sicherheit

SD-WAN vs. Traditionelle WANs

- **Kosten & Flexibilität:** MPLS ist teuer und unflexibel. SD-WAN senkt die Kosten, indem es WANs mit Breitband- oder 5G-Verbindungen kompensiert.
- **Traffic-Management:** WANs bieten garantierte QoS, SD-WAN kompensiert dies durch dynamische Pfadwahl und anwendungsbasiertes Routing in Echtzeit.
- **Skalierbarkeit:** Die Erweiterung von WANs erfordert den Carrier, SD-WAN ermöglicht schnelle, softwarebasierte Rollouts und einfache Standorterweiterungen mit normalen Internet Anschlüssen.
- **Cloud-Fähigkeit:** WANs leiten den Traffic zurück ins Rechenzentrum, SD-WAN optimiert die direkte, performante Anbindung an Cloud-Dienste.
- **Sicherheitsintegration:** SD-WAN integriert zunehmend Sicherheitsfunktionen, während WANs auf separate Sicherheitslösungen angewiesen ist.



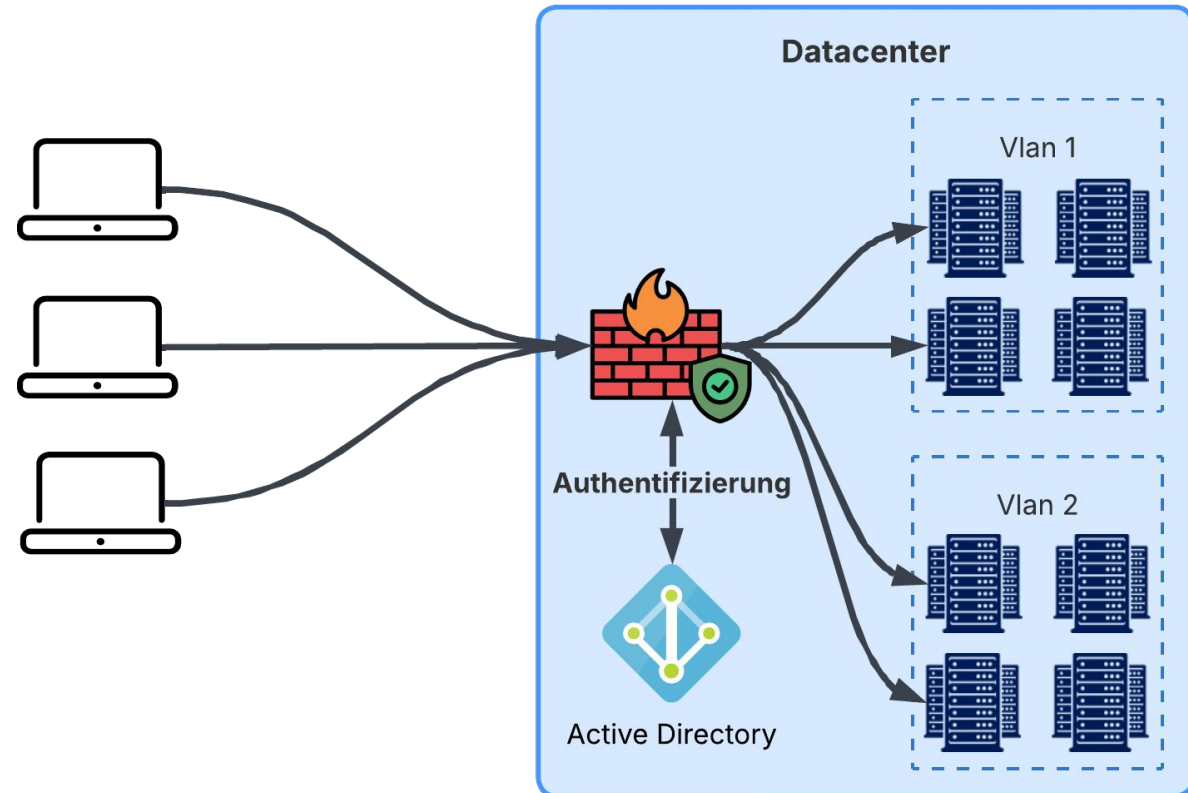
Security Service Edge (SSE)

1. Transition zu SSE
2. SSE Architektur
3. SSE Dienste & Features

1. Transition zu SSE

Klassische Remote Access Lösungen: VPN

- Wird meist als Agent auf den Endgeräten installiert und stellt über ein VTI (Virtual Tunnel Interface) eine Verbindung ins Datacenter her.
- Üblicherweise terminiert direkt auf dem Perimeter (Firewall) oder einem dedizierten VPN-Gateway.
- Authentifizierung erfolgt meist gegen das lokale Active Directory.
- Auf der Firewall muss dafür inbound ein Port geöffnet werden.
- Das Gerät erhält auf seinem VTI eine interne IP-Adresse und befindet sich damit logisch im internen Netzwerk und kann somit alle internen Ziele erreichen (Voraussetzung: Routing)
- Web Traffic wird über den VPN zum DC und dort über einen lokalen Proxy geroutet der die Filterung übernimmt



Klassische Remote Access Lösungen: VPN

Vorteile:

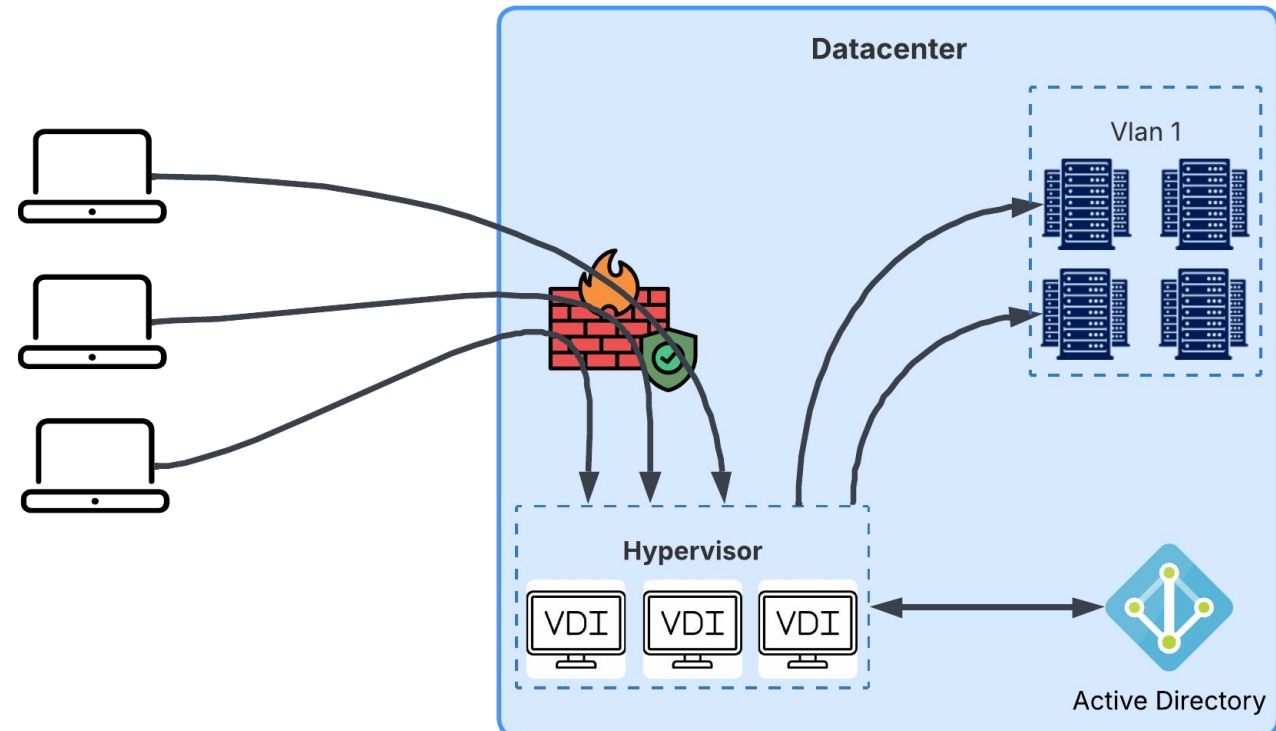
- Extrem günstig.
- Universeller Zugriff auf interne Systeme (legacy-Apps, VOIP, etc)
- Geringe OPEX, weil keine Filterung
- Unabhängig von Cloud-Diensten

Nachteile:

- Segmentierung äusserst statisch und aufwendig
- Keine “built in” Sicherheit (Inspection, Sandboxing, Segmentierung, Kontext-Evaluation, etc.)
- Erfordert einen separaten Proxy (im DC)
- Schlechte Skalierbarkeit
- Hohe Latenz für Internetzugriffe und Zugriffe auf andere Standorte (Backhauling)
- Geringe Transparenz (wer greift wie auf welche Ressourcen zu?)
- Erfordert das Exponieren eines Ports nach aussen

Klassische Remote Access Lösungen: VDI

- Benutzer Verbinden über den Browser auf eine virtuelle Desktop-Infrastruktur.
- Authentifizierung gegen das Active Directory
- Unterstützt den BYOD (bring your own device) Ansatz.
- Ermöglicht das Remote-Arbeiten in einer gekapselten Browser Umgebung so, als wäre der Benutzer am Standort.
- Benutzern wird ein vollwertiges Betriebssystem zur Verfügung gestellt.



Klassische Remote Access Lösungen: VDI

Vorteile:

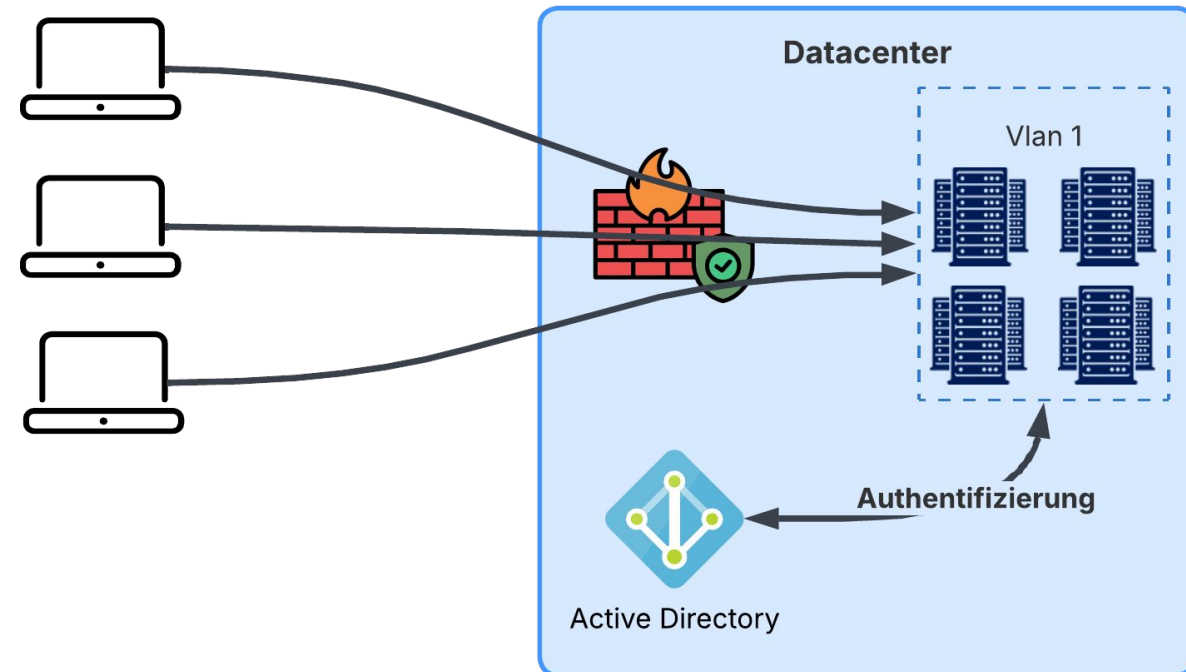
- Zentralisierte Kontrolle und Verwaltung einer Umgebung.
- Die Security des Gerätes von dem aus sich verbunden wird ist “mehr oder weniger” egal.
- Man erhält Kontrolle über den Zu- und Abfluss von Daten (DLP + Sicherheit)
- VDI-Umgebung lassen sich grundsätzlich durch das Hinzufügen von weiterem Storage, Hosts, etc. skalieren (aber aufwendig und teuer).
- Hohe Kompatibilität (funktioniert quasi auf jedem Gerät mit Browser)
- Keine Cloud-Abhängigkeit

Nachteile:

- Segmentierung äusserst statisch und aufwendig
- Security beruht auf der Kapselung des Netzwerks in Zonen
- Erfordert einen separaten Proxy (im DC)
- Äusserst Kostenintensiv (Lizenzen für VDI + zusätzliche Workspace-Lizenzen für jede VM)
- Sehr komplexer Betrieb von Hardware und Software
- Hohe Latenz für Internetzugriffe und Zugriffe auf andere Standorte (Backhauling)
- Geringe Transparenz (wer greift wie auf welche Ressourcen zu?)
- Erfordert das Exponieren eines Ports nach aussen
- Eingeschränkte User-Experience (USB, Audio, Latenz, etc.)

Klassische Remote Access Lösungen: Remote Desktop

- Direkte (RDP) Verbindungen auf ein Ziel im Datacenter
- Zwei Ansätze: Entweder direkte Verbindungen auf das Ziel oder dedizierte Jump-Stationen auf denen gearbeitet wird und von denen aus das eigentliche Ziel erreicht wird.
- Die Server / Jumphosts authentifizieren die Benutzer gegen das lokale Active Directory.
- Bestenfalls sitzen diese Ziele zumindest in einer DMZ.



Warum SSE entstanden ist

- **Cloud & SaaS:**

Anwendungen und Daten liegen nicht mehr im Rechenzentrum, sondern in der Cloud (Microsoft 365, AWS, Salesforce etc.). Direkter, lokaler Outbreak zum nächstgelegenen CDN erhöht die Performance.

- **Remote Work & Mobilität:**

Benutzer arbeiten von überall: klassische, standortbasierte Sicherheit greift nicht oder ist komplex und langsam (Backhauling).

- **Erhöhte Bedrohungslage:**

Standortbasierte Sicherheit ist nicht mehr genug. Zugriffe werden mit Zero Trust Policies auf Basis von Identität, Gerät und Kontext evaluiert.

- **Komplexität** klassischer Lösungen:

Viele Einzellösungen (VPN, SWG, CASB) werden durch eine zentrale, cloudbasierte Sicherheitsplattform ersetzt.

Was ist SSE?

Security Service Edge (SSE) ist ein Term, den Gartner 2021 definiert hat um die Sicherheitsfunktionen aus dem Teil SASE herauszulösen, weil für die meisten Unternehmen die direkte Migration zu SASE zu komplex war. SSE ist häufig Schritt 1 einer SASE-Migration.

Zweck:

- Schutz von Benutzern, Daten und Anwendungen, egal von wo aus sie verbunden sind. Die Abhängigkeit von zentralen Sicherheits-Appliances im Rechenzentrum wird aufgelöst.

Vorteil:

- Cloud-basierte, skalierbare Sicherheitsarchitektur
- Einfachere Richtlinien für alle Benutzer und Geräte
- Weniger Hardware und Komplexität an Standorten
- Macht Benutzer-Zugriffe mittels Overlay unabhängig vom darunterliegenden Netzwerk
- Grundlage für Secure Access Service Edge (SASE)

Figure 1: Magic Quadrant for Security Service Edge

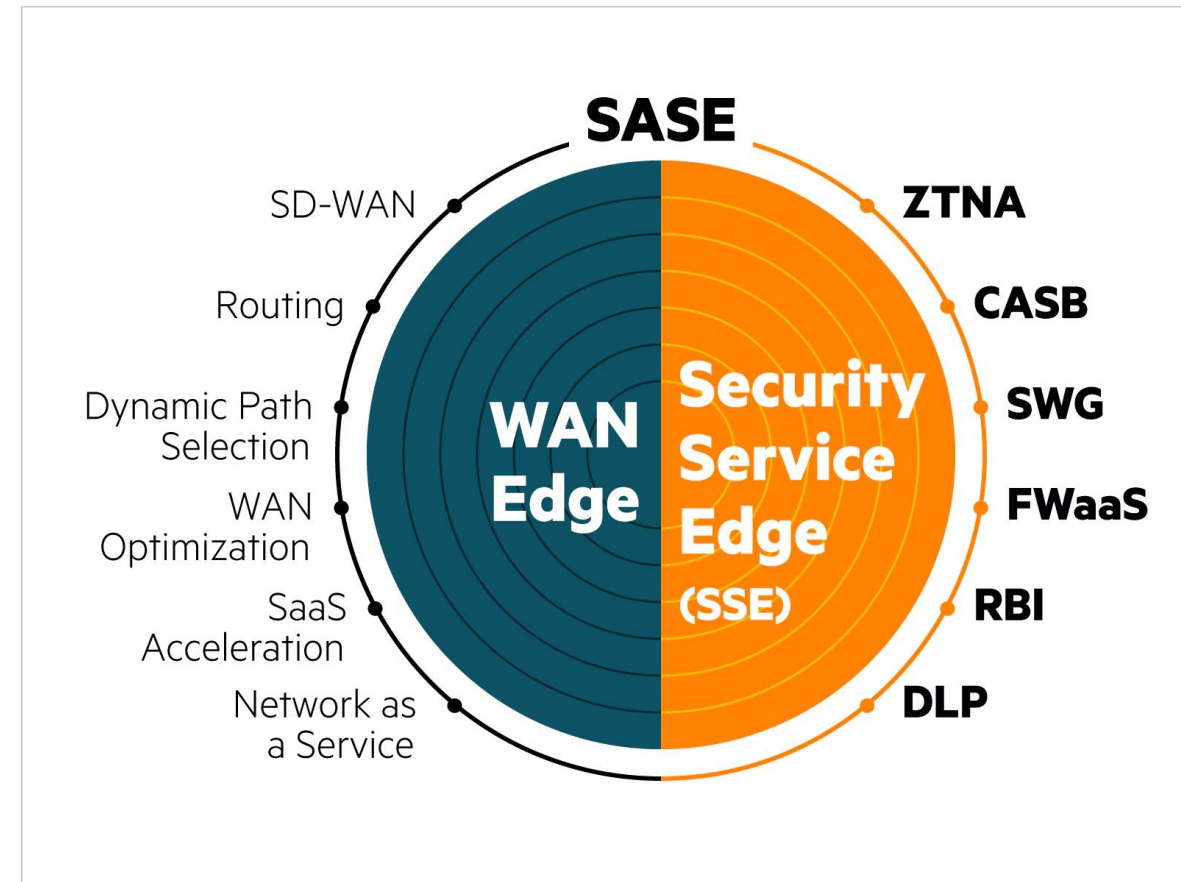


© Gartner, Inc

Gartner

SSE im Kontext von SASE

- SSE ist Bestandteil von SASE und referenziert primär den Security-Stack.
- Die Grenzen sind durch das Verschmelzen von Netzwerk und Sicherheit oft nach Use Cases getrennt.
- Dabei übernimmt SSE primär das Forwarding von Benutzer Traffic, während WAN-Edge für Maschinen-Kommunikation zuständig ist.
- Es gibt aktuell zwei grosse Implementierungsansätze:
 - Single-Vendor-SASE (WAN-Edge & SSE kommen vom gleichen Hersteller)
 - Multi-Vendor-SASE (mit zwei verschiedenen Herstellern)

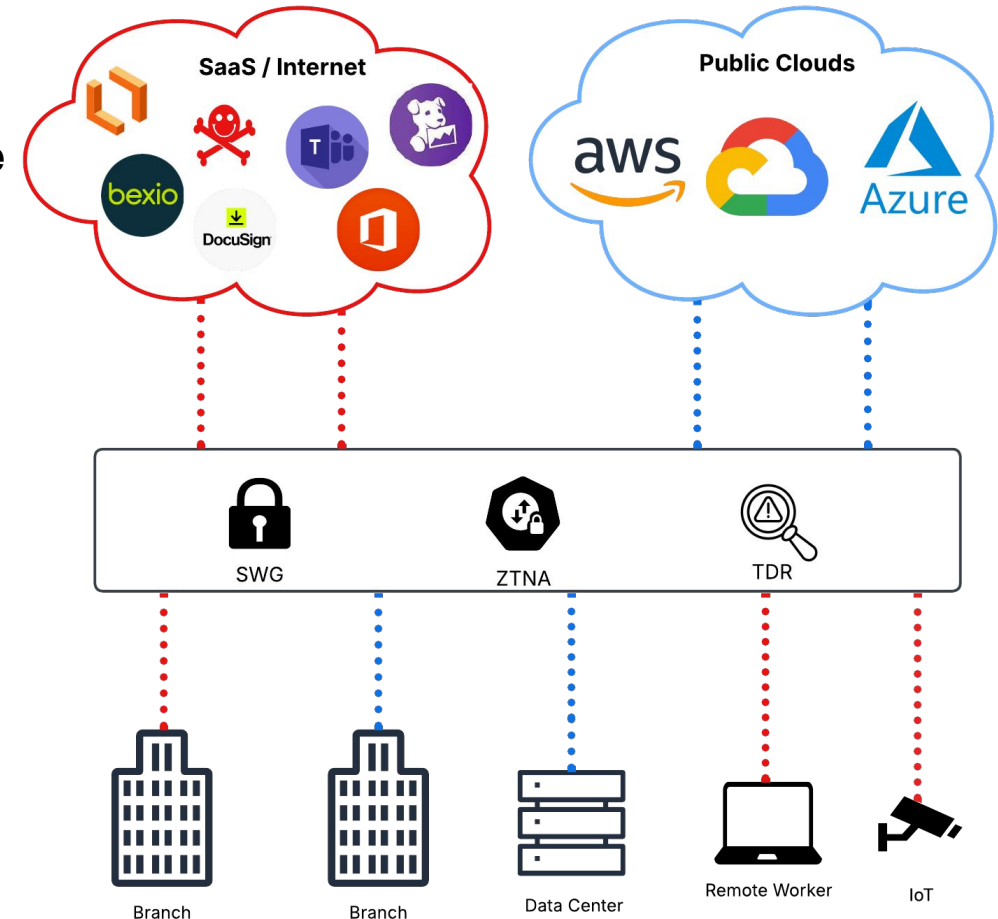


SSE Überblick

SSE ist eine Sammlung integrierter, cloudzentrierter Sicherheitsfunktionen, die den **sicheren Zugriff auf Websites, SaaS-Anwendungen und private Applikationen** ermöglicht.

Zu den wichtigsten Diensten von SSE gehören:

- **Zero Trust Network Access (ZTNA):** Ermöglicht direkten, sicheren, identitätsbasierten Zugriff auf interne Anwendungen – ohne klassisches VPN.
- **Secure Web Gateway (SWG):** Schützt Benutzer beim Zugriff auf das Internet vor Schadcode, Phishing und unerwünschten Inhalten.
- **Threat Detection & Response:** Die kontinuierliche Überwachung von Zugriffen und Events mit Alarmierung und automatisierten Reaktionen.



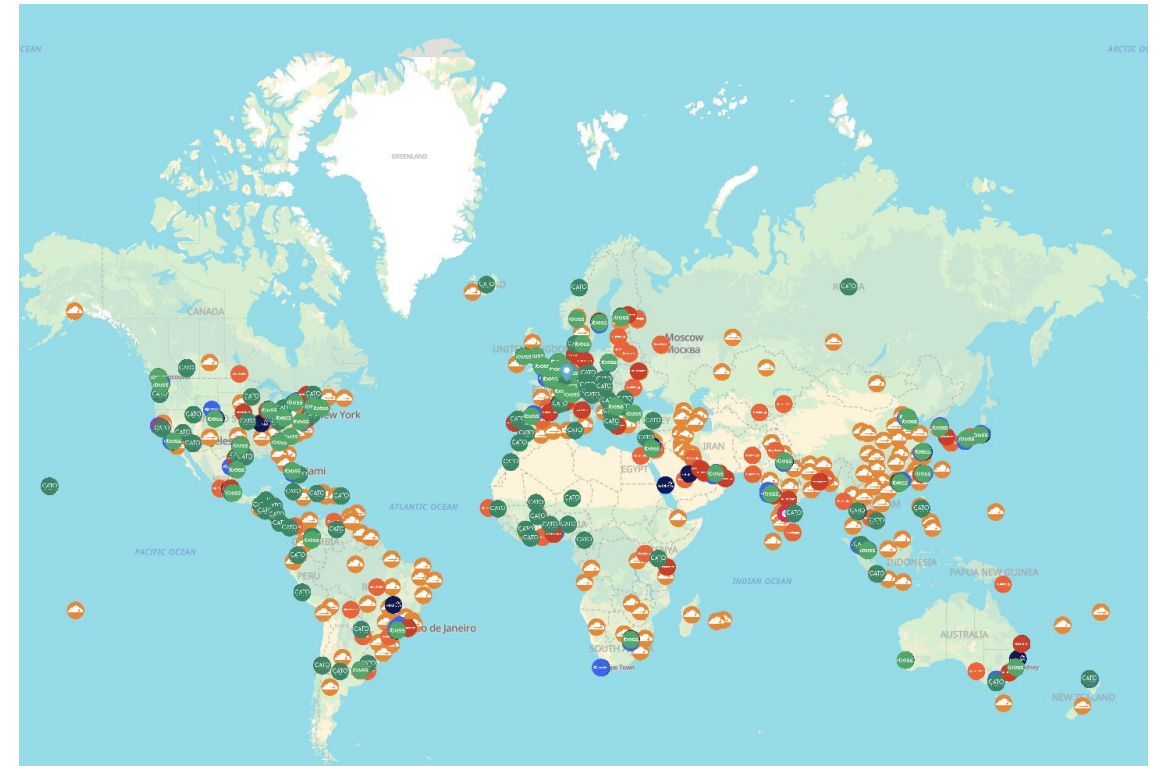
Welche Probleme SSE Löst

- Die **performante und sichere Anbindung von Remote Workern**:
Mitarbeiter arbeiten von überall, teils über mehrere Länder und Kontinente hinweg. Sie benötigen dabei die gleiche Security wie lokal am Standort. Interne Anwendungen müssen erreichbar sein, während SaaS Anwendungen direkt über das nächstliegende CDN bezogen werden sollen.
- Den **sicheren Zugriff auf SaaS** Anwendungen:
IoT, Benutzer, Server und Applikationen konsumieren immer mehr SaaS Anwendungen. SSE sichert den Zugriff darauf und ermöglicht applikationsspezifische Policies und Data Leakage Prevention Mechanismen.
- **Security as a Service**: SSE zentralisiert die Sicherheitslandschaft in der Cloud. Dies macht komplex zu betreibende Einzellösungen wie VPN, SWG, CASB und DLP-Lösungen an den Standorten überflüssig. Die Lösung skaliert dabei ohne Aufwand für die Unternehmen. **Dies erlaubt eine deutliche Simplifizierung der Standorte.**
- Zentralisierte Sicht auf das gesamte Netzwerk (-Overlay):
Administratoren erhalten sofortige Einsicht auf den gesamten (relevanten) Netzwerk-Traffic. Egal ob es sich um SaaS Traffic oder Verbindungen zu internen Applikationen handelt.

2. SSE Architektur

SSE im Überblick

- Zentrale, auf der **Welt verteilte Datacenter** der Provider nehmen den Traffic an, verarbeiten ihn, und bringen ihn dann ans Ziel.
- Logisch **verschmilzt** mit SSE der eigentliche Zugriff (**Netzwerk**) mit der darauf applizierten **Security** im Overlay.
- Knackpunkt: Wie den **Traffic in die Cloud** bekommen?
 - Benutzer Traffic wird über **Agents** eingefangen und zum nächstgelegenen Datacenter getunnelt.
 - Es gibt verschiedene Ansätze auf dem Markt für Overlay-Netze. Teils wird Carrier Grade NAT verwendet, teils wird mit VPN Ansätzen gearbeitet.
 - Server, IoT und OT Traffic wird mit **Tunneln** (VPN oder GRE) vom Perimeter aus zur Cloud geforwarded.
 - Sehr moderner, noch nicht ausgereifter Ansatz: Das Forwarding mittels “Zero Trust Sim Karten”. Dabei wird der APN (Access Point Name) der Sim-Karte auf die SSE-Cloud gesetzt. Dies ist speziell für IoT und OT “im Feld” interessant.
- Auch wenn SSE cloud nativ ist, erlauben manche Anbieter das lokale Enforcement auf WAN-Edge Geräten (dann aber SASE nötig)



<https://sasecloudmap.com/>

SSE Dienste, Komponenten & Features

Folgende **Dienste** werden angeboten:

- Secure Web Gateway
- Zero Trust Network Access
- Threat Detection & Response

Aus folgenden **Komponenten** bestehen SSE-Lösungen:

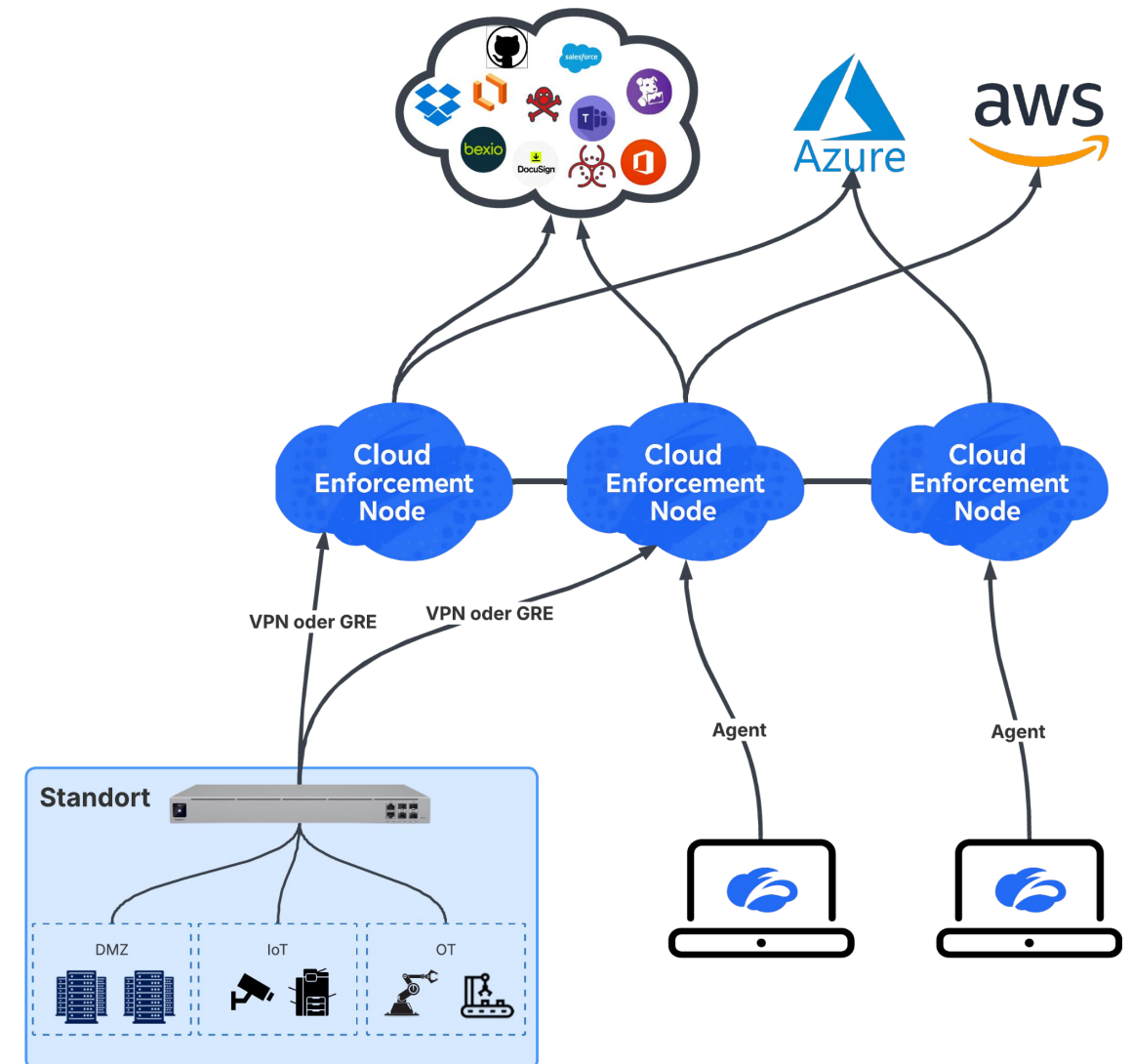
- Cloud Enforcement Nodes
- (Device-) Agents
- Datacenter- / Cloud-Proxies

Folgende **Features** bringen SSE Lösungen:

- Single Sign On
- Cloud Firewall (FWaaS)
- TLS Inspection
- URL Filtering
- Browser Isolation
- Quality of Service (QoS)
- Advanced Threat Protection
- Sandboxing
- Anti-Virus
- DNS Security
- Application Protection
- Data Loss Prevention (DLP)
- Cloud Access Security Broker (CASB)
- File Type Control

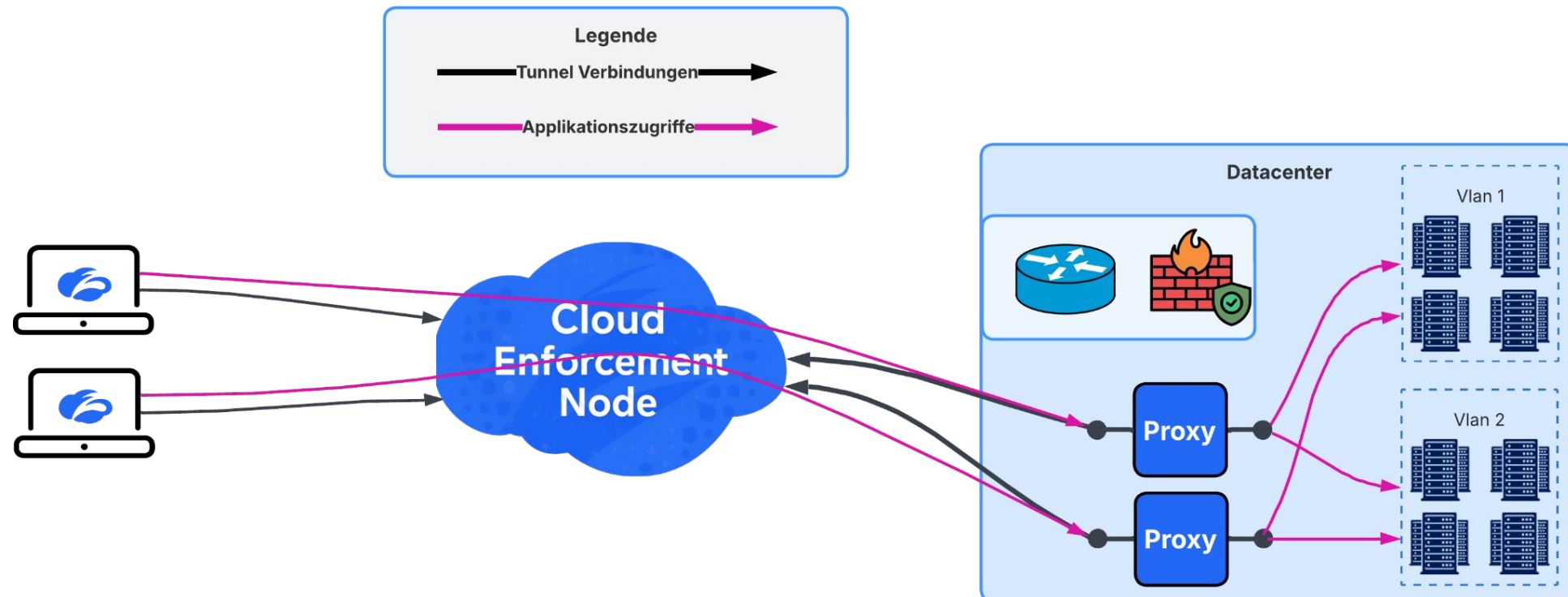
SSE Architektur

- Primär im Fokus von SSE sind Verbindungen ins Internet und Verbindungen von Benutzern zu internen Ressourcen
- East-West-Traffic (also App to App Kommunikation übernimmt SD-Wan bzw. ein WAN-Edge.
- Fast alle SSE Lösungen bauen Inside-Out-Verbindungen auf, sodass keine Ports geöffnet werden müssen
- Für die Anbindung von Datacentern oder Public Clouds werden entweder Tunnel verwendet oder mit (Reverse-) Proxies gearbeitet. Diese Proxies verbinden sich ausgehend zu den Cloud Enforcement Nodes und melden ihre bereitschaft. Ab diesem moment können Mikrotunnel von den Clients über den Node und den Proxy direkt auf die Applikation aufgebaut werden.
- Alternativ können Datacenter oder Clouds auch WAN-Edge Lösungen angebunden werden (Erfordert Single-Vendor-SASE)



Proxy Basierter Ansatz

- Die Verwendung von Proxies vereinfacht die Anbindung von Datacentern und Clouds, da diese wie Inseln betrachtet werden können.
- Sobald ein Proxy installiert wurde und den Node erreicht, sind die dahinterliegenden Applikationen erreichbar.



Proxy Basierter Ansatz

Vorteile

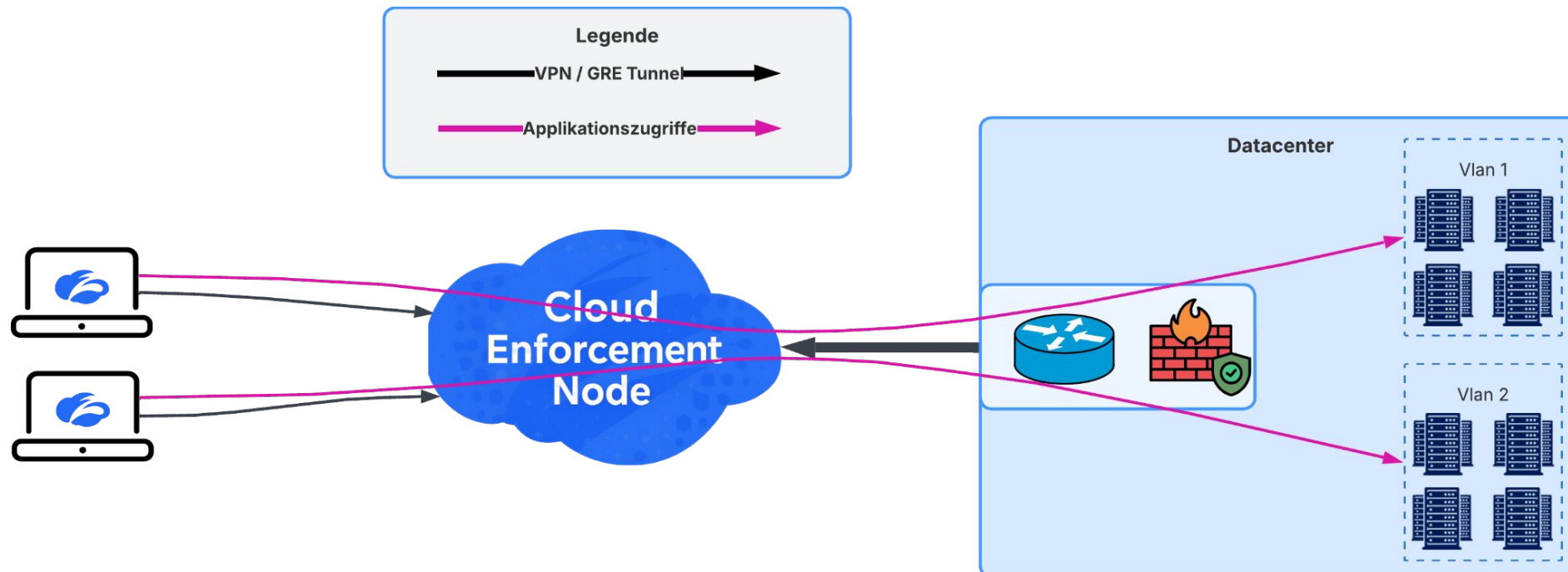
- Die Erweiterung von Bandbreite lässt sich einfach umsetzen, indem die Proxies horizontal skaliert werden.
- Das Proxy-Deployment kann mittels Infrastructure as Code (IaC) deployed und dynamisch skaliert werden.
- Einfache “Wegwerf Maschinen” ohne Komplexität können im Fehlerfall leicht ausgetauscht werden.
- Je nach eingesetzter Lösung sind IP-Überlappungen zwischen den Lokationen irrelevant, solange der Proxy die angefragte Domain zur korrekten IP umsetzen kann

Nachteile

- Das Deployment erfordert eine Virtualisierungsumgebung
- Standorte ohne Virtualisierungsumgebung müssen über das (SD-) WAN geroutet werden, was die Fehleranfälligkeit und Komplexität erhöht
- Infrastruktur kostet Geld & Ressourcen: Virtuelle Maschinen erzeugen monatliche Kosten und das zugrundeliegende Betriebssystem muss gewartet, geschützt und gepatched werden.

Tunnel Basierter Ansatz

- Der bestehende Perimeter wird verwendet um Tunnel zu den Cloud Enforcement Nodes aufzubauen.
- Das hinter dem Perimeter liegende Netzwerk wird damit für den Node zugänglich und die Ressourcen können über den Tunnel angesprochen werden.



Tunnel Basierter Ansatz

Vorteile

- Das Deployment erfordert keine Virtualisierungsumgebung
- Bestehende Infrastruktur / Hardware kann verwendet werden

Nachteile

- Tunnel müssen oft zu festen Enforcement Nodes aufgebaut werden (wenn der SSE Provider kein Anycast einsetzt)
- Clustering von Tunneln und Hardware ist komplexer und nicht von allen Perimetern unterstützt
- IaC ist aufgrund der Operation auf wichtigen Perimetern deutlich kritischer
- Netze müssen statisch definiert werden (anstatt dynamischer, domänenbasierter Zugriffe) -> IP Überlappungen sind ein Problem
- (Policy Based) Routing ist erforderlich, um Antworten wieder zur Quelle zu bringen

SSE vs. VPN

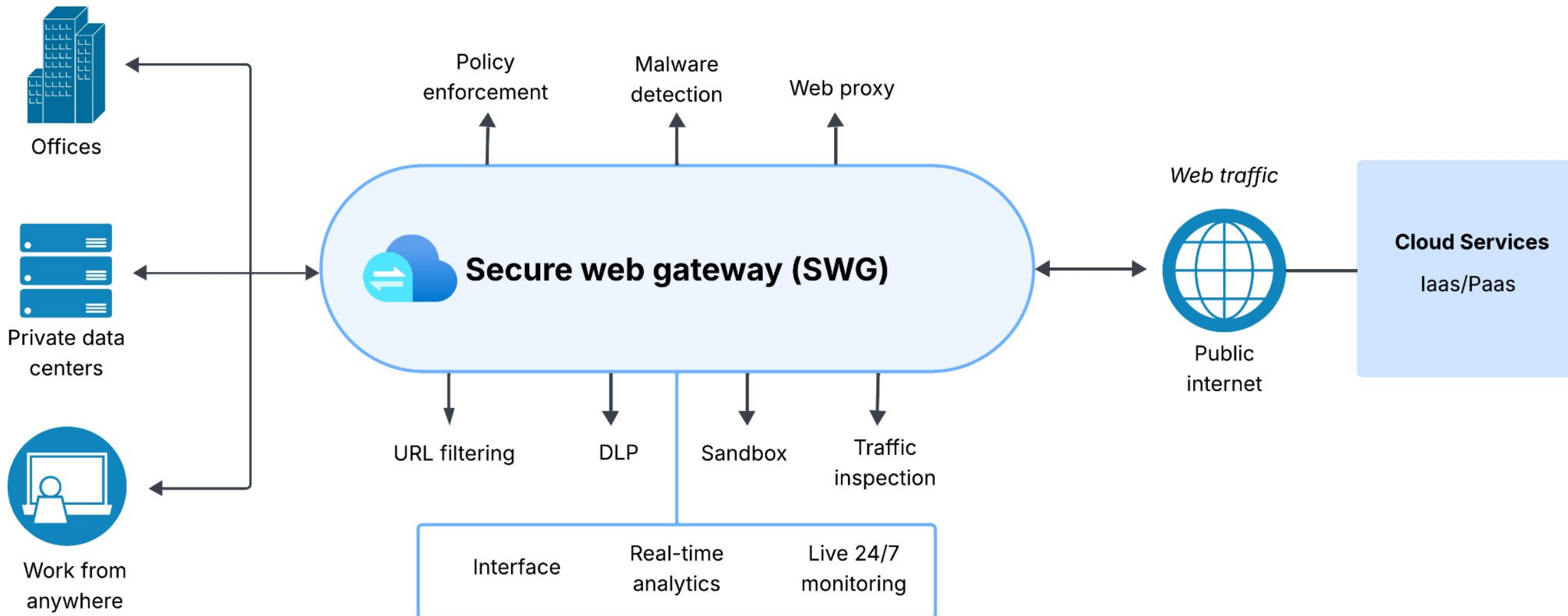
Kriterium	VPN	SSE
Architekturprinzip	Netzwerkbasierend, verbindet Benutzer mit internem LAN	Cloudbasiert, verbindet Benutzer direkt mit Anwendungen
Netzdesign	IP-Basiert, geroutet	Overlay-Netz
Vertrauensmodell	„Einmal vertrauen, immer vertrauen“	Zero Trust – kontinuierliche Prüfung bei jedem Zugriff
Segmentierung	Nicht nativ, maximal über statische IPs & Firewall	Native, RBAC-basierte Mikrosegmentierung
Kontrollinstanz	Perimeter / VPN-Gateway	Cloud Enforcement Nodes
Web Zugriff	Über zusätzlichen Proxy im DC	Integriert
Skalierbarkeit	Schwierig (Perimeter Wechsel)	Cloud-Native (irrelevant)
Angriffsfläche	Öffentlich erreichbarer Perimeter	Keine offenen Ports (aber SSE Hersteller kann angegriffen werden)
Kosten	CAPEX-Intensiv, aber geringere OPEX. Insgesamt geringer.	OPEX-basiert. Insgesamt höher.

SSE Dienste & Features

SSE Dienste: Secure Web Gateway

- Inspiziert und filtert (Web-) Zugriffe ins Internet auf SaaS für Benutzer, Server, IoT und OT
- Verhindert das laden von Schadcode aus dem Internet
- Verhindert gewollte oder ungewollte Datenexfiltration
- Erkennt unautorisierte Cloud-Dienste („Shadow IT“)
- Setzt Unternehmensrichtlinien und Compliance-Vorgaben beim Surfen durch
- Ermöglicht rollenbasierte Web-Zugriffe
- Bietet denselben Schutz für Büro, Homeoffice und unterwegs
- Liefert detaillierte Reports über genutzte Websites und Datenbewegungen
- Liefert Latenz-Optimierte Eintrittspunkte über die Cloud Enforcement Nodes (in der Nähe der Quelle bzw. des Ziels)

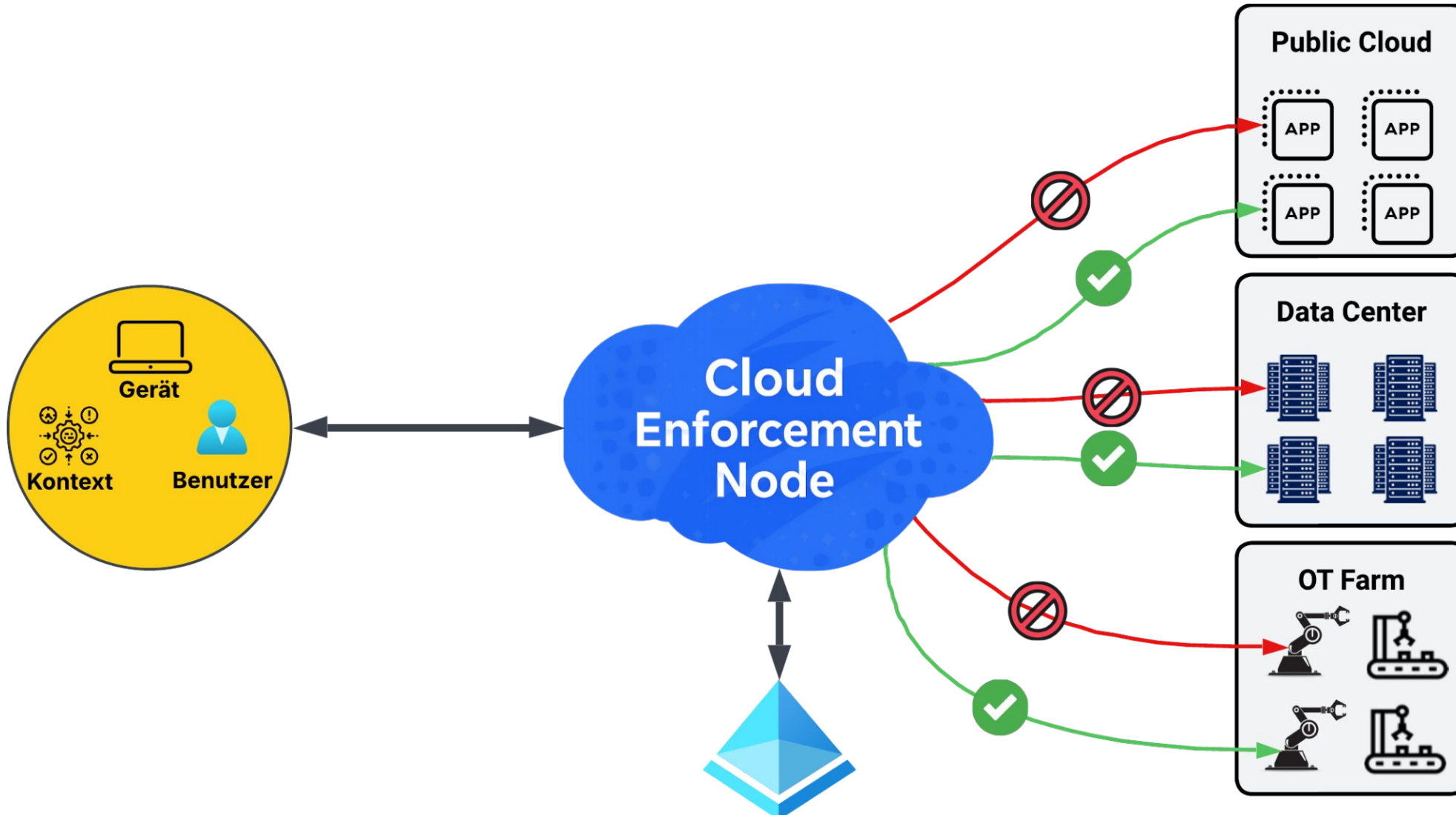
SSE Dienste: Secure Web Gateway



SSE Dienste: Zero Trust Network Access

- Ermöglicht **mikrosegmentierten Zugriff auf Applikationen** im internen Netzwerk (Cloud, DC, Standorte)
- Prüft **jede einzelne Anfrage** anstatt den Benutzer / das Gerät einmalig zu verbinden
- **Identifiziert die Applikation** üblicherweise durch eine Kombination aus FQDN & Port
- **Authentifiziert** Benutzer gegen den IdP, Geräte gegen ein MDM oder eine interne PKI
- **Evaluert** weiteren **Kontext** wie Risk-Score, Standort, Geräte-Attribute, Daten-Sensibilität, Zeit, Nutzerverhalten, etc.
- Setzt **rollenbasierte** Zugriffskontrollen um
- **Schützt Applikationen** vor böswilligem Verhalten
- Prüft Dateien auf **Schadcode**
- Reduziert die **Angriffsfläche** durch Least-Privilege-Policies und das verstecken von Applikationen vor Usern ohne Zugriff
- Erlaubt **direkten Zugriff auf Cloud-Umgebungen** ohne Backhauling über das Datacenter

SSE Dienste: Zero Trust Network Access



SSE Dienste: Threat Detection & Response

- Erkennt und analysiert **verdächtige Aktivitäten** im Datenverkehr zwischen Benutzer, Cloud und Anwendung
- Nutzt **Signatur- und verhaltensbasierte Erkennung** (Malware, Phishing, C2-Kommunikation, Zero-Day)
- Führt **Datei- und Inhaltsanalysen** in isolierten Umgebungen (Sandboxing) durch
- Korrelierte Ereignisse aus mehreren Quellen (Web, App, DNS, Cloud) zur **frühen Angriffserkennung**
- Liefert **Risikobewertungen und Priorisierung** von Vorfällen für Security-Teams
- Ermöglicht **automatisierte Reaktionen**, z. B. Session-Beendigung, Benutzer-Quarantäne oder Policy-Änderung
- Integriert sich mit **SIEM- und SOAR-Systemen** für zentrale Auswertung und Reaktion
- Erkennt **kompromittierte Benutzer oder Geräte** anhand von Anomalien im Verhalten
- Stellt **forensische Informationen und Reports** zur Verfügung (z. B. betroffene Dateien, Apps, Benutzer, Zeitstempel)
- Unterstützt die **kontinuierliche Verbesserung der Sicherheitsrichtlinien** durch Threat Intelligence Feeds

SSE Features: CASB

- **Identifiziert und klassifiziert** Cloud Applikationen und ermöglicht Applikationsspezifische Kontrollen, z.B.:
 - Up- / Download Kontrolle zu Filesharing Diensten
 - Prompt- und File-Kontrolle zu AI-Tools
 - Tenant-Restrictions für die Verwendung von SaaS Diensten (M365: Ja, aber nur der Unternehmens-Tenant)
- **Bewertet Dienste** nach Risiko, Standort und Compliance und setzt automatisiert Richtlinien um
- **Überwacht Datenbewegungen** und gibt Einblick in die Verwendung von SaaS-Applikationen
- Umsetzung auf zwei Arten (komplementär):
 - **Inline**: Daten werden direkt während des Zugriffs analysiert und gefiltert (Data in Motion)
 - **Out of Band**: Anbindung an SaaS-Applikationen und Durchsetzung von Richtlinien via API (Data at Rest)

SSE Features: CASB

Inline use cases

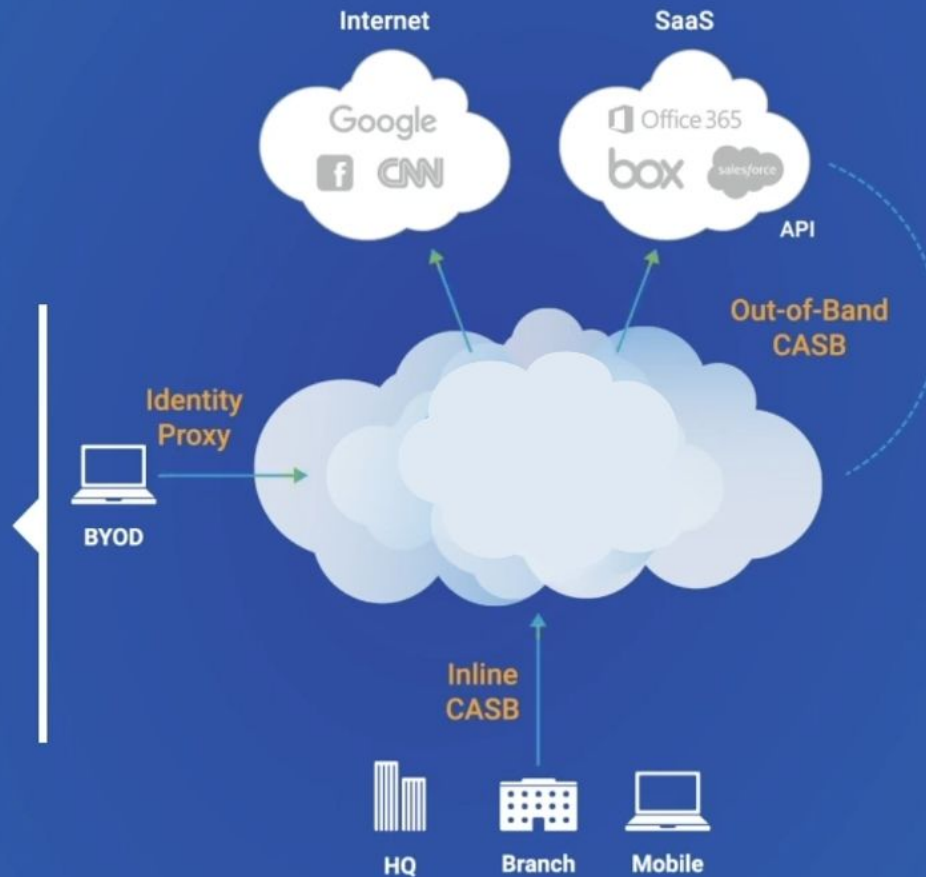
Cloud App Control

Cloud Activity (Upload, Download, Share, Edit, Post)

Corporate v. Personal Instances

Tenancy Restrictions

URLs & Custom URLs



Out-of-band use cases

Visibility and Shadow IT

Cloud Access Control

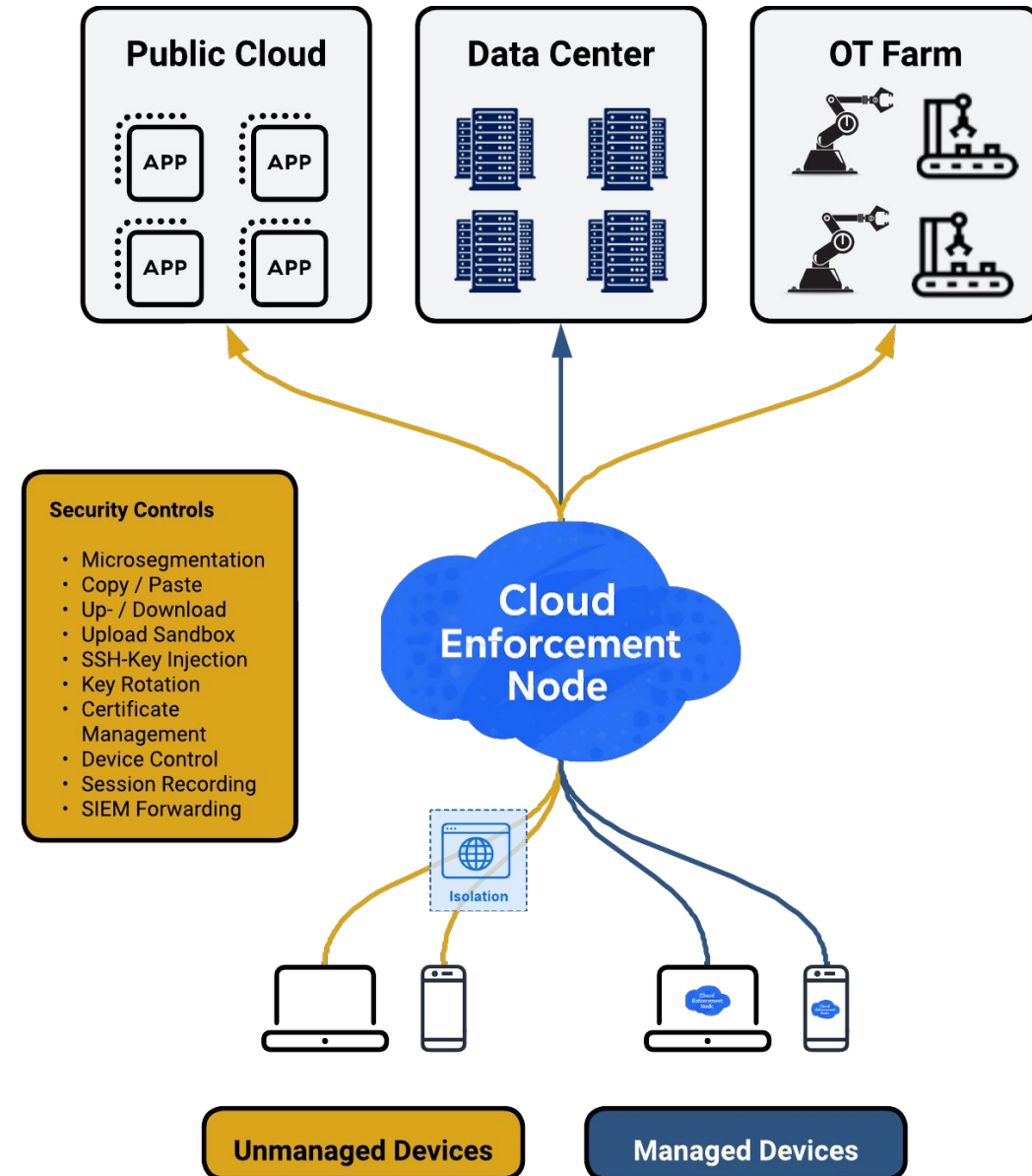
Data Loss Prevention

Threat Prevention

Compliance

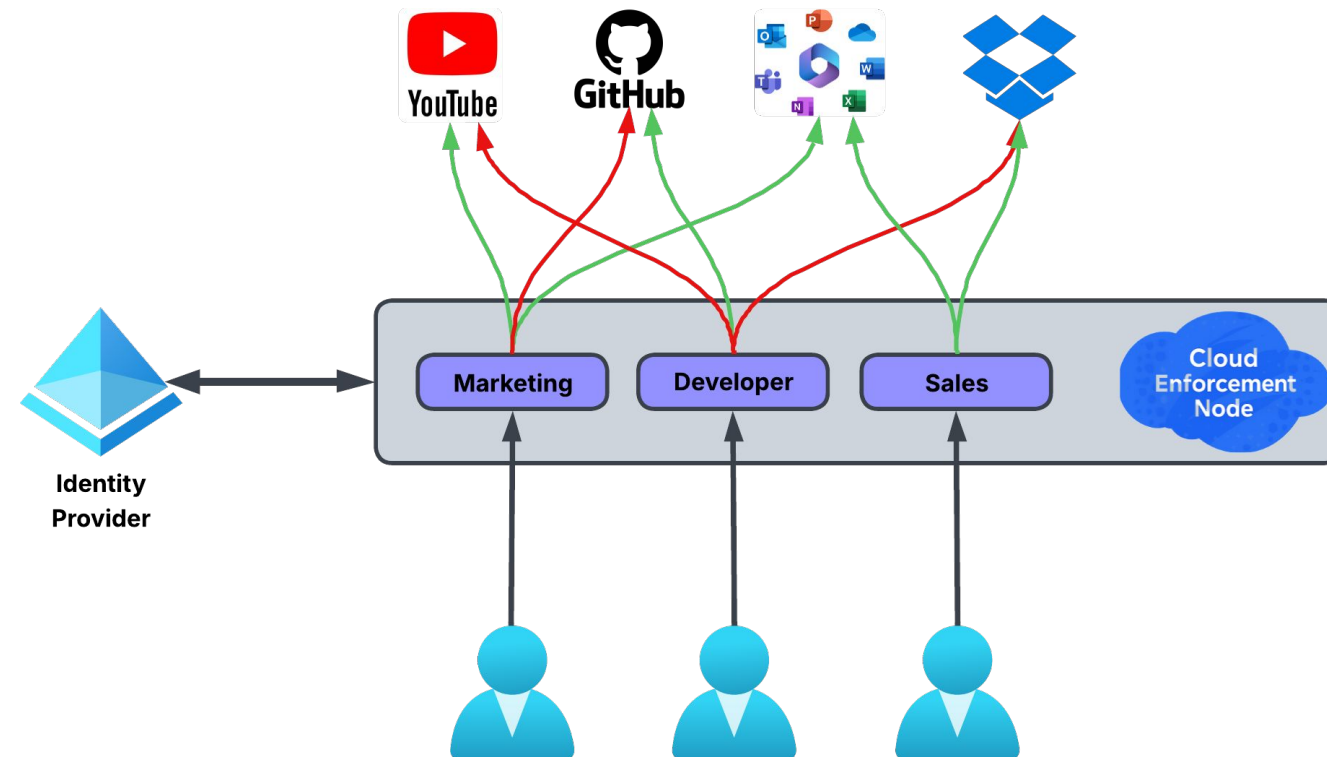
SSE Features: Browser Isolation

- **Enkapsuliert** den Zugriff auf eine Ressource in eine Isolierte Umgebung
- **Rendert** den Zugriff auf die Ressource entweder in der Cloud (Video-Stream) oder auf dem Gerät direkt (über Browser oder Agent)
- Üblicherweise kompatibel mit **HTTP(s), VNC, RDP & SSH**
- Usecases:
 - Sicherer Zugriff auf **Webseiten** ohne oder mit begrenzter Interaktionsmöglichkeit mit dem Endgerät / Benutzer
 - **BYOD**: Zugriffe auf interne Ressourcen ohne Firmengerät
 - **Remote Administration** von Systemen über privilegierte Ports (RDP, SSH, VNC)
 - **Remote Wartung** von Maschinen in Industrieumgebung für Zulieferer oder Hersteller (PAM-Ersatz)
 - **Conditional Access** basierend auf Gerätestatus für SaaS Applikationen (nativer Zugriff für interne Geräte, Isolierter Zugriff für fremde Geräte)



SSE Features: RBAC

- Zugriffe werden **gruppenbasiert** erlaubt (keine generischen Freischaltungen von Applikationen)
- Die Enforcement-Nodes beziehen alle verfügbaren Gruppen und deren Mitglieder **aus dem IdP**
- In den Policies wird eine Gruppe an den Zugriff auf eine Applikation / Ressource **gebunden**
- Gruppen werden **dynamisch** geupdated
- Benutzer können die Zugehörigkeit zu einer Gruppe **beantragen**
- Gruppen werden regelmässig (automatisch) **reviewed** um Überberechtigungen zu vermeiden



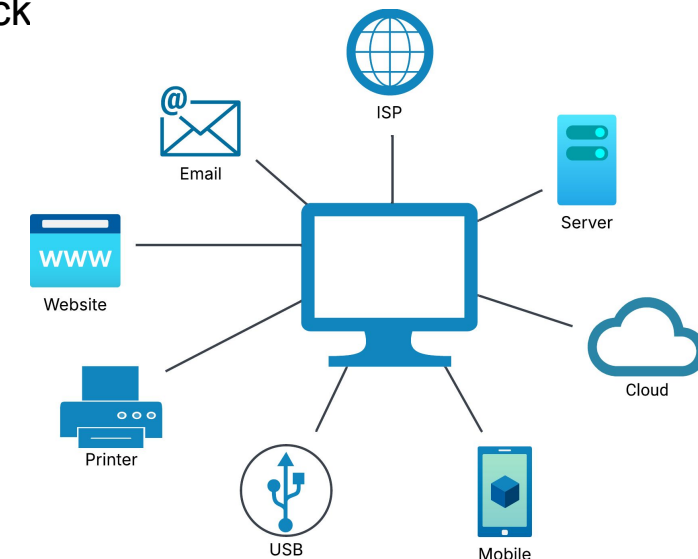
SSE Features: Kontext

- Prüft **Identität und Rolle** des Benutzers (z. B. aus IdP, AD, HR-System)
- Analysiert den **Zustand des Geräts** (verwaltet, verschlüsselt, gepatcht, EDR aktiv)
- Berücksichtigt den **Standort** und das **Netzwerk**, aus dem der Zugriff erfolgt
- Erkennt die **Anwendung und Sensitivität der Daten**, auf die zugegriffen wird
- Nutzt **Verhaltensanalysen (UEBA)** zur Erkennung ungewöhnlicher Aktivitäten
- Reagiert dynamisch auf Änderungen im Kontext (z. B. Standortwechsel, riskantes Verhalten)
- Weist **Risikowerte (Risk Scores)** zu, die Zugriff oder zusätzliche Authentifizierung steuern
- Kombiniert Kontextdaten aus **ZTNA, SWG, CASB und Threat Intelligence**
- Erzwingt Sicherheitsrichtlinien **in Echtzeit**, angepasst an Risiko und Situation



SSE Features: DLP

- Erkennt und schützt **sensible Daten** (z. B. Kundendaten, Finanzinformationen, Gesundheitsdaten) vor Verlust oder Missbrauch
- **Überwacht Uploads, Downloads und Copy/Paste-Vorgänge** in Web-, Cloud- und E-Mail-Traffic
- Nutzt **Datenklassifikation** (z. B. Regex, Dictionaries, Fingerprints, AI), um vertrauliche Inhalte zu identifizieren
- **Erzwingt Richtlinien** je nach Datenart, Benutzerrolle und Ziel (z. B. „Upload blockieren“, „verschlüsseln“, „melden“)
- Schützt Daten in Bewegung (Data in Transit), in Nutzung (In Use) und in Speicherung (At Rest)
- **Unterstützt Cloud-Apps (CASB-Integration)** wie M365, Google Drive, Dropbox oder Slack
- Erkennt **versehentliche und absichtliche Datenabflüsse**
- Liefert **Echtzeit-Warnungen und Reports** für Security- und Compliance-Teams
- **Hilft bei der Einhaltung gesetzlicher Vorgaben** (z. B. DSGVO, FINMA, ISO 27001)
- **ML-Analyse** und **Content-Inspection**, um Fehlalarme zu reduzieren
- **Schwierigkeit: Sämtliche Datenflüsse mit einer Lösung zu kontrollieren**



SSE Features: File Type Control

- **Erkennt und klassifiziert Dateitypen** unabhängig von der Dateiendung (z. B. `.exe`, `.zip`, `.docx`)
- **Blockiert oder erlaubt Dateitypen** basierend auf Richtlinien (z. B. keine `.exe`- Downloads)
- **Verhindert getarnte Dateien**, die durch falsche Endungen Sicherheitskontrollen umgehen (z. B. `.jpg.exe`)
- **Schützt Cloud-Dienste und E-Mail-Verkehr** vor gefährlichen oder unerwünschten Dateiformaten
- **Unterstützt granulare Richtlinien** je nach Benutzerrolle, Ziel-App oder Kommunikationsrichtung (Upload/Download)
- **Reduziert Angriffsfläche** durch Einschränkung potenziell riskanter Dateitypen
- **Ergänzt DLP und Malware Protection**, um bekannte Gefahrenquellen bereits beim Dateityp zu stoppen
- **Ermöglicht Reporting und Nachvollziehbarkeit**, welche Dateitypen wann blockiert oder erlaubt wurden
- **Wird zentral in der Cloud durchgesetzt**, unabhängig vom Endgerät oder Standort
- **Trägt zur Einhaltung von Compliance-Vorgaben** bei (z. B. keine privaten Archivformate in Unternehmensumgebungen)

Source IP Anchoring (SIPA)

SIPA ist eine veraltete aber immer noch gängige Möglichkeit um IP-Basierte Authentifizierung umzusetzen.

- Eine gewisse Ressource (im Internet) muss zwangsläufig von einer gewissen IP kommen
- Teilweise im Public-Sector oder veralteten Applikationen zu finden
- Meist aufgrund des Anbieters nicht oder sehr schwer durch moderne Authentifizierung zu ersetzen
- Kann mit den meisten SSE-Lösungen aber abgefangen werden, indem man gewisse Ziele (IPs, Domains) über gewisse Quellen routed:
 - Cloud-SIPA mit dedizierter outbreak IP in der cloud
 - Über eigene Konnektoren oder Pac-File Einträge
 - Über Policy Based Routing

Secure Access Service Edge (SASE)

1. Einführung in SASE
2. Aktuelle Probleme von SASE Lösungen
3. Aktuelle SASE Architekturen
4. SASE in OT Netzen
5. Tipps zur Einführung

1. Einführung in SASE

Was ist SASE?

- SASE = Secure Access Service Edge
- Gartner Definition (2019):

Secure Access Service Edge (SASE) vereint Netzwerk- und Sicherheitsfunktionen in einem einzigen, cloudbasierten Service. Dazu gehören SD-WAN, Secure Web Gateway (SWG), Cloud Access Security Broker (CASB), Next-Generation Firewall (NGFW) und Zero Trust Network Access (ZTNA).

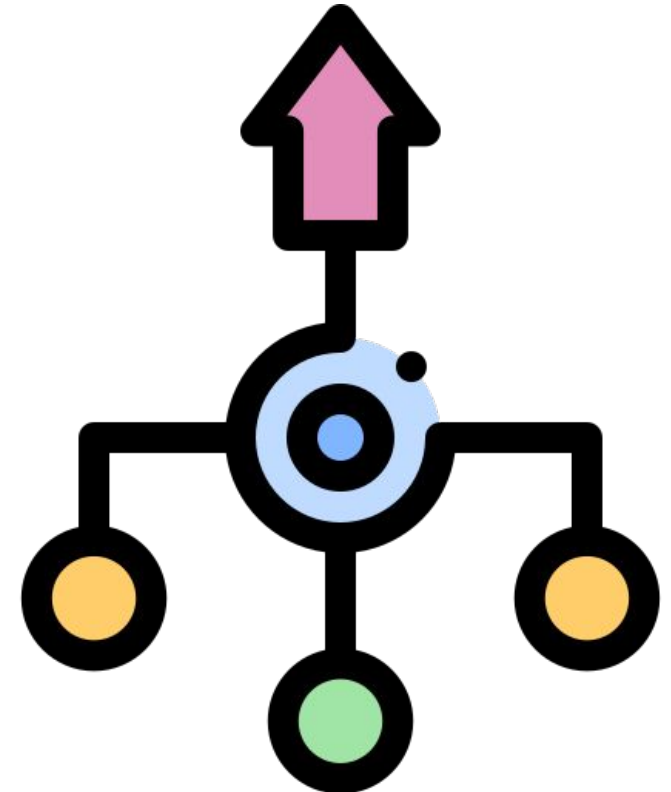
SASE unterstützt typische Anwendungsfälle wie den sicheren Zugriff aus Niederlassungen, von Remote-Mitarbeitenden oder aus lokalen Rechenzentren.

SASE wird überwiegend als Cloud-Service bereitgestellt und ermöglicht Zero-Trust-Zugriff, basierend auf der Identität des Geräts oder Benutzers – ergänzt durch kontextbasierte Echtzeitprüfung sowie Sicherheits- und Compliance-Richtlinien.

The Gartner logo is displayed in a large, bold, dark blue font. It consists of the word "Gartner" followed by a registered trademark symbol (®).

Warum SASE?

- Letztendlich ist SASE die Unifizierung von SD-WAN und SSE in eine Administrationskonsole.
- Vorteile der Konsolidierung:
 - Einheitliche Policy von Nutzer bis Standort
 - Konsistentes Zero-Trust über alle Pfade
 - End-to-End-Sichtbarkeit in einem Stack (und zentrale Telemetriedaten)
 - API-/Automation-first
 - Konsolidierte Betriebs- und Kostenstruktur
 - End-to-End-Troubleshooting
 - Einfachere automatisierte Gegenmassnahmen
- Vision: Eine zentrale SaaS die sämtliche Netzwerk und Security Aufgaben übernimmt



SASE - Aktueller Stand

- Aktuell haben noch längst nicht alle Unternehmen SD-WAN oder SSE eingeführt
- Es tummeln sich aktuell verschiedene Vendors verschiedener Hintergründe auf dem Markt, die unterschiedliche Ansätze verfolgen
- Der aktuelle Technologie-Stand ist noch deutlich hinter der Vision, es gibt aber erste, funktionierende Ansätze.
- Gerade die Nischen-Fälle machen den Herstellern noch Probleme, da die technologische Tiefe oft noch nicht gegeben ist.
- Ausgereift ist aktuell der Einsatz eines Multi-Vendor-SASE Ansatzes mit zwei verschiedenen Herstellern in der Sparte WAN-Edge und SSE
- Üblicherweise haben die On-Prem (Hardware-) Lastigen Hersteller Schwierigkeiten mit der SSE-Lösung, und umgekehrt die Cloud-Zentrischen Anbieter Schwierigkeiten mit der WAN-Edge Lösung

Figure 1: Magic Quadrant for SASE Platforms



Ansatz mit Multi-Vendor-SASE

- Kombiniert einen Anbieter für SD-WAN (oder WAN-Edge) mit einem SSE-Anbieter
- **Vorteile:**
 - Berücksichtigt, die aktuelle Marktlage und technologische Tiefe der aus verschiedenen “Ecken” kommenden Anbieter und erlaubt den “Best of Breed” Ansatz.
 - Erlaubt die Vereinheitlichung der gesamten Layer-2/3 Struktur (WiFi + Switching + Firewall)
 - Bietet üblicherweise eine höhere Feature-Dichte und Tiefe als Single-Vendor-SASE
- **Nachteile:**
 - Manuelle Integration der beiden Komponenten nötig
 - Keine zentralisierte Administration & Policies

Vendor 1
+
Vendor 2
=
SASE

Ansatz mit Single-Vendor-SASE

- Kombiniert beide Technologien in einem Anbieter
- **Vorteile:**
 - Einfache Integration des Standortes in die SSE-Cloud
 - Zentralisierte Administration & Policies
- **Nachteile:**
 - Aktuell niedrige Feature-Dichte und Tiefe
 - Aktuell sehr teuer

Vendor 1
+
Vendor 1
=
SASE

2. Aktuelle Probleme von SASE Lösungen

Lokales Enforcement

Problem

- East-West-Traffic am Standort / Cloud / Datacenter lokal halten
- Damit haben aktuell gerade die Hersteller aus dem Cloud-bereich Probleme
- Wenn Server 1 am Standort mit Server 2 am gleichen Standort sprechen will, muss der Server zuerst über die Cloud kehren, wo dann Security-Enforcements appliziert werden

Auswirkung:

- Höhere Latenz & weniger Bandbreite
- Zusätzliche Kosten (gerade bei Public-Clouds, die für Egress-Traffic billen)
- Geringere Resilienz: Ist das Internet weg, funktioniert auch der lokale Zugriff nicht mehr

Verwaltung des lokalen Netzes

Problem

- Letztendlich muss der WAN-Edge mit dem lokalen Netzwerk in Einklang gebracht werden, um Segmentierung und Sicherheit sicherstellen zu können
- Das heisst, im besten Fall verwaltet er WiFi, Layer-2 Broadcast-Domänen und lokale Netze

Auswirkung:

- Zusätzliche Komplexität für das Alignment des lokalen Netzwerkes mit dem WAN-Edge
- Ein weiterer Vendor für Switching, Routing und WiFi nötig

Business Continuity

Problem

- Wenn die Cloud ausfällt, sind die meisten Dienste weg
- Im besten Fall funktioniert noch lokaler Traffic am Standort

Auswirkung:

- Ausfälle oder Störungen bei Cloud Providern legen ganze Unternehmen lahm, was Multi-Millionen-Schäden verursacht.

Mikrosegmentierung an Standorten

Problem

- Standort-Interne Verbindungen müssen Mikrosegmentiert werden, haben aber die gleiche Broadcast Domain oder sind geroutet
- Letztendlich eine Kombination des Problems “Lokales Enforcement” und “Verwaltung des lokalen Netzes”

Auswirkung:

- Lokale Instanzen können ungefiltert aufeinander zugreifen (Stichwort: Lateral Movement).
- Ist eine Instanz übernommen, kann sie ungehindert alle anderen Instanzen an dem Standort übernehmen

Server to Client Verbindungen

Problem

- Das Overlay Netzwerk und die Routing-Logik der Anbieter erlauben häufig keine Server-2-Client Verbindungen

Auswirkung:

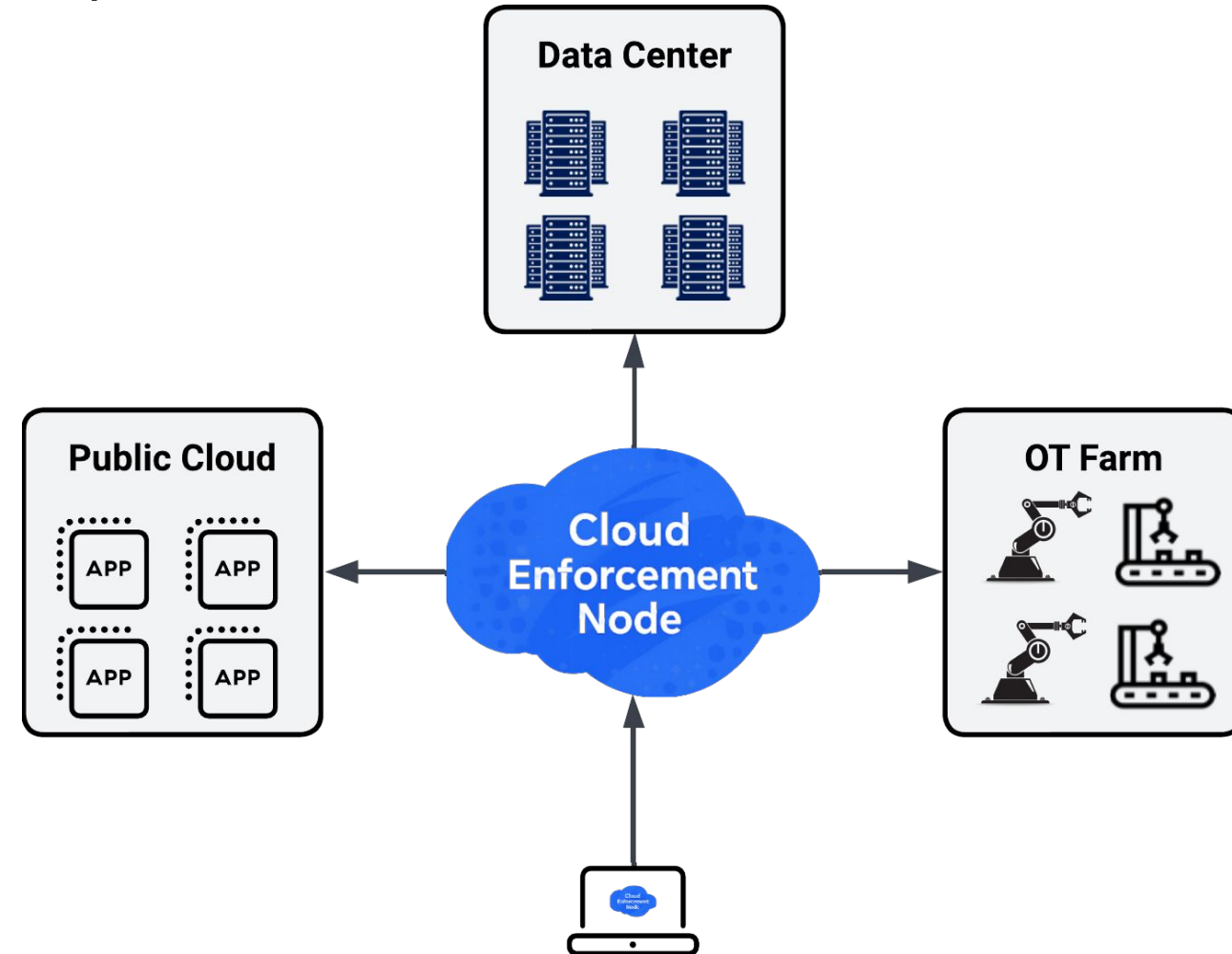
- Gerade in grossen Infrastrukturen mit Legacy-Systemen führt das zum Verlust der Applikationen für remote Benutzer
- Es muss teils ein paralleler VPN Client nur für diese Edge-Cases betrieben werden

3. Aktuelle SASE Architekturen

Cloud-anchored SASE (PoP-first)

Prinzipien

- **Globale PoPs:** Benutzer & Standorte terminieren am nächstgelegenen PoP (Point of Presence).
- **Single-Pass Processing:** L3–L7-Kontrollen in einem Cloud-Pfad (SWG/CASB/ZTNA/FWaaS/IPS).
- **Identity- & Policy-zentriert:** Zugriffe pro Identität/Applikation, nicht per Subnetz.
- **Thin Edge:** Client (Remote) + IPsec/GRE (Standort), Konnektoren für private Apps (ausgehend).
- **Zentrale Orchestrierung:** Einheitliche Cloud-Konsole, API-first, Telemetrie aus der Cloud



Cloud-anchored SASE (PoP-first)

Traffic Flow

- Remote-User greifen mittels Agent oder Browser auf den PoP zu. Policy Inspektion direkt im PoP.
- Web Filtering für IoT / OT / Server und Container mittels Tunnel (VPN oder GRE) zum PoP (transparenter Proxy)
- Standort Vernetzung mittels Tunnel und / oder Konnektoren zu PoPs.
- Anbindung von Datacentern, Clouds und Standorten mittels Konnektoren (outbound).
- East/West-Verbindungen innerhalb der Standorte, Clouds und DCs üblicherweise nicht effizient umsetzbar (Forwarding zu PoP notwendig).

Cloud-anchored SASE (PoP-first)

Stärken

- Einfache Skalierung möglich ohne sich um Hardware kümmern zu müssen
- Meist sehr ausgeprägte SSE Funktionalität mit hoher technischer Tiefe im Bereich Proxy, CASB, DLP und Threat Detection
- Einfaches Onboarding und Betrieb

Schwächen

- East/West Segmentierung wenn überhaupt mit Backhauling über PoP möglich
- Starke Cloud Abhängigkeit
- Keine zentralisierten Telemetriedaten für ALLE Verbindungen im Unternehmen

Cloud-anchored SASE (PoP-first)

Üblicher Einsatz

- Für Unternehmen mit IT Fokus
- Für Unternehmen mit hohen Anforderungen an im Proxy, CASB und DLP Bereich
- Für moderne Unternehmen mit viel SaaS und Cloud-Ressourcen
- Für Unternehmen die einen Best-of-Breed Ansatz fahren
- Für Unternehmen die einem “Thin-Edge” Ansatz folgen

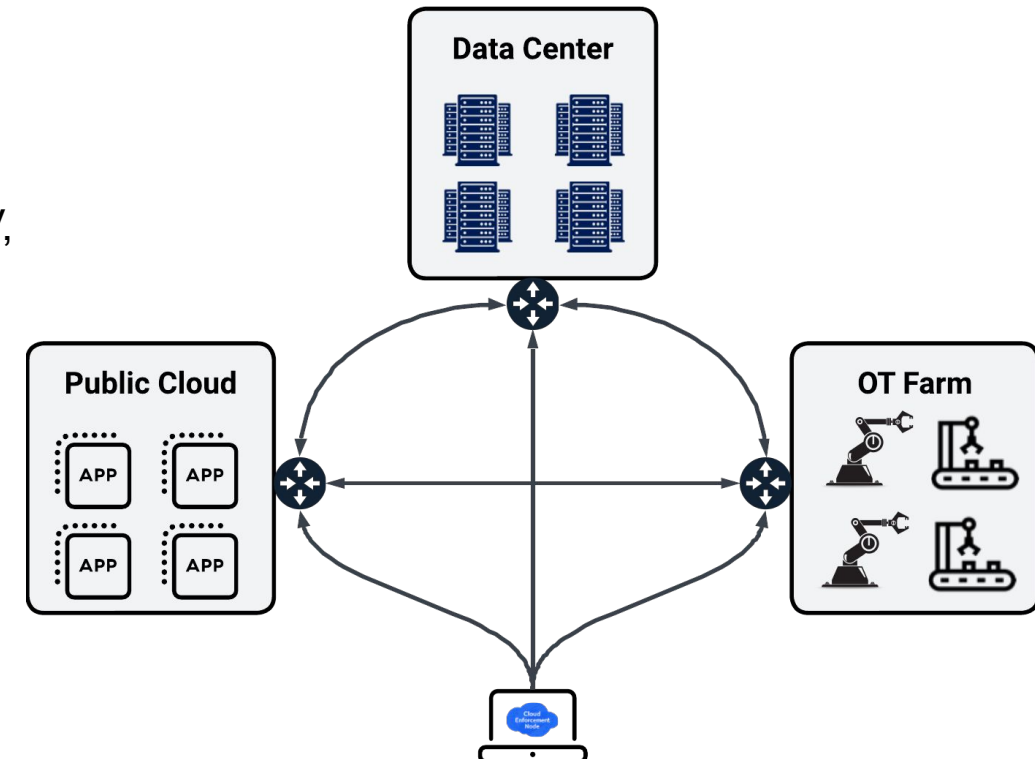
Hersteller in diesem Gebiet

- Zscaler
- Cloudflare
- Netscope

Edge-anchored SASE (Gateway-first)

Prinzipien

- **Lokale Edge-Appliances:** Primäre Durchsetzung von Policies am Standort. Cloud-Dienste optional als Ergänzung (z. B. SWG/ZTNA).
- **Thick Edge:** L3–L7-Kontrollen auf dem WAN-Edge (Routing, IPS/AV, App-ID, QoS). Cloud ist nicht zwingender Datenpfadbestandteil.
- **Network- & Identity-zentriert:** Zonen/VLAN/VRF als Basis, Identität/Device-Posture via AD/SSO/NAC in Policies integrierbar.
- **Topologien frei:** Full-Mesh oder Hub-and-Spoke als Overlay (SD-WAN). Internet-Breakout lokal oder zentral/hub.
- **Zentrales Management:** Controller/Manager (on-prem oder cloud-gehostet), Log-Korrelation/SIEM; Lifecycle (Sizing, HA, Upgrades) verbleibt beim Betreiber.



Edge-anchored SASE (Gateway-first)

Traffic Flow

- **Remote-User:** VPN/ZTNA-Client direkt zum Standort. Inspection on-prem, mit optional zusätzlich Cloud für Proxy Funktionalität.
- **Lokale User auf lokale Ressourcen:** Direkt & lokal über die Appliance (kein Cloud Umweg). Funktioniert auch bei Internet-/PoP-Ausfall.
- **Standortvernetzung:** Direkte SD-WAN-Overlays (Full-Mesh/Hub). Pfadwahl auf dem Edge, Cloud nicht zwingend im Pfad.
- **DC/Cloud-Anbindung:** Ebenfalls mit Appliance, folgt dem Prinzip der Standortvernetzung.
- **East/West Verbindungen** innerhalb des Standorts über klassische Anbindung mit VLANs.

Edge-anchored SASE (Gateway-first)

Stärken

- **Resilienz & Latenz:** Lokaler Betrieb bei ISP/Cloud-Störung möglich und deterministische East-West-Pfadkontrolle ohne Cloud-Umwege.
- Vollständige L3–L7-Abdeckung am Edge: Reife NGFW/IPS/AV, OT/IoT-Protokolle, Inter-VLAN-Firewalling und NAC-Integrationen.
- Zentrales Management und (Security-) Controlling aus einem Guss

Schwächen

- Betriebsaufwand & Skalierung: Hardware-Lifecycle, Sizing/HA und Skalierung gerätegebunden.
- SSE-Tiefe: In den Bereichen Proxy/CASB/DLP/RBI oft deutlich weniger ausgeprägt als bei Cloud-Natives und faktisch häufig dennoch getrennte Konsolen für die verschiedenen Features

Edge-anchored SASE (Gateway-first)

Üblicher Einsatz

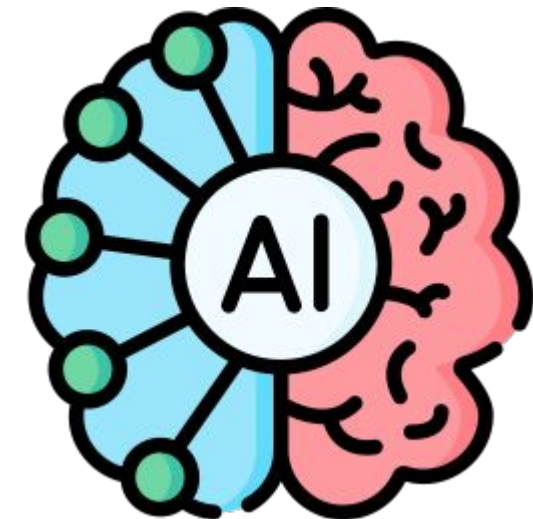
- Unternehmen mit starker On-Prem/OT-Präsenz (Fertigung, KRITIS), strengen East-West-/Latenz-Anforderungen oder stark verteilter Virtualisierungsumgebung.
- Organisationen mit Fokus auf lokale Resilienz & hohe Kontrolle/Customization der Netzpfade.
- Brownfield-Umgebungen mit bestehender NGFW/SD-WAN-Landschaft die eine schrittweise Cloud-Ergänzung anstreben.

Hersteller in diesem Gebiet

- Fortinet
- Palo Alto
- Cisco
- Versa
- Check Point

Verwendung von AI in SASE

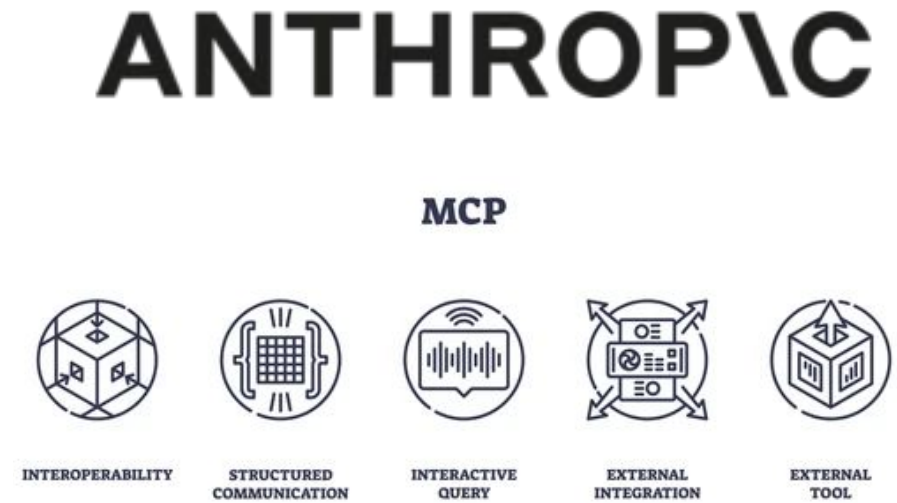
- **Mikrosegmentierung:** Erkennung von Geräten anhand Fingerprints und Policy-Vorschläge (nach Lernphase)
- **Security** (Detection/Response): UEBA/IoT-UEBA (User and Entity Behavior Analytics) um abnormes Verhalten festzustellen, ML-Sandbox/URL/Phishing, risk-adaptive ZTNA, AI-gestütztes DLP, AI-Based Browser Isolation and Phishing Detection.
- **Automatisierung:** Autoremediation (Quarantäne, Policy-Hotfix, Tunnel-Self-Healing), Predictive SD-WAN (Loss/Jitter-Forecast & Pfadwahl), Config-Assist, SecOps-Copilot (NL-Abfragen, Incident-Summary, Playbooks).
- **Performance optimization:** AI-based routing Entscheidungen für korrekte Pfadwahl und MTU-Discovery



Ausflug MCP (Model Context Protocol)

Definition & Nutzung in Kürze

- Ein MCP-Server (Model Context Protocol) stellt KI-Modellen über standardisierte Schnittstellen („Tools“, „Resources“, „Prompts“) kontextsensitive Daten und Aktionen bereit.
- **Beispiel** Zscaler MCP-Server:
 - KI-Agent fragt: „Zeige mir alle Benutzer mit Risiko-Score > 70 in Region Europa“ → MCP-Server liefert Daten aus Zscaler.
 - KI-Agent initiiert Aktion: „Quarantiere diese Benutzergruppe sofort“ → MCP-Server ruft Zscaler API zur Policy-Anwendung auf.
- **Nutzen:** Schnelle Integration von Sicherheits- und Netzwerk-Daten in KI-Workflows, automatisiertes Incident-Handling, reduzierte OPEX



Mikrosegmentierung von Standorten

Problem:

Grundsätzlich stellt die Einführung von Mikrosegmentierung Unternehmen vor eine grosse Herausforderung, denn:

- Administratoren wissen überhaupt nicht, welche IT / OT überhaupt vorhanden ist
- Die Kommunikationsflüsse sind unbekannt
- JEDE Verbindung explizit zu konfigurieren, ist massiv aufwändig
- Viel Verkehr wird überhaupt nicht über die Firewall geroutet (Layer-2 Broadcast Domänen)
- Auf den meisten Quellen (IoT, OT, Server, Apps) lassen sich überhaupt keine Agents installieren



Mikrosegmentierung von Standorten

Lösungsansätze:

Vorab: Es gibt vielversprechende Ansätze, aber die Durchdringung ist aktuell $< 2\%$. Folgende Ansätze existieren:

- Agent-Bezogen: Auf den Servern werden Agents installiert, die sich zum WAN-Edge / SSE-Cloud verbinden: Erfordert aber Unterstützte Geräte und ist nicht praktikabel mit IoT und OT oder geschlossenen Systemen.
- Switch-ACLs: Konfiguration von ACLs auf unterstützten Switches. Aktuell nur wenige Hersteller, teils NAC-basiert und AI-Unterstützt. Vorteil: Keine Änderung der Infrastruktur
- Mikrosegmentierung auf Netzbasis durch Forwarding: Sämtlicher Verkehr wird trotz gleicher Broadcast Domain auf den WAN-Edge gezwungen. Manche Hersteller bieten das an, diese haben aber keine AI-Unterstützung für die Segmentierung
- Mikrosegmentierung auf Netzbasis durch Mikronetze: DHCP wird zentral auf dem WAN-Edge beantwortet. Dieser beantwortet alle Anfragen immer mit /32 Netzen. Eine AI unterstützt nach einer Lernphase die Segmentierung.

Mikrosegmentierung von Datacentern und Clouds

Ansatz 1:

Grundsätzlich ist die Technik hier schon etwas weiter. Gerade die Verfügbarkeit von Tags ermöglicht einen dynamischen Dev-Ops-Ansatz. Clouds erlauben unterstützend das einfache setzen von Routing-Policies, womit Verbindungen mit Policy Based Routing einfach unabhängig von klassischen Netzen beliebig geroutet werden können.

- Virtuellen Maschinen werden Tags zugewiesen. Diese Tags identifizieren entweder die Quelle oder ein Ziel und dessen Funktion. Beispiel: <TAG1_DNS-Server> oder <TAG2_SAP-Frontend>
- Anstatt Firewall-Rules auf basis von IPs zu bauen, werden als Quelle und Ziel Solche Tags gesetzt. Beispiel: ALLOW <TAG2_SAP-Frontend> to <TAG1_DNS-Server>
- Tags können dabei von Applikations-Ownern selbst gesetzt werden oder in IaC-Deployments standardisiert werden.
- Zentrale Compliance-Regeln kontrollieren die gesetzten Tags und erzeugen Alarme oder entfernen Tags wieder
- Dadurch werden die Operativen Aufwände für die Mikrosegmentierung massiv reduziert

Mikrosegmentierung von Datacentern und Clouds

Ansatz 2:

Weiterhin Default-Routen der Applikationen / Server auf die Firewall.

- Firewall benutzt AI, um die Policy in drei Schritten selbst aufzubauen:
 - Learning: Die AI Identifiziert und kategorisiert Quellen und Netzwerk-Flüsse
 - Monitoring: Die AI setzt Policies, aber blockiert noch keine Packete. Policies werden noch korrigiert.
 - Enforce: Aktives Enforcement nach Überprüfung der Policies durch Administratoren. Nicht erlaubte Verbindungen werden blockiert.
- **Vorteil:** Hoher Automatisierungsgrad, wenig menschliches Zutun
- **Nachteil:** Falsche Policy-Entscheidungen führen zu Ausfällen oder Über-Berechtigungen

4. SASE in OT Netzen

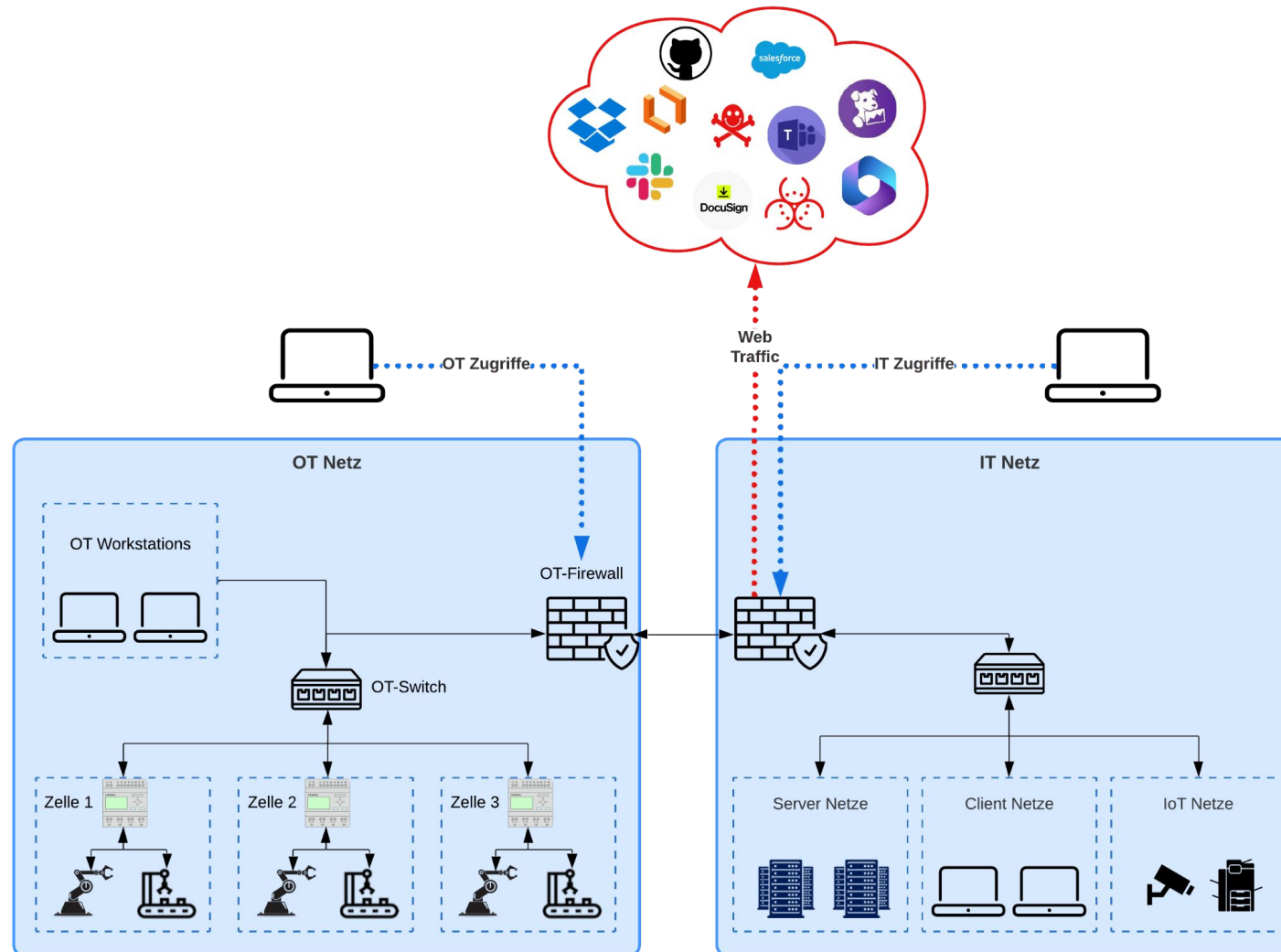
Funktionen und Anforderungen an OT Netze

- OT Netze sind Netze, die Maschinen in der Industrie miteinander verbinden.
- Solche Maschinen sind sehr hohe Investitionen und werden meist **über Jahrzehnte** abgeschrieben und **betrieben** (dementsprechend alt sind ihre Softwarestände)
- Sie werden teils mit **proprietären Protokollen** betrieben (zum Beispiel ProfiNet)
- OT Netze werden meist gesondert betrieben, weil sie sehr **individuelle Anforderungen** haben. Dazu gehören:
 - Fokus auf Hochverfügbarkeit und Resilienz: Auch kürzere Ausfälle können je nach Anlage millionenschwere Schäden zur Folge haben.
 - Offline Betrieb: Anlagen müssen auch produzieren, wenn das Internet ausfällt.
 - Segmentierung: Aufgrund der teils extrem alten Softwarestände werden sie häufig komplett in isolierten Netzen betrieben
 - Wartungszugriffe: Für Wartungen, Störungsbeseitigungen und Kalibrierung muss externen Dienstleistern Zugriff gewährleistet werden

Klassische Funktionsweise von OT-Netzen

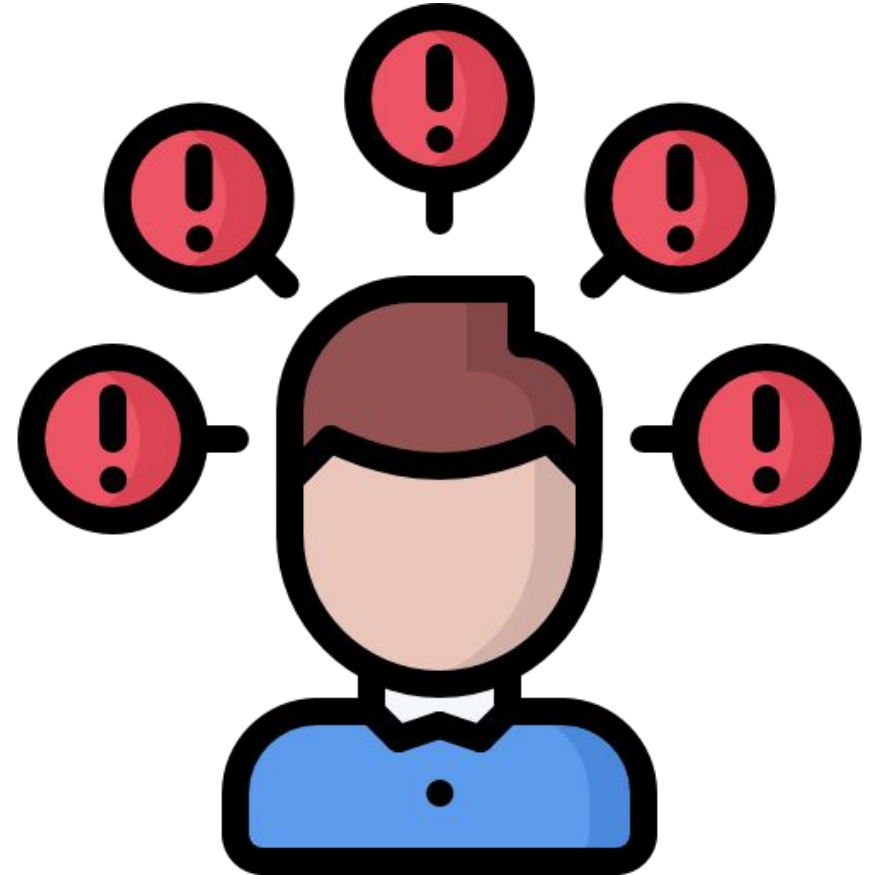
- **Zellenprinzip:** Jede Anlage/Zelle mit SPS steuert Sensoren/Aktoren; Bedienung über einzelne Management-Konsole.
- **Feldkommunikation** (Layer-2): Echtzeit-Kommunikation zwischen SPS und Feldgeräten mittels Profinet.
- **Zellenkopplung** (Layer-3): Zellen/Anlagen werden über Switches und Router verbunden. Ein Leitsystem sammelt und visualisiert ggf. Daten.
- **Segmentierung:** OT-Firewalls terminieren verschiedene VLANs. Oft mit gesonderter DMZ für Datenaustausch mit IT. Sehr limitierter Internet-Zugriff.
- **Remote-Access:** Teilweise mit eigen “VPN-Boxen” der Hersteller, Jump-Hosts oder VPN-Clients für Dienstleister.

Klassische Funktionsweise von OT-Netzen



Übliche Probleme von OT-Netzen

- **Hohe Segmentierungsanforderungen:** Da die Softwarestände meist sehr alt sind, ist Segmentierung entsprechend wichtig aber auch aufwendig.
- **Komplizierter und schwer zu kontrollierender Remote-Access:** Meist unterschiedliche Lösungen für jeden Hersteller, Dienstleister, etc. Bis auf die Netzwerktrennung keine zusätzliche Security (Sandbox, Bot-Detection, etc)
- **Zugriff ins Internet:** Immer stärker werdender Usecase der aktuell durch die Kapselung von OT und IT oft rudimentär mit FW-Rules ermöglicht wird.



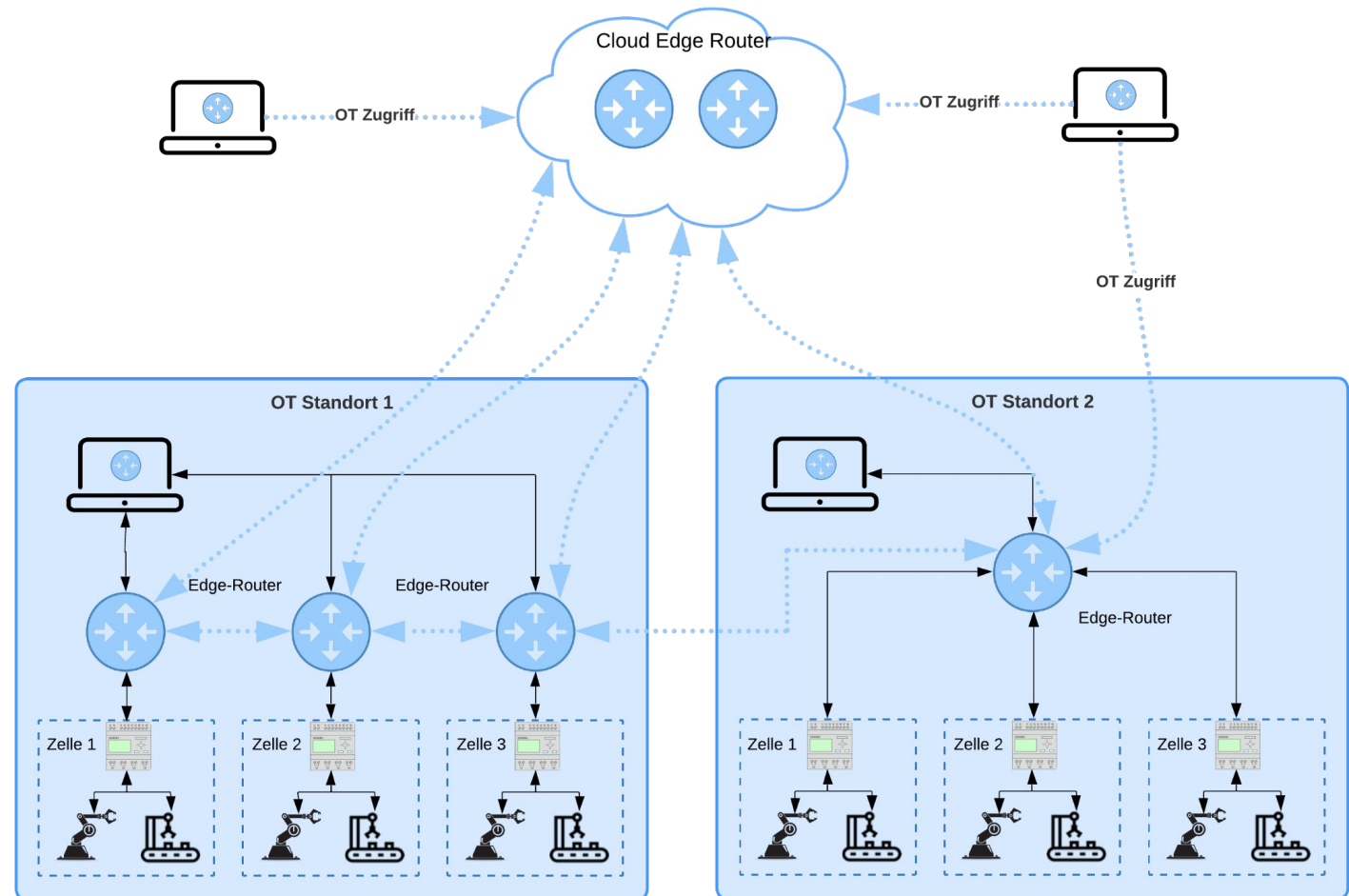
Moderne Lösungsansätze für OT-Netze

- Verwendung von SASE in OT-Infrastrukturen.
- OT terminiert auf dem WAN-Edge
- Das WAN-Edge Gateway übernimmt:
 - Mikrosegmentierung innerhalb der OT (teils automatisiert mit AI)
 - Mikrosegmentierung in und aus Richtung IT
 - Cloud-Proxy Enforcement oder Forwarding (via VPN / GRE)
 - Sicheren und vor allem einfachen (browser-based) Remote-Access für Hersteller und Dienstleister
 - Remote Access für interne Mitarbeiter
 - (Security) Monitoring für Live-Überwachung

Moderne Lösungsansätze für OT-Netze: SINEC

- SINEC ist Siemens ZTNA Lösung speziell für OT (Released 10/2025)
- Sie ist ausschliesslich für OT gedacht, und vernetzt diese standortübergreifend.
- Mikrosegmentierung ist manuell möglich.
- Problem: Trennung von IT und (noch) wenig Features

[Hier](#) mehr lesen.



5. Tipps zur Einführung



1. Ausgangslage und Abhängigkeiten erfassen

- Was für Infrastruktur hat das Unternehmen?
- Public Cloud? (verteilte) Datacenter? SaaS?
- Wie funktioniert der Remote Access für Mitarbeiter und externe? (VDI, VPN, etc.)
- OT / IoT? Serverless Applications? Container? VMs? Physische Server?
- Gibt es nicht SASE-fähige Use Cases (VOIP, server2client, etc.)?
- Wie sind die Standorte vernetzt? (MPLS, SD-WAN, Leased-Lines)
- Wie ist die Segmentierung aufgesetzt (Makro, Mikro, gar nicht)?
- Welche anderen Systeme müssen integriert werden? (NAC, SIEM, XDR, WAF, etc.)
- Welche Compliance-Anforderungen hat das Unternehmen?
- Wie funktionieren aktuelle Service-Prozesse?
- Wie umfangreich und kompetent ist mein IT Team und wie ist deren Auslastung?
- Wie viel "Change" kann den Mitarbeitern zugemutet werden?
- Wie viel Budget steht zur Verfügung?



2. Zielbild und Anforderungen definieren

- Was möchte das Unternehmen erreichen? (mehr Sicherheit, weniger Kosten, etc.)
- Welche Strategischen Aspekte sind zu berücksichtigen? (M&A, Wachstum, Cloud-Fokus)
- Welche Architektur passt am besten zur Strategie und dem Bestand?
- Wie können damit Compliance-Anforderungen eingehalten werden?
- Wie werden die Systeme miteinander integriert? Wie komplex sind die Integrationen?
- Sind im Zielbild alle wichtigen Funktionalitäten bestmöglich abgebildet?
- Wurden Optionen erstellt und verglichen?
- Wurden alle Stakeholder in den Prozess involviert und deren zusätzliche Anforderungen aufgenommen?
- Gibt es eine besser zum Unternehmen passende Lösung?
- Bis wann soll das Zielbild erreicht werden?
- Wie wird der Erfolg der Umsetzung gemessen?
- Wer führt aus, wer entscheidet, wer trägt die Kosten?
- Wie zukunftssicher ist das Zielbild?
- Wie erfolgt die Migration? Parallel-Betrieb oder Big Bang-Ansatz?



3. Verifizierung & Planung

- Funktioniert die Lösungsidee? (Evaluierung mit Proof of Concept)
- Sind alle Anforderungen abgedeckt? Hat der CISO zugestimmt?
- Passen die Angebote zum Budget?
- Ist das Budget sicher gesprochen?
- Können personelle Ressourcen alloziert werden?
- Sind Fachabteilungen und IT-Team informiert?
- Wurden Einwände geprüft?
- Wurde die Migrations-Strategie doppelt verifiziert?
- Gibt es einen Projektplan?
- Nach welcher Methodik wird das Projekt durchgeführt?
- Gibt es einen Projektmanager?
- Haben alle Beteiligten ihre Verfügbarkeit gemeldet?
- Sind die Erfolgskriterien definiert?



4. Pilot und Umsetzung

- Wurden Pilot- und Rollout-Gruppen definiert?
- Wurden alle Vorbereitungen getroffen?
- Gibt es Anpassungen aufgrund von auftretenden Störungen oder Problemen? (-> Dokumentieren und Verbessern)
- Werden die Betroffenen Benutzer und Applikations-Owner vor dem Rollout informiert?
- Ist das Projekt In-Time?
- Kann der aktuelle Prozess verbessert werden? (Review der Störungen und lösen des Problems)
- Sind alle Systeme integriert?
- Gibt es nachträgliche Tätigkeiten, die später durchgeführt werden müssen (-> Dokumentieren)
- Wie kann die User-Experience maximiert werden?



5. Nachbereitung und Review

- Welche offenen Tasks gibt es aus dem Projekt noch? Wer bearbeitet diese bis wann? -> Verantwortlichkeit schaffen
- Wurden alle Ziele erreicht?
- Wie ist das User Feedback? Wie behebt man Beschwerden langfristig (Schulung, Verbesserung, etc.)
- Wurde die Zielerreichung und der Mehrwert den das Projekt dem Unternehmen geschaffen hat gemessen?
- **Wurde die Zielerreichung und der Mehrwert an das Management kommuniziert / präsentiert?**
- Was sind die nächsten Schritte im Kontext einer übergeordneten Strategie?



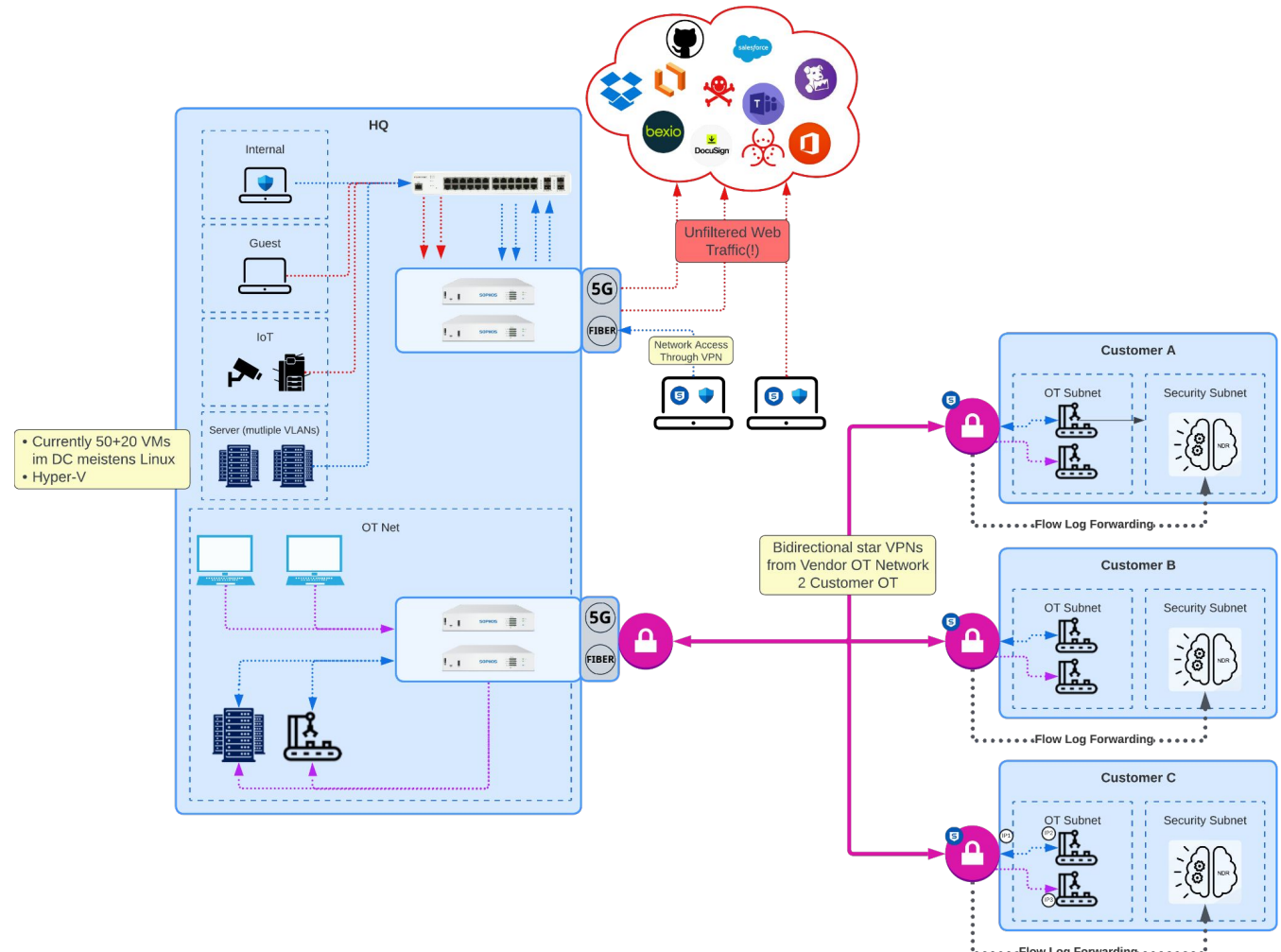
Allgemeine Tipps

- Hartes verhandeln mit Herstellern
- Umsetzen von SSE vor Umstellen auf WAN-Edge
- Betroffenen Benutzer gut informieren was wann gemacht wird
- Messbare Ziele erfassen
- Dem Management den Mehrwert präsentieren

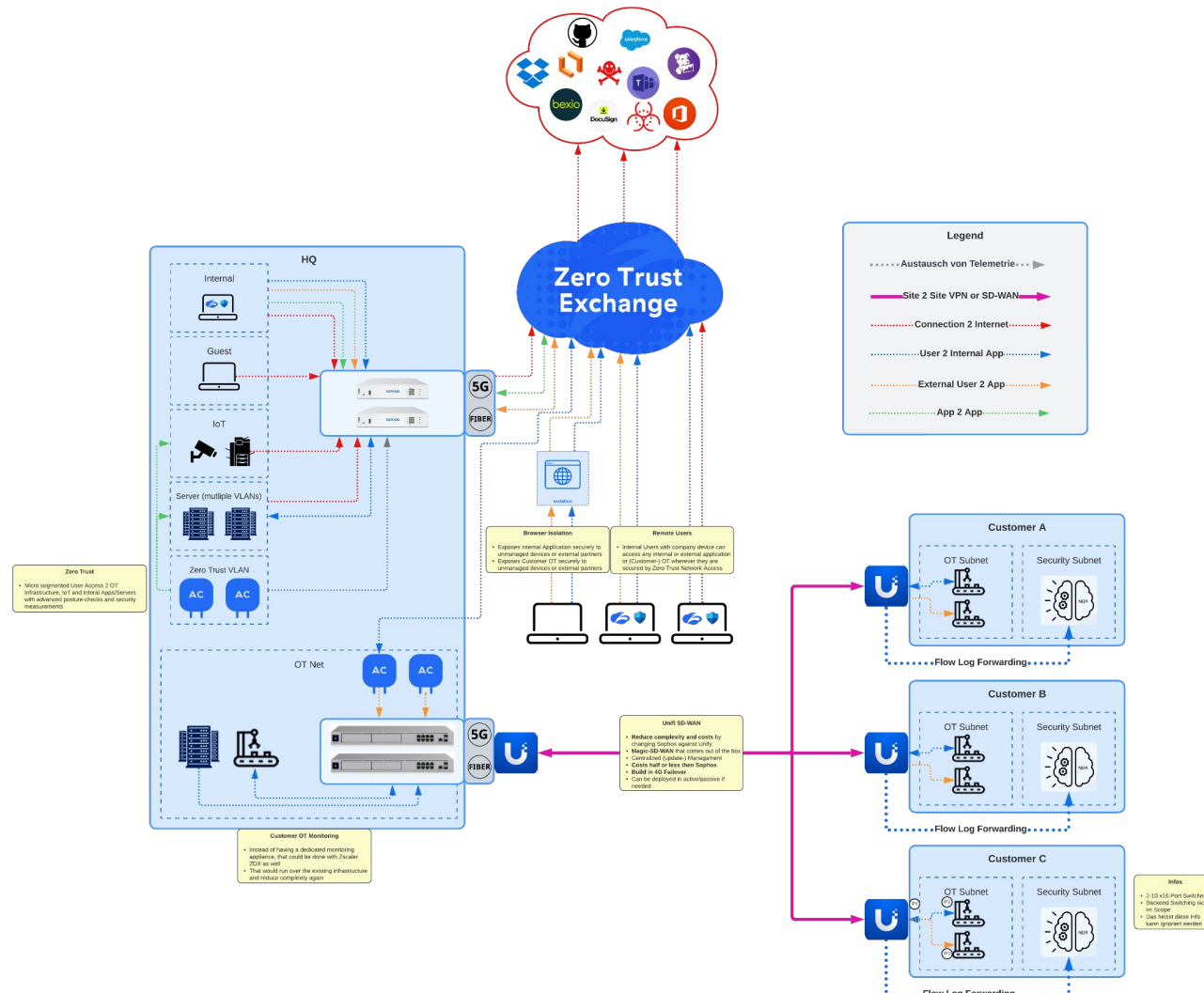
Beispiel Architektur

Industrie Unternehmen (mehrere hundert Mitarbeiter) - Vorher

- Einen Standort mit OT Umgebung
- Beliefern andere Unternehmen mit ihren Maschinen
- Brauchen Zugriff auf diese Maschinen bei Kunden
- Haben eine interne Test-Umgebung



Industrie Unternehmen (mehrere hundert Mitarbeiter) - Nachher



Internationale Universität (mehrere tausend Schüler)

